

**CHƯƠNG TRÌNH QUỐC GIA “NÂNG CAO NĂNG SUẤT VÀ CHẤT LƯỢNG SẢN PHẨM,
HÀNG HÓA CỦA DOANH NGHIỆP VIỆT NAM ĐẾN NĂM 2020”**

QUẢN LÝ AN TOÀN THÔNG TIN THEO TIÊU CHUẨN ISO/IEC 27001

NỘI DUNG CƠ BẢN VÀ HƯỚNG DẪN ÁP DỤNG



NHÀ XUẤT BẢN HÀ NỘI

LỜI NÓI ĐẦU

Xu thế phát triển kinh tế - xã hội, đặc biệt trong bối cảnh hội nhập kinh tế toàn cầu hiện nay, đã và đang chứng minh vai trò, tầm quan trọng và phạm vi không ngừng tăng lên của việc ứng dụng công nghệ thông tin trong mọi lĩnh vực, quá trình, từ công việc của một cá nhân, các hoạt động một tổ chức, cho đến việc vận hành thể chế chính trị và nền kinh tế - xã hội của một quốc gia và cả thế giới. Các lợi ích này cũng luôn song hành cùng các mối đe dọa và rủi ro về an toàn thông tin ngày càng cao, dẫn đến hậu quả ngày càng nghiêm trọng, gây ảnh hưởng đến nhiều khía cạnh khác nhau đối với một tổ chức, doanh nghiệp như làm gián đoạn quá trình kinh doanh, vi phạm các yêu cầu của khách hàng, gây tổn thất về tài chính, ảnh hưởng đến uy tín, thương hiệu và đặc biệt là có thể dẫn tới vi phạm các yêu cầu pháp luật.

Để chủ động kiểm soát, phòng ngừa, hạn chế các hậu quả từ việc mất an toàn thông tin, mỗi tổ chức, doanh nghiệp với nguồn lực của mình, có thể có những cách thức, phương pháp tiếp cận và kiểm soát các rủi ro về an toàn thông tin ở các mức độ khác nhau. Tiêu chuẩn ISO/IEC 27001 đến nay đã được chấp nhận ở quy mô toàn cầu như là một phương pháp quản lý, kiểm soát rủi ro về an toàn thông tin một cách chặt chẽ, có hệ thống và mang lại nhiều lợi ích cho chính tổ chức áp dụng và các bên liên quan.

Cuốn sách nhỏ này nhằm mục đích cung cấp những thông tin cơ bản liên quan đến bộ tiêu chuẩn ISO/IEC 27000 về lĩnh vực an toàn thông tin và hướng dẫn các bước hoạch định, xây dựng, vận hành một hệ thống quản lý an toàn thông tin trong tổ chức, doanh nghiệp phù hợp với yêu cầu của ISO/IEC 27001 để bảo vệ các tài sản thông tin phục vụ cho các hoạt động sản xuất, cung cấp dịch vụ của mình.

Chúng tôi mong nhận được ý kiến đóng góp của bạn đọc để nội dung cuốn sách tiếp tục được cải thiện trong lần tái bản./.

Nhóm biên tập

MỤC LỤC

LỜI NÓI ĐẦU	2
MỤC LỤC	3
NHỮNG TỪ VIẾT TẮT VÀ ĐỊNH NGHĨA.....	5
DANH MỤC CÁC BẢNG BIỂU, HÌNH ẢNH	7
DANH MỤC CÁC PHỤ LỤC	8
Phần 1: NỘI DUNG CƠ BẢN.....	10
Chương 1: Khái quát về bộ tiêu chuẩn ISO/IEC 27000.....	10
1. Giới thiệu về Tổ chức quốc tế về tiêu chuẩn hóa ISO.....	10
2. Quá trình hình thành và phát triển bộ tiêu chuẩn ISO/IEC 27000	13
3. Phạm vi, mục đích, đối tượng áp dụng tiêu chuẩn ISO/IEC 27001	18
4. Những lợi ích cơ bản của việc áp dụng ISMS theo ISO/IEC 27001	19
Chương 2: Tóm tắt nội dung tiêu chuẩn ISO/IEC 27001:2013 và hướng dẫn cách thức đáp ứng yêu cầu của tiêu chuẩn.....	25
1. Cấu trúc của ISO/IEC 27001:2013.....	25
2. Giải thích các yêu cầu chính của tiêu chuẩn ISO/IEC 27001:2013 và hướng dẫn cách thức thực hiện.....	27
3. Lộ trình triển khai hệ thống quản lý ATTT theo ISO/IEC 27001:2013	106
Phần 2: HƯỚNG DẪN TRIỂN KHAI ISO/IEC 27001:2013 TẠI DOANH NGHIỆP	109
Chương 1: Tóm tắt quá trình triển khai ISO/IEC 27001:2013 tại doanh nghiệp	109
1. Các giai đoạn triển khai ISO/IEC 27001:2013.....	109

2. Kế hoạch tổng thể triển khai ISO/IEC 27001:2013	110
Chương 2: Hướng dẫn cách thực hiện dự án ISMS tại tổ chức, doanh nghiệp, những lợi ích dự kiến sẽ thu được và các yếu tố đảm bảo thực hiện thành công	121
1. Hướng dẫn cách thực hiện và một số kết quả đầu ra theo từng bước triển khai Kế hoạch tổng thể xây dựng, thực hiện ISO/IEC 27001:2013	121
2. Một số yếu tố quyết định sự thành công của việc thực hiện ISMS theo ISO/IEC 27001	122
Phần 3: THỰC TIỄN TRIỂN KHAI ÁP DỤNG THỬ NGHIỆM HỆ THỐNG QUẢN LÝ AN TOÀN THÔNG TIN THEO ISO/IEC 27001 TẠI DOANH NGHIỆP.....	125
Chương 1: Tóm tắt kết quả triển khai ISO/IEC 27001:2013 tại 2 doanh nghiệp	125
Chương 2: Một số nhận định và bài học được rút ra từ 2 mô hình thử nghiệm	137

CÁC PHỤ LỤC

QUYẾT ĐỊNH

V/v: Thành lập Ban điều hành Dự án xây dựng và áp dụng Hệ thống quản lý an toàn thông tin theo tiêu chuẩn ISO/IEC 27001:2013 141

QUYẾT ĐỊNH

V/v: Phân công trách nhiệm Đại diện Lãnh đạo về an toàn thông tin theo ISO/IEC 27001 144

QUYẾT ĐỊNH

V/v: Thành lập Tổ Thư ký dự án xây dựng và áp dụng Hệ thống hệ thống quản lý 146

an toàn thông tin theo yêu cầu của ISO/IEC 27001..... 146

TÀI LIỆU THAM KHẢO 181

NHỮNG TỪ VIẾT TẮT VÀ ĐỊNH NGHĨA

ISO	: International Organization for Standardization/ Tổ chức quốc tế về Tiêu chuẩn hóa
IEC	: International Electrotechnical Commission/ Ủy ban kỹ thuật điện quốc tế
IS	: International Standard/ Tiêu chuẩn quốc tế
TC	: Technical Committee/ Ủy ban kỹ thuật (của ISO)
SC	: Sub-committee/ Tiểu ban (thuộc các TC của ISO)

Các Ủy ban kỹ thuật của ISO và IEC hợp tác trong các lĩnh vực mà hai bên đều quan tâm. Trong lĩnh vực công nghệ thông tin (Information Technology/ IT), ISO và IEC đã thành lập Ủy ban kỹ thuật phối hợp (Joint technical committee), viết tắt là ISO/IEC JTC 1.

Tiểu ban kỹ thuật SC 27 (IT Security techniques - Các kỹ thuật an toàn) thuộc ISO/IEC JTC 1 là Tiểu ban chịu trách nhiệm đối với việc phát triển tiêu chuẩn ISO/IEC 27001.

PDC	: Policy Development Committee/ Ủy ban phát triển chính sách (của ISO)
MOST	: Ministry of Science and Technology/ Bộ Khoa học và Công nghệ
STAMEQ	: Directorate for Standards, Metrology and Quality/ Tổng cục Tiêu chuẩn Đo lường Chất lượng
ATTT	: An toàn thông tin

ISMS	: Information Security Management System/ Hệ thống quản lý an toàn thông tin
P-D-C-A	: Plan - Do - Check - Act/ Hoạch định - Thực hiện - Kiểm tra - Hành động cải tiến (Chu trình cải tiến liên tục)
C	: Confidentiality/ Tính bảo mật
I	: Integrity/ Tính toàn vẹn
A	: Availability/ Tính sẵn có
RTP	: Risk Treatment Plan/ Kế hoạch xử lý rủi ro
SoA	: Statement Of Applicability/ Thông báo việc áp dụng

DANH MỤC CÁC BẢNG BIỂU, HÌNH ẢNH

Bảng:

- Bảng 1-1 : Tóm tắt mức độ và hình thức tham gia của STAMEQ vào hoạt động phát triển tiêu chuẩn ISO (tính đến tháng 4/2019)
- Bảng 1-2 : Tình trạng ban hành của một số tiêu chuẩn trong bộ tiêu chuẩn ISO/IEC 27000 đến 4/2019
- Bảng 1-3 : Số lượng chứng chỉ đã được cấp theo các hệ thống quản lý phổ biến dựa trên tiêu chuẩn ISO.
- Bảng 1-4 : Nhóm 10 quốc gia có số chứng chỉ ISO/IEC 27001 cao nhất thế giới theo thống kê trong năm 2016.
- Bảng 1-5 : Số chứng chỉ ISO/IEC 27001 được cấp ở khu vực Đông Á và Thái Bình Dương năm 2016 và 2017
- Bảng 1-6 : Bảng trình bày các điều khoản chính của tiêu chuẩn ISO/IEC 27001:2013
- Bảng 2-1 : Nội dung cơ bản của Kế hoạch tổng thể triển khai xây dựng, áp dụng hệ thống quản lý ATTT theo ISO/IEC 27001:2013

Hình:

- Hình 1-1 : Tỷ lệ % tiêu chuẩn quốc tế ISO được đã được ban hành theo các lĩnh vực
- Hình 1-2 : Khái quát về các nhóm tiêu chuẩn thành phần trong bộ tiêu chuẩn ISO/IEC 27000
- Hình 1-3 : Cấu trúc các yêu cầu của ISO/IEC 27001:2013 theo

Chu trình P-D-C-A

Hình 1-4 : Sơ đồ lộ trình triển khai hệ thống quản lý ATTT theo ISO/IEC 27001:2013

DANH MỤC CÁC PHỤ LỤC

- Phụ lục 1 : Quyết định thành lập Ban điều hành triển khai thực hiện ISMS theo ISO/IEC 27001:2013
- Phụ lục 2 : Quyết định phân công vai trò Lãnh đạo an toàn thông tin theo ISO/IEC 27001:2013
- Phụ lục 3 : Quyết định thành lập Tổ thư ký ISO/IEC 27001:2013
- Phụ lục 4 : Báo cáo đánh giá thực trạng dựa theo yêu cầu ISO/IEC 27001:2013 (Gap Analysis)
- Phụ lục 5 : Xác định phạm vi áp dụng ISMS
- Phụ lục 6 : Kế hoạch xây dựng hệ thống văn bản ISMS
- Phụ lục 7 : Chính sách chung về ATTT
- Phụ lục 8 : Bảng kiểm kê tài sản thông tin
- Phụ lục 9 : Bảng đánh giá rủi ro về ATTT
- Phụ lục 10 : Mục tiêu ATTT
- Phụ lục 11 : Kế hoạch xử lý rủi ro ATTT
- Phụ lục 12 : Bản Thông báo việc áp dụng SoA
- Phụ lục 13 : Chính sách kiểm soát ATTT cụ thể - ví dụ Chính sách an toàn nguồn nhân lực khi kết thúc công việc
- Phụ lục 14 : Kế hoạch đo lường hiệu lực của ISMS
- Phụ lục 15 : Hoạch định cụ thể đo lường hiệu lực của ISMS - đo

lượng chất lượng mật khẩu

Phụ lục 16 : Kế hoạch đánh giá nội bộ ISMS

Phần 1

NỘI DUNG CƠ BẢN

Chương 1

Khái quát về bộ tiêu chuẩn ISO/IEC 27000

1. Giới thiệu về Tổ chức quốc tế về tiêu chuẩn hóa ISO

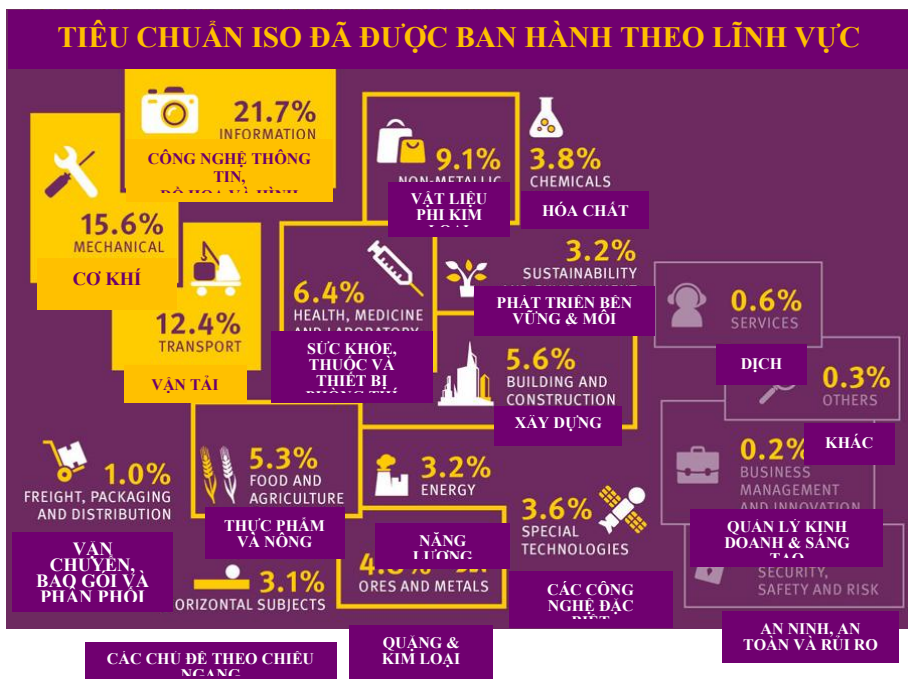
Năm 1946, phái đoàn từ 25 quốc gia nhóm họp tại Học viện các Kỹ sư xây dựng ở Luân Đôn để quyết định thành lập một tổ chức quốc tế nhằm thúc đẩy sự hợp tác quốc tế và hợp nhất các tiêu chuẩn ngành công nghiệp. Ngày 23 tháng 02 năm 1947, Tổ chức quốc tế về Tiêu chuẩn hóa ISO chính thức đi vào hoạt động.

Năm 2017, ISO kỷ niệm sự kiện 70 năm thành lập. Tại thời điểm này, ISO có 163 quốc gia thành viên với tổng số tiêu chuẩn đã được ban hành là hơn 21.000 tiêu chuẩn.

Tính đến tháng 4/2019, có 164 quốc gia thành viên tham gia vào ISO và 786 Ủy ban kỹ thuật và các Tiểu ban chịu trách nhiệm phát triển các tiêu chuẩn. Hiện có hơn 135 người làm việc chính thức ở trụ sở cơ quan Tổng Thư ký của ISO tại Geneva, Thụy Sĩ. Cũng vào thời điểm này, ISO đã ban hành hơn 22.586 tiêu chuẩn quốc tế (IS) liên quan đến hầu hết các khía cạnh khác nhau của công nghệ và sản xuất.

Hình 1-1 cung cấp thông tin tổng quan về các lĩnh vực và tỉ lệ (%) các tiêu chuẩn ISO đã được ban hành theo từng lĩnh vực. Trong đó, có thể thấy con số 21,7% trên tổng số tiêu chuẩn ISO đã được ban hành trong lĩnh vực công nghệ thông tin, đồ họa và hình ảnh đã phản ánh khá rõ xu hướng phát triển và ứng dụng công nghệ thông tin ngày

càng mạnh mẽ, sâu rộng trong mọi lĩnh vực phát triển kinh tế - xã hội ở cả cấp độ quốc gia và quốc tế.



Hình 1-1: Tỷ lệ % tiêu chuẩn quốc tế ISO được đã được ban hành theo các lĩnh vực

Việt Nam tham gia vào ISO kể từ năm 1977, với cơ quan đại diện là Tổng cục Tiêu chuẩn Đo lường Chất lượng (STAMEQ) (thuộc Bộ Khoa học và Công nghệ - MOST), chịu trách nhiệm tham mưu cho Chính phủ và Bộ Khoa học và Công nghệ về quản lý nhà nước trong lĩnh vực tiêu chuẩn hóa, đo lường và chất lượng.

STAMEQ đã và đang tham gia ngày càng nhiều vào quá trình phát triển tiêu chuẩn quốc tế với tư cách là thành viên của các Ủy ban kỹ thuật (TC) và Ủy ban phát triển chính sách (PDC) của ISO theo hai

hình thức gồm thành viên "Tham gia chính thức/ Participating/ P-Member" và thành viên "Quan sát/ Observing/ O-Member) tùy theo từng lĩnh vực tiêu chuẩn. **Bảng 1-1** tóm tắt mức độ và hình thức tham gia của STAMEQ vào hoạt động phát triển tiêu chuẩn ISO tính đến tháng 4/2019:

Tham gia vào	Mức độ, hình thức tham gia của STAMEQ vào hoạt động phát triển tiêu chuẩn ISO
TC	P-Member của 17 TC sau: ISO/TC 176/SC 2 Các hệ thống chất lượng ISO/TC 207 Quản lý môi trường ISO/TC 207/SC 1 Hệ thống quản lý môi trường ISO/TC 207/SC 2 Kiểm toán môi trường và hoạt động điều tra liên quan đến môi trường ISO/TC 207/SC 7 Quản lý khí nhà kính và các hoạt động liên quan ISO/TC 22/SC 38 Mô tô và xe máy ISO/TC 234 Thủy sản và nuôi trồng thủy sản ISO/TC 249 Đông được ISO/TC 268 Thành phố và cộng đồng bền vững ISO/TC 282 Tái sử dụng nước ISO/TC 34/SC 15 Cà phê ISO/TC 45 Cao su và sản phẩm từ cao su ISO/TC 45/SC 2 Thử nghiệm và phân tích ISO/TC 45/SC 3 Nguyên liệu (kể cả mủ cao su) cho

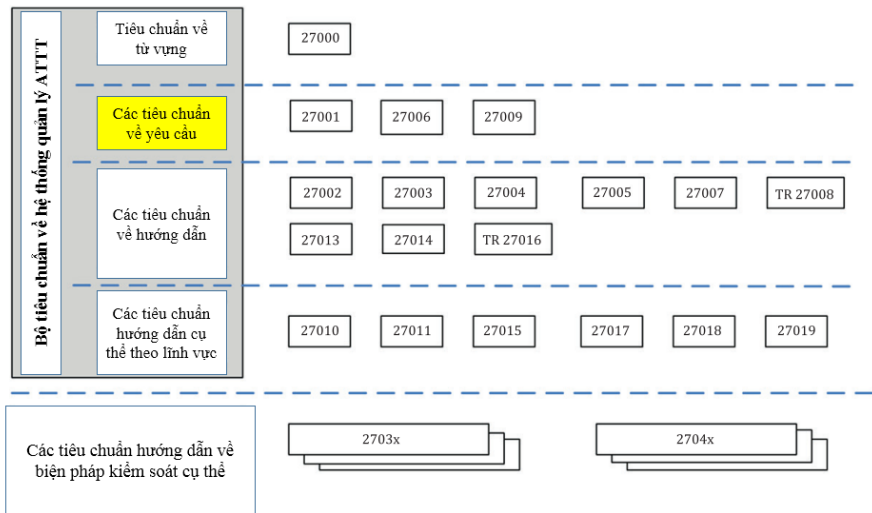
	công nghiệp cao su ISO/TC 5/SC 10 Mặt bích kim loại và gioăng nổi ISO/TC 5/SC 5 Phụ kiện ren, phụ kiện hàn, đo ren ISO/TC 71/SC 7 Bảo trì và sửa chữa cầu kiện bê tông
	O-Member của 72 TC (chi tiết tại: https://www.iso.org/member/2199.html?view=participation&t=OT)
PDC	P-Member của 02 PDC sau: ISO/CASCO Ủy ban đánh giá sự phù hợp ISO/DEVCO Ủy ban các vấn đề của các nước đang phát triển
	O-Member của 02 PDC sau: ISO/COPOLCO Ủy ban về chính sách đối với người tiêu dùng ISO/REMCO Ủy ban về các vật liệu/ mẫu chuẩn

Bảng 1-1: Tóm tắt mức độ và hình thức tham gia của STAMEQ vào hoạt động phát triển tiêu chuẩn ISO (tính đến tháng 4/2019)

2. Quá trình hình thành và phát triển bộ tiêu chuẩn ISO/IEC 27000

ISO/IEC 27000 là bộ tiêu chuẩn được phát triển nhằm hỗ trợ các tổ chức bảo vệ an toàn các tài sản thông tin của mình, thông qua việc quản lý được tính an toàn của các tài sản thông tin như thông tin về tài chính, sở hữu trí tuệ, thông tin về nhân sự hoặc các thông tin được tổ

chức ủy thác cho bên thứ ba. **Hình 1-2** khái quát về các nhóm tiêu chuẩn thành phần trong bộ tiêu chuẩn ISO/IEC 27000.



Hình 1-2: Khái quát về các nhóm tiêu chuẩn thành phần trong bộ tiêu chuẩn ISO/IEC 27000

ISO/IEC 27001 là một tiêu chuẩn quan trọng trong bộ tiêu chuẩn ISO/IEC 27000, đưa ra yêu cầu đối với một hệ thống quản lý an toàn thông tin. Tiền thân của ISO/IEC 27001 là tiêu chuẩn về quản lý an toàn thông tin BS 7799 của Viện Tiêu chuẩn Anh quốc (British Standards Institute - BSI). Tháng 12/2000, tiêu chuẩn BS 7799-1 được Tổ chức Tiêu chuẩn hoá quốc tế (ISO) chính thức chấp nhận và ban hành thành tiêu chuẩn quốc tế ISO/IEC 17799:2000.

Năm 2005, tiêu chuẩn ISO/IEC 17799:2000 được sửa đổi và ban hành thành phiên bản đầu tiên của tiêu chuẩn ISO/IEC 27001:2005 : Công nghệ thông tin - Hệ thống quản lý an toàn thông tin - Các yêu cầu.

Tháng 10/2013, phiên bản thứ hai - ISO/IEC 27001:2013 được

ban hành để thay thế cho phiên bản ISO/IEC 27001:2005, xuất phát từ hai yếu tố tác động chính, thứ nhất, đó là yêu cầu từ việc áp dụng Phụ lục/ Annex SL năm 2012 của ISO đối với việc chuẩn hóa, thống nhất các khái niệm, thuật ngữ và cấu trúc của tiêu chuẩn về hệ thống quản lý của ISO. Thứ hai, đó là việc đưa vào áp dụng các nguyên tắc về quản lý rủi ro theo hướng dẫn của tiêu chuẩn ISO 31000:2009 - Quản lý rủi ro - Các nguyên tắc và hướng dẫn (hiện tại, ISO 31000:2018 đã được ban hành để thay thế cho phiên bản 2009, với tiêu đề được đổi thành "Quản lý rủi ro - Hướng dẫn").

Đến tháng 4/2019, tình trạng ban hành một số tiêu chuẩn chính trong bộ tiêu chuẩn ISO/IEC 27000 được trình bày trong **Bảng 1-2**, trong đó tiêu chuẩn ISO/IEC 27001 là tiêu chuẩn được biết đến nhiều nhất, nhằm đưa ra yêu cầu đối với một hệ thống quản lý an toàn thông tin (ISMS), các tiêu chuẩn còn lại nhằm mục đích hỗ trợ cho việc thiết lập, vận hành, giám sát, duy trì, cải tiến hiệu lực của một ISMS:

Bảng 1-2: Tình trạng ban hành của một số tiêu chuẩn trong bộ tiêu chuẩn ISO/IEC 27000 đến 4/2019 (tham khảo thêm tại:

<https://www.iso.org/committee/45306/x/catalogue/>)

Ký hiệu tiêu chuẩn	Tiêu đề tiêu chuẩn
ISO/IEC 27000:2018	Công nghệ thông tin - Kỹ thuật an toàn - Hệ thống quản lý an toàn thông tin - Khái quát và từ vựng
ISO/IEC 27001:2013 <i>Cor.1 2014</i> <i>Cor.2. 2015</i>	Công nghệ thông tin - Kỹ thuật an toàn - Hệ thống quản lý an toàn thông tin - Các yêu cầu

Ký hiệu tiêu chuẩn	Tiêu đề tiêu chuẩn
ISO/IEC 27002:2013 <i>Cor.1 2014</i> <i>Cor2. 2015</i>	Công nghệ thông tin - Kỹ thuật an toàn Quy phạm thực hành các biện pháp kiểm soát an toàn thông tin
ISO/IEC 27003:2017	Công nghệ thông tin - Kỹ thuật an toàn - Hệ thống quản lý an toàn thông tin - Hướng dẫn
ISO/IEC 27004:2016	Công nghệ thông tin - Kỹ thuật an toàn Quản lý an toàn thông tin - Theo dõi, đo lường, phân tích, đánh giá
ISO/IEC 27005:2018	Công nghệ thông tin - Kỹ thuật an toàn - Quản lý rủi ro an toàn thông tin
ISO/IEC 27006:2015	Công nghệ thông tin - Kỹ thuật an toàn - Các yêu cầu đối với tổ chức đánh giá và chứng nhận hệ thống quản lý an toàn thông tin
ISO/IEC 27007:2017	Công nghệ thông tin - Kỹ thuật an toàn - Hướng dẫn đánh giá hệ thống quản lý an toàn thông tin
ISO/IEC TS 27008:2019	Công nghệ thông tin - Kỹ thuật an toàn - Hướng dẫn đánh giá các biện pháp kiểm soát ATTT
ISO/IEC 27009:2016	Công nghệ thông tin - Kỹ thuật an toàn - Việc áp dụng ISO/IEC 27001 theo lĩnh vực cụ thể - Các yêu cầu

Ký hiệu tiêu chuẩn	Tiêu đề tiêu chuẩn
ISO/IEC 27010:2015	Công nghệ thông tin - Kỹ thuật an toàn - Quản lý an toàn thông tin đối với thông tin liên lạc trong nội bộ tổ chức và giữa các ngành
ISO/IEC 27011:2016 Cor.1 2018	Công nghệ thông tin - Kỹ thuật an toàn - Hướng dẫn quản lý an toàn thông tin đối với các tổ chức viễn thông dựa trên ISO/IEC 27002
ISO/IEC 27013:2015	Công nghệ thông tin - Kỹ thuật an toàn - Hướng dẫn thực hiện tích hợp ISO/IEC 27001 và ISO/IEC 20000-1
ISO/IEC 27014:2013	Công nghệ thông tin - Kỹ thuật an toàn - Quản trị về ATTT
ISO/IEC TR 27016:2014	Công nghệ thông tin - Kỹ thuật an toàn - Kinh tế tổ chức
ISO/IEC 27017:2015	Công nghệ thông tin - Kỹ thuật an toàn - Quy phạm thực hành các biện pháp kiểm soát ATTT dựa theo ISO/IEC 27002 đối với các dịch vụ đám mây
ISO/IEC 27032:2012	Công nghệ thông tin - Kỹ thuật an toàn - Hướng dẫn về an ninh mạng (Guidelines for cybersecurity)
ISO/IEC 27035-1:2016	Công nghệ thông tin - Kỹ thuật an toàn - Quản lý sự cố ATTT - Phần 1: Nguyên tắc quản lý sự cố

Ký hiệu tiêu chuẩn	Tiêu đề tiêu chuẩn
ISO/IEC 27035-2:2016	Công nghệ thông tin - Kỹ thuật an toàn - Quản lý sự cố ATTT - Phần 2: Hướng dẫn lập kế hoạch và chuẩn bị ứng phó sự cố

3. Phạm vi, mục đích, đối tượng áp dụng tiêu chuẩn ISO/IEC 27001

ISO/IEC 27001 có thể áp dụng đối với mọi loại hình tổ chức (doanh nghiệp sản xuất, dịch vụ, thương mại, cơ quan chính phủ, các tổ chức phi chính phủ...). Tiêu chuẩn này quy định các yêu cầu đối với việc thiết lập, thực hiện, vận hành, giám sát, xem xét, duy trì và cải tiến một hệ thống quản lý an toàn thông tin (ISMS) dưới dạng văn bản trong bối cảnh các rủi ro liên quan đến các quá trình kinh doanh/tác nghiệp tổng thể của chính tổ chức đó. Tiêu chuẩn cũng quy định cụ thể các yêu cầu đối với việc thực hiện các biện pháp kiểm soát an toàn tương thích với nhu cầu của chính tổ chức. Mục đích cuối cùng của hệ thống là nhằm bảo vệ các tài sản thông tin và tạo lòng tin cho các bên quan tâm.

Các mục đích cụ thể của việc áp dụng ISO/IEC 27001:2013:

- Được sử dụng trong nội bộ tổ chức để triển khai các yêu cầu và mục tiêu về an toàn thông tin;
- Được xem như là một cách để đảm bảo rằng các rủi ro về an toàn thông tin được quản lý có hiệu quả về chi phí;
- Để đảm bảo sự tuân thủ pháp luật, chế định;
- Tạo khuôn khổ cho việc thực hiện và quản lý các biện pháp kiểm soát nhằm đảm bảo đạt được các mục tiêu an toàn thông tin cụ thể của tổ chức;

- Hỗ trợ việc định nghĩa về các quá trình quản lý an toàn thông tin mới;
- Nhận biết và làm rõ các quá trình quản lý an toàn thông tin hiện có trong tổ chức;
- Được lãnh đạo sử dụng để xác định tình trạng của các hoạt động quản lý an toàn thông tin;
- Được các chuyên gia đánh giá nội bộ và chuyên gia đánh giá bên ngoài sử dụng để xác định mức độ tuân thủ theo các chính sách, định hướng và các tiêu chuẩn mà tổ chức chấp nhận để thực hiện;
- Để cung cấp thông tin liên quan đến chính sách, định hướng, tiêu chuẩn và các thủ tục về an toàn thông tin đến các đối tác kinh doanh và các tổ chức khác có tương tác với các quá trình của tổ chức;
- Để cung cấp thông tin về việc đảm bảo an toàn thông tin đến khách hàng của tổ chức.

4. Những lợi ích cơ bản của việc áp dụng ISMS theo ISO/IEC 27001

Những lợi ích của việc thực hiện ISMS chủ yếu có được từ việc giảm các rủi ro về ATTT (ví dụ như giảm khả năng xảy ra và/ hoặc tác động gây ra bởi các sự cố ATTT). Cụ thể là, các lợi ích đã được thừa nhận đối với một tổ chức, doanh nghiệp nhằm đạt được sự thành công bền vững thông qua việc chấp nhận và áp dụng ISMS theo ISO/IEC 27001 bao gồm:

- a) Tạo được khuôn khổ được cấu trúc để hỗ trợ cho việc quy định, thực hiện, vận hành và duy trì hệ thống quản lý ATTT toàn diện, hiệu quả về chi phí, tạo thêm giá trị (cho khách hàng, các bên quan tâm và cho chính tổ chức), nhất quán và đồng bộ nhằm thỏa mãn các nhu cầu của tổ chức;
- b) Hỗ trợ cho lãnh đạo của tổ chức trong việc quản lý và vận hành một cách nhất quán, có trách nhiệm đối với hoạt động quản lý về

ATTT, dựa trên nền tảng quản lý các rủi ro của tổ chức, kể cả việc giáo dục và đào tạo cho các chủ thể của hệ thống và các quá trình nghiệp vụ trong tổ chức, doanh nghiệp về quản lý ATTT;

c) Thúc đẩy việc áp dụng các thực hành tốt về ATTT đã được chấp nhận toàn cầu, tạo cơ hội để tổ chức, doanh nghiệp có thể tiếp cận và chấp nhận áp dụng, cải tiến các biện pháp kiểm soát phù hợp với tình huống/ bối cảnh cụ thể của mình, cũng như để duy trì các biện pháp kiểm soát này trước những thay đổi từ nội bộ và bên ngoài;

d) Tạo lòng tin cho khách hàng, các đối tác kinh doanh về hệ thống quản lý ATTT được tuân thủ, phù hợp tiêu chuẩn được thừa nhận quốc tế, nhất là khi các đối tác này yêu cầu chứng nhận sự phù hợp của hệ thống quản lý ATTT theo yêu cầu ISO/IEC 27001 bởi một tổ chức chứng nhận được công nhận;

e) Thỏa mãn được nhu cầu và mong đợi của xã hội về khía cạnh ATTT, kể cả việc đáp ứng, tuân thủ các yêu cầu của pháp luật;

f) Đạt hiệu quả hơn về quản lý về kinh tế khi đầu tư cho quản lý ATTT.

5. Tình hình áp dụng ISO/IEC 27001 trên thế giới:

Theo kết quả khảo sát năm 2017 của ISO dựa trên nguồn thông tin từ các tổ chức chứng nhận, tính đến 31/12/2017, tổng cộng có 39.500 chứng chỉ ISO/IEC 27001 đã được cấp cho các tổ chức ở 160 quốc gia, nền kinh tế trên toàn cầu. Trong đó, cũng đã ghi nhận mức tăng 19% (tương ứng với 6.211 chứng chỉ) ở năm 2017 so với năm 2016 (33.290 chứng chỉ). **Bảng 1-3** tóm tắt số lượng chứng chỉ đã được cấp theo các hệ thống quản lý phổ biến dựa trên tiêu chuẩn ISO của năm 2017 so với năm 2016, trong khi đó **Bảng 1-4** là nhóm 10 quốc gia có số chứng chỉ ISO/IEC 27001 cao nhất thế giới theo thống kê trong năm 2016:

Bảng 1-3: Số lượng chứng chỉ đã được cấp theo các

hệ thống quản lý phổ biến dựa trên tiêu chuẩn ISO

Tiêu chuẩn hệ thống quản lý	Thống kê số lượng chứng chỉ			%
	Năm 2016	Năm 2017	Thay đổi	thay đổi
ISO 9001/ Hệ thống quản lý chất lượng	1.105.937	1.058.504	-47.433	-4
ISO 14001/ Hệ thống quản lý môi trường	346.147	362.61	16.463	5
ISO 50001/ Hệ thống quản lý năng lượng	20.216	21.501	1.285	6
ISO/IEC 27001/ Hệ thống quản lý an toàn thông tin	33.290	39.501	6.211	19
ISO 22000/ Hệ thống quản lý an toàn thực phẩm	32.139	32.722	583	2
ISO 13485/ Hệ thống quản lý an toàn đối với dụng cụ y tế	29.585	31.520	1.935	7
ISO 22301/ Hệ thống quản lý liên tục kinh doanh	3.853	4.281	428	11
ISO 39001/ Hệ thống quản lý an toàn giao thông đường bộ	478	620	142	30

Bảng 1-4: Nhóm 10 quốc gia có số chứng chỉ ISO/IEC 27001 cao nhất thế giới theo thống kê trong năm 2016

10 quốc gia có số chứng chỉ ISO/IEC 27001 cao nhất thế giới
--

(năm 2016)		
1	Nhật Bản/ Japan	8.945
2	Anh Quốc/ United Kingdom	3.367
3	Ấn độ/ India	2.902
4	Trung quốc/ China	2.618
5	Đức/ Germany	1.338
6	Ý/ Italy	1.220
7	Mỹ/ United States of America	1.115
8	Đài Loan/ Trung quốc/ Taipei, Chinese	1.087
9	Tây Ban Nha/ Spain	752
10	Hà Lan/ Netherlands	670

Cũng theo khảo sát năm 2017 của ISO, ở khu vực Đông Á và Thái Bình Dương, cũng ghi nhận tổng cộng có 17.562 chứng chỉ được thống kê trong 2017, so với con số 14.704 chứng chỉ của năm 2016. **Bảng 1-5** cung cấp thông tin chi tiết về chứng chỉ ISO/IEC 27001 ở khu vực này, trong đó 198 và 64 là số lượng chứng chỉ được thống kê ở Việt Nam lần lượt cho năm 2017 và 2016.

Bảng 1-5: Số chứng chỉ ISO/IEC 27001 được cấp ở khu vực Đông Nam Á và Thái Bình Dương năm 2016 và 2017

Quốc gia	Số chứng chỉ ISO/IEC 27001 theo năm
----------	-------------------------------------

	Năm 2016	Năm 2017
	14.704	17.562
Úc/ Australia	531	404
Brunei		1
Cambodia	1	4
China	2.618	5.069
Hong Kong, China	173	182
Macau, China	13	14
Taipei, Chinese	1.087	994
Fiji	2	1
Indonesia	115	222
Japan	8.945	9.161
Korea, Democratic People's Republic of	1	2
Korea, Republic of	364	369
Lao People's Democratic Republic	2	4
Malaysia	260	317
Marshall Islands		1
Micronesia (Federal States of)		1
Mongolia	2	2
Myanmar	1	1
New Zealand	27	28

Quốc gia	Số chứng chỉ ISO/IEC 27001 theo năm	
	Năm 2016	Năm 2017
Palau		1
Papua New Guinea		1
Philippines	168	174
Singapore	112	123
Thailand	218	287
Vanuatu		1
Vietnam	64	198

Chương 2

Tóm tắt nội dung tiêu chuẩn ISO/IEC 27001:2013 và hướng dẫn cách thức đáp ứng yêu cầu của tiêu chuẩn

1. Cấu trúc của ISO/IEC 27001:2013

Phiên bản tiêu chuẩn ISO/IEC 27001:2013 đã được áp dụng cấu trúc theo hướng dẫn ở Phụ lục Annex SL (2012) của Tổ chức ISO đối với tiêu chuẩn về hệ thống quản lý được áp dụng cho tổ chức, như trình bày trong **Bảng 1-6**:

**Bảng 1-6: Bảng trình bày các điều khoản chính của tiêu chuẩn
ISO/IEC 27001:2013**

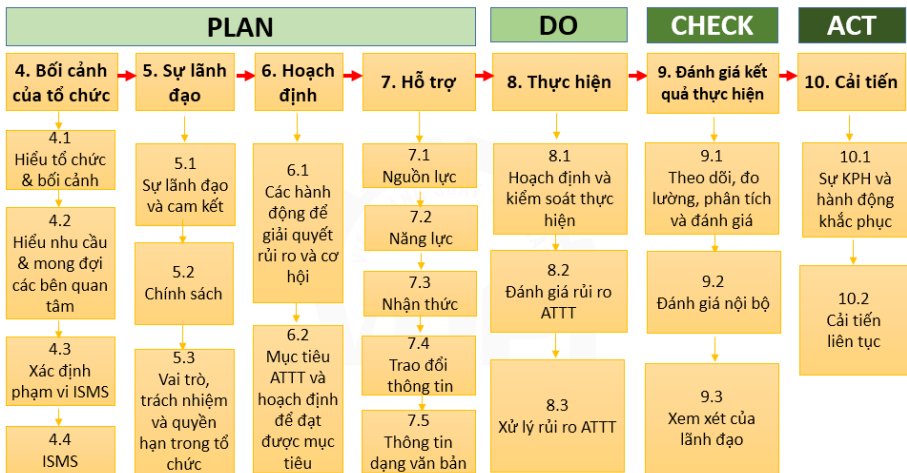
Điều mục	Tiêu đề
0	Giới thiệu
1	Phạm vi
2	Tiêu chuẩn trích dẫn
3	Thuật ngữ và định nghĩa
4	Bối cảnh của tổ chức
4.1	Hiểu về tổ chức và bối cảnh của tổ chức
4.2	Hiểu về nhu cầu và mong đợi của các bên quan tâm
4.3	Xác định phạm vi của hệ thống quản lý an toàn thông tin
4.4	Hệ thống quản lý an toàn thông tin
5	Sự lãnh đạo

5.1	Sự lãnh đạo và cam kết
5.2	Chính sách
5.3	Vai trò, trách nhiệm và quyền hạn trong tổ chức
6	Hoạch định
6.1	Các hành động giải quyết rủi ro và cơ hội
6.2	Mục tiêu an toàn thông tin và hoạch định để thực hiện mục tiêu
7	Hỗ trợ
7.1	Nguồn lực
7.2	Năng lực
7.3	Nhận thức
7.4	Trao đổi thông tin
7.5	Thông tin dạng văn bản
8	Thực hiện
8.1	Hoạch định và kiểm soát việc thực hiện
8.2	Đánh giá rủi ro an toàn thông tin
8.3	Xử lý rủi ro an toàn thông tin
9	Đánh giá kết quả thực hiện
9.1	Theo dõi, đo lường, phân tích và đánh giá
9.2	Đánh giá nội bộ
9.3	Xem xét của lãnh đạo
10	Cải tiến

10.1	Sự không phù hợp và hành động khắc phục
10.2	Cải tiến liên tục
Phụ lục A (quy định)	Tham chiếu các mục tiêu kiểm soát và biện pháp kiểm soát

Các yêu cầu chính của tiêu chuẩn (từ Điều 4 đến Điều 10) được sắp xếp trong tiêu chuẩn dựa trên việc vận dụng chu trình P-D-C-A để thiết lập, thực hiện, duy trì, cải tiến một hệ thống quản lý ATTT phù hợp với ISO/IEC 27001:2013. Sơ đồ ở **Hình 1-3** trình bày cấu trúc các yêu cầu của ISO/IEC 27001:2013 theo Chu trình P-D-C-A:

Cấu trúc chung các yêu cầu của ISO/IEC 27001:2013



Hình 1-3: Cấu trúc các yêu cầu của ISO/IEC 27001:2013 theo chu trình P-D-C-A

2. Giải thích các yêu cầu chính của tiêu chuẩn ISO/IEC 27001:2013 và hướng dẫn cách thức thực hiện

Phần dưới đây được trình bày trên cơ sở tham khảo tiêu chuẩn ISO/IEC 27003:2017 - Công nghệ thông tin - Các kỹ thuật an toàn: Hệ thống quản lý an toàn thông tin - Hướng dẫn để tóm tắt cách thức thực hiện, đáp ứng từng yêu cầu chính của ISO/IEC 27001:2013.

Điều 4 - Bối cảnh của tổ chức	
4.1 Hiểu về tổ chức và bối cảnh của tổ chức	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> Tổ chức phải xác định các vấn đề bên ngoài và nội bộ có liên quan đến mục đích của tổ chức và ảnh hưởng đến khả năng của tổ chức để đạt được các kết quả dự kiến của ISMS
	<i>Giải thích:</i> • Khi thực hiện các hoạt động của mình, tổ chức phải thường xuyên xem xét, phân tích về chính mình và thế giới quanh mình. Việc phân tích này có liên quan đến các vấn đề bên ngoài và nội bộ có ảnh hưởng đến ATTT và bằng cách nào ATTT được quản lý, cũng như có liên quan đến các mục tiêu của tổ chức. • Có 3 mục đích của việc phân tích, gồm: ✓ Để hiểu về bối cảnh, từ đó xác định phạm vi áp dụng ISMS; ✓ Để hiểu về các rủi ro và cơ hội; ✓ Để đảm bảo ISMS phù hợp với sự thay đổi của các vấn đề bên ngoài và nội bộ. • Những vấn đề bên ngoài là những gì nằm ngoài sự kiểm soát của tổ chức, có thể về các khía cạnh môi trường sau, tùy theo sự ưu tiên và tình huống cụ thể của từng tổ chức: - Văn hóa và xã hội (ví dụ: nhu cầu của xã hội đối với các dịch vụ do tổ chức cung cấp);

	b) Chính trị, pháp luật, chế định (ví dụ: các quy định của pháp luật khi sử dụng các dịch vụ về IT do bên ngoài cung cấp); c) Tài chính và vĩ mô (ví dụ: nhu cầu của xã hội đối với các dịch vụ do tổ chức cung cấp); d) Công nghệ (ví dụ: các tiến bộ kỹ thuật của các công cụ tấn công (hack) và việc sử dụng mã hóa); e) Tự nhiên (ví dụ: các đặc điểm tự nhiên về khả năng của các tai họa như cháy, lũ lụt, động đất); f) Cạnh tranh. • Các vấn đề nội bộ là những gì thuộc sự kiểm soát của tổ chức, có thể về các khía cạnh sau: g) Văn hóa của tổ chức; h) Chính sách, mục tiêu và chiến lược để đạt được mục tiêu; i) Việc quản trị, cơ cấu tổ chức, các vai trò, trách nhiệm; j) Các tiêu chuẩn, hướng dẫn và các mô hình mẫu được tổ chức chấp nhận; k) Các mối quan hệ hợp đồng có thể trực tiếp ảnh hưởng các quá trình thuộc phạm vi áp dụng ISMS của tổ chức; l) Các quá trình và thủ tục; m) Năng lực, xét về các nguồn lực và tri thức (ví dụ: vốn, thời gian, nhân sự, quá trình, các hệ thống và công nghệ); n) Cơ sở hạ tầng và môi trường vật lý; o) Các hệ thống thông tin, các dòng thông tin và các quá
--	---

	trình ra quyết định (cả chính thức và không chính thức); p) Các cuộc đánh giá trước đó và các kết quả đánh giá rủi ro trước đó. Các kết quả của việc xác định các vấn đề bên ngoài và nội bộ (tức là xác định bối cảnh) sẽ được sử dụng để xác định phạm vi của ISMS (điều 4.3), để xác định hành động giải quyết rủi ro và cơ hội (điều 6.1) và để phục vụ cho hoạt động xem xét của lãnh đạo (điều 9.3).
	<i>Hướng dẫn:</i> • Căn cứ trên việc hiểu rõ về mục đích của tổ chức (ví dụ như từ "Sứ mệnh" và Kế hoạch kinh doanh của tổ chức), cũng như các kết quả dự kiến của ISMS của tổ chức, tổ chức phải: ✓ Xem xét môi trường bên ngoài để xác định các vấn đề bên ngoài liên quan; ✓ Xem xét các khía cạnh nội bộ để xác định các vấn đề nội bộ liên quan. • Để xác định các vấn đề liên quan đó, tổ chức có thể đặt câu hỏi "<i>Liệu từng vấn đề từ a) đến p) như liệt kê trên sẽ ảnh hưởng đến các mục tiêu ATTT của tổ chức như thế nào?</i>". Dưới đây là 3 ví dụ minh họa đối với các vấn đề nội bộ: ✓ Ví dụ 1 (liên quan đến việc quản trị và cơ cấu tổ chức, mục i)): Khi thiết lập ISMS, việc quản trị điều hành và cơ cấu tổ chức hiện tại phải được đưa vào xem xét. Ví dụ như tổ chức có thể có mô hình cơ cấu tổ chức trong ISMS dựa trên cơ cấu tổ chức đã được xác định trong các hệ thống quản lý hiện có khác, và có thể kết hợp

	các chức năng chung như việc xem xét của lãnh đạo và hoạt động đánh giá. ✓ Ví dụ 2 (liên quan đến chính sách, mục tiêu và chiến lược, mục h)): Việc phân tích các chính sách, mục tiêu và các chiến lược hiện có, có thể chỉ ra điều mà tổ chức dự định sẽ đạt được và cách thức mà các mục tiêu ATTT sẽ được lồng ghép cùng với các mục tiêu kinh doanh để đảm bảo các kết quả thành công. ✓ Ví dụ 3 (liên quan các hệ thống thông tin và các dòng thông tin, mục o)): Khi xác định các vấn đề nội bộ, tổ chức phải xác định, ở mức độ chi tiết nhất định, các dòng thông tin giữa các hệ thống thông tin khác nhau của mình. • Các vấn đề, cả bên ngoài lẫn nội bộ, sẽ thay đổi theo thời gian, các vấn đề và ảnh hưởng của chúng lên phạm vi, những hạn chế và các yêu cầu của ISMS phải được xem xét thường xuyên. • Các thông tin dạng văn bản cho hoạt động xác định bối cảnh và kết quả đầu ra chỉ bắt buộc dưới hình thức và mức độ mà tổ chức xác định là cần thiết để đảm bảo tính hiệu lực của ISMS của mình (theo điều 7.5.1.b của ISO/IEC 27001:2013).
4.2 Mục tiêu và mong đợi của các bên quan tâm	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Tổ chức phải xác định các bên quan tâm liên quan đến ISMS của tổ chức và các yêu cầu của họ về vấn đề ATTT.
	<i>Giải thích:</i> • Bên quan tâm được hiểu là cá nhân hay tổ chức có thể có ảnh hưởng, hoặc chịu ảnh hưởng bởi một quyết định hoặc

	hoạt động của tổ chức đang xét. Bên quan tâm có thể bao gồm những bên từ bên ngoài và từ nội bộ của tổ chức, có thể có những nhu cầu, mong đợi cụ thể đối với ATTT của tổ chức. • Bên quan tâm từ bên ngoài có thể gồm: ✓ Cơ quan quản lý nhà nước; ✓ Các cổ đông, kẻ và chủ sở hữu và nhà đầu tư; ✓ Các nhà cung cấp, kẻ cả thầu phục, tư vấn và đối tác từ bên ngoài; ✓ Các hiệp hội ngành nghề; ✓ Các đối thủ cạnh tranh; ✓ Khách hàng và người tiêu dùng; ✓ Các nhóm hoạt động. • Các bên quan tâm từ nội bộ có thể gồm: ✓ Những người có quyền ra quyết định, kẻ cả lãnh đạo cao nhất; ✓ Chủ thể của các quá trình, chủ thể các hệ thống và chủ thể thông tin; ✓ Các chức năng hỗ trợ như các nguồn lực về IT, về nhân sự; ✓ Nhân viên/ người lao động, người dùng (users); ✓ Chuyên gia về ATTT. • Kết quả xác định các bên quan tâm sẽ được sử dụng để xác định phạm vi của ISMS (điều 4.3) và hoạch định hành động giải quyết rủi ro, cơ hội (điều 6.1). <i>Hướng dẫn:</i>
--	--

	• Cần tiến hành các bước sau đây: ✓ Xác định các bên quan tâm từ bên ngoài; ✓ Xác định các bên quan tâm từ nội bộ; ✓ Xác định yêu cầu của các bên quan tâm đó. • Vì nhu cầu, mong đợi của các bên quan tâm sẽ thay đổi theo thời gian, các thay đổi này có thể có ảnh hưởng lên phạm vi, các hạn chế và các yêu cầu trong ISMS của tổ chức, do đó tổ chức cần phải xem xét, theo dõi để cập nhật thường xuyên về các thay đổi này. • Kết quả đầu ra của điều 4.2 có thể được tổ chức lập thành văn bản tới mức cần thiết để đảm bảo tính hiệu lực của hệ thống ISMS (theo điều 7.5.1.b).
4.3 Phạm vi của ISMS	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Tổ chức phải xác định các ranh giới và khả năng áp dụng ISMS để thiết lập phạm vi áp dụng ISMS.
	<i>Giải thích:</i> • Phạm vi ISMS sẽ xác định rõ ISMS sẽ được áp dụng "ở đâu" và cho "cái gì" đối với tổ chức, cũng như làm rõ "ở đâu" và "cái gì" sẽ không được áp dụng. • Theo đó, phạm vi ISMS sẽ giúp xác định các hoạt động nào được thực hiện trong ISMS. Ví dụ, việc đánh giá rủi ro và xử lý rủi ro, cũng như việc xác định các biện pháp kiểm soát sẽ không thể mang lại kết quả có giá trị nếu như tổ chức không hiểu được chính xác ISMS của mình được áp dụng cho điều gì, hoạt động nào. • Các yếu tố sau đây có thể ảnh hưởng đến việc xác định phạm vi của ISMS:

	✓ Các vấn đề bên ngoài và nội bộ (đã mô tả ở điều 4.1); ✓ Các bên quan tâm và yêu cầu của họ (đã mô tả ở điều 4.2); ✓ Tính sẵn sàng của các hoạt động kinh doanh, nghiệp vụ mà ISMS sẽ đề cập đến; ✓ Các chức năng hỗ trợ, ví dụ như quản lý nhân lực; dịch vụ IT và các ứng dụng phần mềm; việc quản lý cơ sở hạ tầng, các tòa nhà, các khu vực vật lý, các dịch vụ và tiện ích thiết yếu); ✓ Tất cả các chức năng có nguồn gốc từ bên ngoài, kể cả những phần khác cùng thuộc tổ chức hoặc thuộc nhà cung cấp độc lập.
	<i>Hướng dẫn:</i> • Tổ chức cần tiến hành các bước sau để thiết lập phạm vi của ISMS: ✓ Xác định phạm vi sơ bộ: nên được tiến hành bởi một nhóm nhỏ những người đại diện lãnh đạo (ví dụ lãnh đạo công ty và lãnh đạo cấp phòng ban trong công ty); ✓ Tinh chỉnh phạm vi: các đơn vị chức năng trong và ngoài phạm vi sơ bộ cần được xem xét khi xác định ranh giới/ giao diện giữa bên trong và ngoài phạm vi, tương ứng với các hoạt động sản xuất/ kinh doanh thuộc phạm vi ISMS; ✓ Xác định phạm vi chính thức: lãnh đạo tổ chức sẽ đánh giá, xem xét lại phạm vi đã được tinh chỉnh nói trên; ✓ Phê duyệt phạm vi ISMS: Lãnh đạo cao nhất phê duyệt chính thức văn bản xác định phạm vi của ISMS.

	• Thông tin dạng văn bản xác định phạm vi của ISMS phải bao gồm: ✓ Phạm vi, ranh giới và các giao diện về mặt tổ chức; ✓ Phạm vi, ranh giới và các giao diện về mặt công nghệ thông tin; và ✓ Phạm vi, ranh giới và các giao diện về mặt vật lý.
4.4 ISMS	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Tổ chức phải thiết lập, thực hiện, duy trì và cải tiến thường xuyên ISMS.
	<i>Giải thích:</i> • Điều này đưa ra yêu cầu chung đối với việc thiết lập, thực hiện, duy trì và cải tiến thường xuyên một hệ thống quản lý ATTT để qua đó đáp ứng đầy đủ các yêu cầu khác trong tiêu chuẩn ISO/IEC 27001:2013.
	<i>Hướng dẫn:</i> • Việc tổ chức triển khai thực hiện tất cả các yêu cầu của ISO/IEC 27001:2013 chính là cơ sở để đáp ứng yêu cầu 4.4 này.

Điều 5 - Sự lãnh đạo

5.1 Sự lãnh đạo và cam kết

Các hoạt động theo yêu cầu tiêu chuẩn:

- Lãnh đạo cao nhất phải chứng minh vai trò lãnh đạo và sự cam kết đối với ISMS.

Giải thích:

- Vai trò và sự cam kết của lãnh đạo cao nhất của tổ chức là thiết yếu để thực hiện thành công ISMS. "Lãnh đạo cao nhất" theo định nghĩa trong ISO/IEC 27000:2018, đó là người hay nhóm người chỉ đạo và kiểm soát một tổ chức về ISMS ở cấp độ cao nhất. Theo đó, lãnh đạo cao nhất có trách nhiệm toàn diện thể đối với ISMS, chỉ đạo điều hành ISMS theo cách tương tự như điều hành các lĩnh vực khác trong tổ chức, ví dụ như phân bổ và kiểm soát về ngân sách để triển khai ISMS. Lãnh đạo cao nhất có thể trao quyền và cung cấp các nguồn lực cho các hoạt động trong ISMS, tuy nhiên vẫn phải duy trì trách nhiệm tổng thể của mình đối với ISMS.

✓ Ví dụ, trường hợp một tổ chức thực hiện, vận hành ISMS có thể là một đơn vị con trong một tổ chức lớn hơn. Khi đó, lãnh đạo cao nhất là người hay nhóm người chỉ đạo và kiểm soát đơn vị con đó.

- Lãnh đạo cao nhất cũng tham gia vào hoạt động xem xét của lãnh đạo (điều 9.3) và thúc đẩy cải tiến liên tục (điều 10.2).

Hướng dẫn:

- Lãnh đạo cao nhất phải chứng minh về vai trò lãnh đạo và

sự cam kết thông qua việc:

- ✓ Đảm bảo rằng Chính sách ATTT và các Mục tiêu ATTT được thiết lập và tương thích với định hướng chiến lược của tổ chức;
- ✓ Đảm bảo rằng các yêu cầu của ISMS và các biện pháp kiểm soát sẽ được tích hợp vào các quá trình kinh doanh của tổ chức. Cách thức để đạt được điều này phải được bố trí sao cho phù hợp với bối cảnh cụ thể của tổ chức. Ví dụ, một tổ chức ở đó có đã có phân định vai trò chủ thể quá trình thì có thể giao trách nhiệm thực hiện các yêu cầu liên quan trong ISMS cho người hay nhóm người đó. Sự hỗ trợ của lãnh đạo cao nhất cũng cần thiết để giúp vượt qua những trở ngại, vướng mắc trước các thay đổi về quá trình và các biện pháp kiểm soát;
- ✓ Đảm bảo sự sẵn có của các nguồn lực để thực hiện ISMS có hiệu lực. Các nguồn lực cần thiết cho các giai đoạn thiết lập, thực hiện, duy trì và cải tiến ISMS, cũng như các nguồn lực để thực hiện các biện pháp kiểm soát, có thể bao gồm những loại nguồn lực sau:
 - ❖ Nguồn lực tài chính;
 - ❖ Nguồn nhân lực;
 - ❖ Nhà xưởng, thiết bị, tiện ích...;
 - ❖ Cơ sở hạ tầng kỹ thuật.Các nguồn lực cần thiết phụ thuộc vào bối cảnh của tổ chức, ví dụ như quy mô, mức độ phức tạp, các yêu cầu nội bộ và bên ngoài. Khi lãnh đạo tiến hành xem

	xét về ISMS, phải cung cấp thông tin cho thấy các nguồn lực đã thỏa đáng cho ISMS của tổ chức chưa. ✓ Lãnh đạo cao nhất phải truyền đạt nhu cầu quản lý ATTT trong tổ chức và nhu cầu của việc đáp ứng các yêu cầu của ISMS. Có thể thực hiện điều này qua việc cung cấp các ví dụ thực tế để minh họa nhu cầu thực sự của ATTT trong bối cảnh của tổ chức và qua việc truyền đạt các yêu cầu về ATTT trong tổ chức; ✓ Lãnh đạo cao nhất phải đảm bảo rằng ISMS sẽ đạt được các kết quả dự kiến bằng cách hỗ trợ việc thực hiện các quá trình quản lý ATTT, cụ thể thông qua việc yêu cầu và xem xét các báo cáo về tình hình thực hiện và tính hiệu lực của ISMS. Các báo cáo đó có thể thu được từ hoạt động đo lường (điều 6.2, 9.1), hoạt động xem xét của lãnh đạo và các báo cáo đánh giá. Lãnh đạo cao nhất cũng có thể đạt ra các mục tiêu thực hiện cho những nhân sự chủ chốt trong ISMS; ✓ Lãnh đạo cao nhất phải chỉ đạo và hỗ trợ các nhân sự trong tổ chức có liên quan trực tiếp đến ATTT và ISMS. Nếu việc này làm không tốt có thể gây tác động xấu đến hiệu lực của ISMS. Các phản hồi từ lãnh đạo cao nhất có thể bao gồm việc các hoạt động đã được hoạch định được đồng bộ với chiến lược của tổ chức như thế nào, cũng như đối với việc thiết lập ưu tiên cho các hoạt động khác nhau trong ISMS; ✓ Lãnh đạo cao nhất phải đánh giá các nhu cầu nguồn lực khi tiến hành xem xét của lãnh đạo và thiết lập mục tiêu cải tiến liên tục và việc giám sát tính hiệu
--	---

	lực của các hoạt động đã hoạch định; ✓ Lãnh đạo cao nhất phải hỗ trợ các nhân sự có vai trò và trách nhiệm đã được phân công, xác định trong ISMS, theo đó họ được khích lệ để có thể chỉ đạo, hỗ trợ các hoạt động về ATTT ở phạm vi trách nhiệm của họ. • Trong những trường hợp, khi tổ chức thực hiện ISMS là một phần thuộc một tổ chức lớn hơn (ví dụ công ty mẹ), sự lãnh đạo và cam kết có thể được cải thiện bằng sự cam kết, tham gia với người hay nhóm người có quyền kiểm soát và chỉ đạo ở tổ chức lớn hơn (công ty mẹ). Nếu họ hiểu những gì có trong việc thực hiện một ISMS thì họ có thể hỗ trợ cho lãnh đạo cao nhất trong phạm vi của ISMS để giúp họ chứng minh vai trò lãnh đạo và cung cấp cam kết cho ISMS. Ví dụ: nếu các bên quan tâm từ bên ngoài phạm vi của ISMS (ví dụ như công ty mẹ của tổ chức áp dụng ISMS) có tham gia vào việc ra quyết định liên quan đến các Mục tiêu ATTT và tiêu chí về rủi ro và họ có nhận thức về các kết quả tích cực sẽ thu được từ ISMS, khi đó các quyết định của họ liên quan đến phân bổ các nguồn lực sẽ được đồng bộ với các yêu cầu của ISMS.
5.2 Chính sách	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Lãnh đạo cao nhất phải thiết lập Chính sách ATTT.
	<i>Giải thích:</i> • Chính sách ATTT mô tả tầm quan trọng chiến lược của ISMS đối với một tổ chức và phải đảm bảo được duy trì dưới dạng thông tin bằng văn bản. Chính sách ATTT sẽ định hướng cho các hoạt động ATTT trong cả tổ chức,

	nêu rõ những nhu cầu đối với ATTT là gì trong bối cảnh thực tế của tổ chức.
	<i>Hướng dẫn:</i> • Chính sách ATTT phải bao gồm các công bố ngắn gọn ở cấp độ cao về dự định và sự định hướng về ATTT trong một tổ chức, có thể cụ thể theo phạm vi của ISMS hoặc mở rộng hơn. • Tất cả các chính sách khác, các thủ tục, các hoạt động và các mục tiêu liên quan đến ATTT phải nhất quán với Chính sách ATTT. • Chính sách ATTT phải phản ánh được tình huống kinh doanh của tổ chức, văn hóa, những vấn đề và mối quan tâm đến ATTT. Mức độ của Chính sách ATTT phải phù hợp với mục đích và văn hóa của tổ chức sao cho cân bằng giữa tính dễ đọc và sự đầy đủ về nội dung của chính sách, đồng thời cũng giúp những đối tượng/ người sử dụng Chính sách có thể tự nhận diện được mình trong định hướng chiến lược về ATTT có trong Chính sách. • Chính sách ATTT có thể bao gồm các mục tiêu ATTT hoặc mô tả về cơ sở bằng cách nào thiết lập mục tiêu ATTT (nghĩa là, ai sẽ thiết lập Mục tiêu ATTT và bằng cách nào triển khai mục tiêu trong phạm vi của tổ chức). Ví dụ: ở các tổ chức quy mô lớn, các mục tiêu ở cấp độ cao cần được thiết lập bởi lãnh đạo cấp cao của toàn tổ chức. Từ đó, dựa trên khuôn khổ được đặt ra trong Chính sách ATTT, các mục tiêu sẽ được cụ thể hóa để có thể định hướng cho tất cả các bên quan tâm. • Chính sách ATTT phải đưa ra sự tuyên bố rõ ràng của lãnh

	đạo cao nhất về cam kết đối với việc đáp ứng các yêu cầu về ATTT; về việc lãnh đạo cao nhất sẽ hỗ trợ cho cải tiến liên tục mọi hoạt động. • Chính sách ATTT phải được truyền đạt đến tất cả những người trong phạm vi ISMS, do đó, định dạng và ngôn ngữ sử dụng trong Chính sách phải phù hợp để những đối tượng liên quan có thể hiểu được dễ dàng. • Lãnh đạo cao nhất phải quyết định việc truyền đạt Chính sách ATTT đến những bên quan tâm nào. Theo đó, Chính sách ATTT có thể được viết theo cách thích hợp để có thể truyền đạt/ công bố ra cho các bên quan tâm từ bên ngoài. Ví dụ, các bên quan tâm từ bên ngoài có thể là khách hàng, nhà cung cấp, nhà thầu/ thầu phụ và các cơ quan quản lý. Nếu Chính sách ATTT được đảm bảo sẵn có cho bên ngoài thì nội dung của nó không được chứa các thông tin có yêu cầu bảo mật. • Chính sách ATTT có thể được thiết lập riêng rẽ hoặc có thể được kết hợp chung trong Chính sách tổng thể về các vấn đề khác nhau của tổ chức (ví dụ: chất lượng, môi trường và ATTT).
5.3 Vai trò, trách nhiệm, quyền hạn trong tổ chức	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Lãnh đạo cao nhất phải đảm bảo các trách nhiệm, quyền hạn của các vai trò liên quan trong ISMS được xác định và được truyền đạt trong toàn tổ chức.
	<i>Giải thích:</i> • Lãnh đạo cao nhất phải đảm bảo các vai trò, trách nhiệm, quyền hạn về ATTT được xác định và được truyền đạt. Mục đích là nhằm phân công rõ ràng các trách nhiệm,

	quyền hạn trong việc đảm bảo sự phù hợp của ISMS theo các yêu cầu của ISO/IEC 27001, và đảm bảo việc báo cáo kết quả thực hiện ISMS đến lãnh đạo cao nhất.
	<i>Hướng dẫn:</i> • Lãnh đạo cao nhất là người phải đảm bảo việc xác định, truyền đạt về các vai trò, trách nhiệm, quyền hạn để ISMS đáp ứng yêu cầu tiêu chuẩn. Tuy nhiên, điều này không có nghĩa là lãnh đạo cao nhất phải trực tiếp phân định vai trò, trách nhiệm, quyền hạn mà có thể trao quyền để thực hiện việc đó. Lãnh đạo cao nhất nên phê duyệt các vai trò, trách nhiệm, quyền hạn chủ chốt trong ISMS. • Các trách nhiệm, quyền hạn liên quan các hoạt động ATTT bao gồm: ✓ Điều phối việc xây dựng, thực hiện, duy trì, báo cáo kết quả thực hiện và cải tiến ISMS; ✓ Cố vấn về đánh giá rủi ro ATTT và xử lý rủi ro ATTT; ✓ Thiết kế các quá trình và các hệ thống ATTT; ✓ Thiết lập các tiêu chuẩn về việc xác định, cấu hình và thực hiện các biện pháp kiểm soát ATTT; ✓ Quản lý sự cố về ATTT; ✓ Xem xét và đánh giá ISMS. • Ngoài các vai trò trực tiếp liên quan đến ATTT, các trách nhiệm, quyền hạn về ATTT cũng cần bao gồm các vai trò khác, ví dụ, các trách nhiệm về ATTT có thể được kết hợp trong các vai trò sau: ✓ Các chủ thể thông tin; ✓ Các chủ thể quá trình;

	✓ Các thủ thủ tài sản (ví dụ: các chủ thể về các ứng dụng, các cơ sở hạ tầng); ✓ Các chủ thể rủi ro; ✓ Các bộ phận chức năng hoặc nhân sự về an toàn thông tin để hỗ trợ trong ISMS; ✓ Người quản lý dự án; ✓ Người quản lý đường truyền (line); ✓ Người dùng (users). • Thông tin dạng văn bản về các vai trò, trách nhiệm, quyền hạn về ATTT ở hình thức nào và tới mức độ nào cần thiết là do tổ chức quyết định để đảm bảo tính hiệu lực của ISMS (điều 7.5.1.b - ISO/IEC 27001:2013).
--	---

Điều 6 - Hoạch định

6.1 Hành động giải quyết rủi ro và cơ hội/ 6.1.1 Khái quát

Các hoạt động theo yêu cầu tiêu chuẩn:

- Khi tiến hành hoạch định ISMS, tổ chức phải xác định các rủi ro và cơ hội, có xét đến các vấn đề/ bối cảnh (điều 4.1) và các yêu cầu (điều 4.2).

Giải thích:

- Đối với các rủi ro và cơ hội liên quan đến các kết quả dự kiến của ISMS, tổ chức phải xác định chúng dựa trên kết quả xác định bối cảnh bên ngoài và nội bộ (đã thực hiện theo điều 4.1) và các yêu cầu của các bên quan tâm (đã thực hiện ở điều 4.2). Từ đó, tổ chức tiến hành hoạch định ISMS của mình để:
 - a) Đảm bảo rằng sẽ đạt được các kết quả dự kiến từ việc thực hiện ISMS, các rủi ro ATTT sẽ được các chủ thể rủi ro hiểu và được xử lý tới mức có thể chấp nhận (ví dụ về rủi ro: các quá trình và trách nhiệm không rõ ràng; nhận thức của nhân viên kém; thiếu sự quan tâm của lãnh đạo,...);
 - b) Ngăn ngừa hoặc giảm các tác động không mong muốn của rủi ro đối với kết quả dự kiến của ISMS (ví dụ về rủi ro: việc quản lý rủi ro kém hoặc nhận thức kém về các rủi ro);
 - c) Đạt được sự cải tiến liên tục (xem điều 10.2), ví dụ như thông qua cơ chế thích hợp để phát hiện và khắc phục các điểm yếu trong các quá trình quản lý hoặc tranh thủ được cơ hội để cải thiện về ATTT (ví dụ về

	rủi ro: việc quản lý kèm đối với hệ thống tài liệu và các quá trình của ISMS). • Khi tổ chức theo đuổi các cơ hội trong các hoạt động của mình, các hoạt động này sẽ có tác động đến bối cảnh của tổ chức hoặc các nhu cầu, mong đợi của các bên quan tâm và có thể làm thay đổi các rủi ro đối với tổ chức. Ví dụ về cơ hội: tập trung kinh doanh vào các lĩnh vực sản phẩm/ dịch vụ; thiết lập chiến lược marketing cho từng vùng miền, hoặc mở rộng quan hệ kinh doanh với các tổ chức khác. • Việc hoạch định ở điều 6.1.1 bao gồm việc xác định về: d) Các hành động để giải quyết rủi ro và cơ hội; e) Cách thức để: ❖ Tích hợp và thực hiện các hành động giải quyết rủi ro, cơ hội vào các quá trình của ISMS; ❖ Đánh giá hiệu lực của các hành động này. <i>Hướng dẫn:</i> • Tổ chức phải: f) Xác định các rủi ro và cơ hội có thể ảnh hưởng đến việc đạt được các mục a), b), c), có xét đến bối cảnh của tổ chức và các yêu cầu của các bên quan tâm; g) Xây dựng một kế hoạch để thực hiện các hành động đã xác định và để đánh giá tính hiệu lực của các hành động đó. Các hành động giải quyết rủi ro, cơ hội cần được tích hợp vào các quá trình trong ISMS và trong hệ thống thông tin dạng văn bản của ISMS. Các hành động này cũng phải được liên kết đến các mục tiêu ATTT mà theo đó, các rủi ro ATTT được đánh giá và
--	---

	được xử lý. Hình thức và mức độ của các thông tin dạng văn bản cho hoạt động này và kết quả đầu ra là do tổ chức quyết định để đảm bảo tính hiệu lực của ISMS (điều 7.5.1.b - ISO/IEC 27001:2013).
6.1.2 Đánh giá rủi ro ATTT	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> Tổ chức phải xác định và áp dụng quá trình đánh giá rủi ro ATTT.
	<i>Giải thích:</i> - Tổ chức phải xác định quá trình đánh giá rủi ro ATTT, ở đó: a) Thiết lập và duy trì: ✓ Các tiêu chí chấp nhận rủi ro; ✓ Chuẩn mực để tiến hành đánh giá rủi ro ATTT, bao gồm tiêu chí đánh giá hậu quả và khả năng xảy ra, và các quy tắc để xác định mức độ của rủi ro; b) Đảm bảo rằng việc đánh giá rủi ro ATTT sẽ cho ra các kết quả nhất quán, có giá trị và có thể so sánh. - Quá trình đánh giá rủi ro ATTT theo đó được xác định theo các quá trình con sau đây: c) Nhận biết rủi ro ATTT: ✓ Nhận biết rủi ro gắn với các tổn thất về tính bảo mật (C), tính toàn vẹn (I) và tính sẵn có (A) của các tài sản thông tin thuộc phạm vi của ISMS; ✓ Nhận biết chủ thể của rủi ro, tức là xác định và chỉ định người/ nhóm người có trách nhiệm và quyền hạn tương ứng để quản lý các rủi ro đã nhận diện.

	d) Phân tích rủi ro ATTT: ✓ Đánh giá về các hậu quả tiềm tàng nếu các rủi ro đã nhận diện xảy ra, tức là các tác động trực tiếp lên chức năng/ việc kinh doanh của tổ chức, ví dụ như gây tổn thất về tài chính; hoặc tác động gián tiếp như gây thiệt hại uy tín. Việc đánh giá hậu quả có thể theo cách định tính hoặc định lượng. ✓ Đánh giá về khả năng xảy ra của rủi ro đã nhận diện, theo cách định tính (ví dụ khả năng, hay tần suất xảy ra) hoặc cách định lượng (cho điểm); ✓ Xác định mức độ của rủi ro đã nhận diện dựa trên sự kết hợp hai yếu tố hậu quả và khả năng xảy ra; e) Đánh giá rủi ro ATTT: ✓ So sánh các kết quả phân tích rủi ro với tiêu chí chấp nhận rủi ro đã thiết lập; ✓ Thiết lập thứ tự ưu tiên cho các rủi ro đã phân tích đối với việc xử lý rủi ro, tức là xác định tính khẩn cấp để xử lý đối với các rủi ro đã được xem là không thể chấp nhận, và thứ tự nếu một số rủi ro nào đó cần được xử lý. • Theo đó, áp dụng quá trình đánh giá rủi ro vào thực tế. • Tổ chức phải lưu giữ thông tin dạng văn bản về quá trình đánh giá rủi ro ATTT cũng như kết quả của việc thực hiện nó theo yêu cầu ở 6.1.2.a) đến e). <i>Hướng dẫn:</i> • Hướng dẫn thiết lập tiêu chí chấp nhận rủi ro (điều 6.1.2.a):
--	--

	✓ Để thiết lập tiêu chí chấp nhận rủi ro, tổ chức phải dựa trên việc xem xét bối cảnh ATTT của mình, xem xét các yêu cầu liên quan ATTT của các bên quan tâm. Các tiêu chí này, một mặt phải phù hợp với những ưu tiên đối với rủi ro và sự nhận thức về rủi ro của lãnh đạo cao nhất, mặt khác phải giúp đề ra được quá trình quản lý rủi ro khả thi và thích hợp. ✓ Các tiêu chí chấp nhận rủi ro phải được thiết lập có sự liên kết đến các kết quả đầu ra dự kiến của ISMS. ✓ Sau khi thiết lập tiêu chí đánh giá hậu quả và khả năng xảy ra của các rủi ro ATTT, tổ chức cũng phải lập phương pháp kết hợp chúng lại để qua đó xác định được mức độ rủi ro. Hậu quả và khả năng xảy ra có thể được thể hiện theo cách định tính, định lượng hoặc bán định lượng. ✓ Tiêu chí chấp nhận rủi ro liên quan đến đánh giá rủi ro (ở bước đánh giá rủi ro/ risk evaluation), khi tổ chức xem xét liệu có chấp nhận một rủi ro nào đó hay không), và các hoạt động xử lý rủi ro (khi tổ chức xem xét liệu việc xử lý rủi ro được đề nghị là đã đủ để đạt được mức chấp nhận rủi ro hay chưa). ✓ Tiêu chí chấp nhận rủi ro có thể được dựa trên mức tối đa để chấp nhận rủi ro, theo kết quả xem xét về lợi ích - chi phí, hoặc theo những hậu quả đối với tổ chức. ✓ Lãnh đạo cao nhất phải phê duyệt các tiêu chí chấp nhận rủi ro. • Hướng dẫn cách thức để cho ra các kết quả đánh giá rủi ro có tính nhất quán, có giá trị sử dụng và có thể so sánh
--	---

được (6.1.2.b):

- ✓ Quá trình đánh giá rủi ro phải dựa trên các phương pháp và công cụ được thiết kế chi tiết tới mức nhất định để từ đó giúp cho ra kết quả nhất quán, có giá trị sử dụng và có thể so sánh được.
- ✓ Dù theo phương pháp nào, quá trình đánh giá rủi ro ATTT phải đảm bảo rằng:
 - ❖ Tất cả các rủi ro, đến mức độ chi tiết cần thiết, đều được xem xét;
 - ❖ Các kết quả là nhất quán và có thể tái lập (tức là, việc nhận diện rủi ro, việc phân tích và đánh giá rủi ro có thể được hiểu bởi một bên thứ ba và các kết quả là tương đương khi những người khác nhau tiến hành đánh giá rủi ro trong cùng bối cảnh); và
 - ❖ Các kết quả đánh giá rủi ro lặp lại là có thể so sánh được (tức là, có thể hiểu được nếu các mức độ rủi ro tăng lên hay giảm xuống).
- ✓ Sự không nhất quán hoặc tương phản nhau trong các kết quả khi toàn bộ hay phần của quá trình đánh giá rủi ro ATTT được lặp lại có thể cho thấy rằng phương pháp đánh giá rủi ro là không thỏa đáng.
- Hướng dẫn nhận biết rủi ro ATTT (6.1.2.c):
 - ✓ Nhận biết rủi ro là quá trình tìm ra, ghi nhận và mô tả về rủi ro. Việc này liên quan đến xác định nguồn gốc rủi ro, các sự kiện, nguyên nhân của chúng và những hậu quả tiềm tàng của chúng.
 - ✓ Mục đích của việc nhận diện rủi ro là nhằm xác định

	được một danh mục đầy đủ của các rủi ro dựa trên các sự kiện có thể tạo ra, làm tăng thêm, ngăn chặn, suy giảm, gia tốc hay làm chậm trễ việc đạt được các mục tiêu ATTT. ✓ Hai phương pháp tiếp cận hay được sử dụng để nhận diện rủi ro ATTT như sau: ❖ Phương pháp dựa trên sự kiện: xem xét các nguồn rủi ro theo cách chung. Các sự kiện được xem xét có thể đã xảy ra trong quá khứ hoặc có thể được tiên đoán xảy ra trong tương lai. Đối với trường hợp đầu thì chúng có thể liên quan đến các dữ liệu trong lịch sử, còn trường hợp sau thì dựa trên phân tích lý thuyết và ý kiến của chuyên gia; ❖ Phương pháp dựa trên việc nhận biết các tài sản (thông tin), các mối đe dọa và các điểm yếu: xem xét hai dạng khác nhau của nguồn rủi ro: các tài sản thông tin có các điểm yếu cố hữu của chúng và các mối đe dọa có thể khai thác được điểm yếu. Các sự kiện tiềm ẩn được xem xét ở đây là các cách thức mà những mối đe dọa có thể khai thác được một điểm yếu nhất định của một tài sản thông tin và từ đó tác động đến mục tiêu của tổ chức. ✓ Cả hai phương pháp tiếp cận trên đều nhất quán với các nguyên tắc và hướng dẫn chung về quản lý rủi ro theo ISO 31000. ✓ Các phương pháp nhận diện rủi ro khác cũng có thể được áp dụng nếu chúng được chứng minh tính hữu ích thực tế và nếu cũng đảm bảo được các yêu cầu ở
--	--

điều 6.1.2.b).

- Hướng dẫn phân tích rủi ro ATTT (6.1.2.d):

- ✓ Mục đích của phân tích rủi ro là để xác định được mức độ rủi ro. Tiêu chuẩn ISO/IEC 27001 yêu cầu, với mỗi rủi ro đã nhận diện, cần tiến hành phân tích rủi ro đó căn cứ trên việc đánh giá các hậu quả nảy sinh từ rủi ro và khả năng xảy ra để từ đó xác định mức độ rủi ro.
- ✓ Các kỹ thuật phân tích rủi ro dựa trên hậu quả và khả năng xảy ra có thể là:
 - ❖ Định tính, qua cách sử dụng thang đánh giá định tính (ví dụ: Cao, Vừa, Thấp);
 - ❖ Định lượng, bằng cách sử dụng thang các giá trị bằng số (ví dụ: chi phí tính bằng tiền, tần suất hay khả năng/ xác suất xảy ra); hoặc
 - ❖ Bán định lượng, bằng cách sử dụng thang định tính được gán các giá trị.
- ✓ Dù theo kỹ thuật phân tích rủi ro nào thì cũng phải xem xét về tính khách quan của nó. Ví dụ: khi chủ thể rủi ro tiến hành đánh giá định tính (cao/vừa/thấp) hay định lượng (3/2/1) thì phải có cơ sở lý giải cho việc gán các mức độ đó cho hậu quả hay khả năng xảy ra của một rủi ro nhất định.
- ✓ Có một số phương pháp phân tích rủi ro. Hai phương pháp đã được đề cập ở trên (phương pháp dựa trên sự kiện và phương pháp dựa trên nhận biết tài sản, các mối đe dọa và các điểm yếu) có thể thích hợp đối với việc phân tích rủi ro ATTT. Quá trình nhận diện và

	phân tích rủi ro có thể hiệu quả nhất khi được thực hiện với sự trợ giúp của chuyên gia đối với rủi ro đang xét. • Hướng dẫn đánh giá (evaluation) rủi ro ATTT (6.1.2.e): ✓ Việc đánh giá các rủi ro đã phân tích liên quan đến việc sử dụng các quá trình ra quyết định của tổ chức để so sánh mức độ rủi ro của từng rủi ro với tiêu chí chấp nhận đã định trước để xác định các giải pháp xử lý rủi ro. ✓ Đây là bước cuối cùng của hoạt động đánh giá rủi ro để kiểm tra xác nhận xem các rủi ro đã qua bước phân tích có thể được chấp nhận chiếu theo tiêu chí chấp nhận đã xác định ở mục 6.1.2.a) không, hay cần có việc xử lý tiếp theo. Công việc ở mục 6.1.2.d) cung cấp thông tin về độ lớn của rủi ro nhưng không phải là thông tin về tính khẩn cấp của việc thực hiện các giải pháp xử lý rủi ro. Tùy theo bối cảnh ở đó rủi ro xảy ra mà chúng có thể có những mức độ ưu tiên để xử lý khác nhau. Từ đó, đầu ra của bước này là một Danh mục các rủi ro lập theo thứ tự ưu tiên. Tổ chức cần lưu giữ các thông tin tiếp theo về các rủi ro này từ bước nhận diện và phân tích rủi ro để hỗ trợ các quyết định đối với việc xử lý rủi ro.
6.1.3 Xử lý rủi ro ATTT	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Tổ chức phải xác định và áp dụng quá trình xử lý rủi ro ATTT.
	<i>Giải thích:</i> • Xử lý rủi ro ATTT là quá trình tổng thể của việc lựa chọn

	các giải pháp xử lý rủi ro, xác định các biện pháp kiểm soát thích hợp, vạch ra kế hoạch xử lý rủi ro và đạt được sự thống nhất của các chủ thể rủi ro về kế hoạch xử lý rủi ro. • Tổ chức phải lưu hồ sơ về kết quả thực hiện các bước trong quá trình xử lý rủi ro ATTT từ 6.1.3.a) đến 6.1.3.f), cũng như kết quả của việc áp dụng chúng.
	<i>Hướng dẫn:</i> • Hướng dẫn về các giải pháp/ tùy chọn xử lý rủi ro ATTT (điều 6.1.3.a) ✓ Các giải pháp/ tùy chọn để xử lý rủi ro gồm: ❖ Tránh rủi ro, bằng cách quyết định không bắt đầu hoặc không tiếp tục thực hiện hoạt động phát sinh rủi ro hoặc bằng cách loại bỏ nguồn gốc rủi ro (ví dụ như đóng cổng giao tiếp thương mại điện tử / closing an e-commerce portal); ❖ Nhận lấy rủi ro hoặc tăng rủi ro lên để theo đuổi một cơ hội kinh doanh nào đó (ví dụ như mở một cổng thương mại điện tử/ opening an e-commerce portal); ❖ Thay đổi rủi ro bằng cách thay đổi khả năng xảy ra (ví dụ như làm giảm các điểm yếu) hoặc thay đổi hậu quả (ví dụ như đa dạng hóa các tài sản thông tin) hoặc thay đổi cả hai khía cạnh này; ❖ Chia sẻ rủi ro với các bên khác như bảo hiểm, thuê thầu phụ hoặc tài trợ rủi ro; và ❖ Giữ lại rủi ro dựa trên tiêu chí chấp nhận rủi ro hoặc có quyết định được thông báo (ví dụ như

	tiếp tục duy trì công thương mại điện tử hiện có). ✓ Mỗi rủi ro riêng rẽ phải được xử lý tương ứng với các mục tiêu ATTT, bởi một hoặc nhiều hơn các giải pháp này nhằm đáp ứng được tiêu chí chấp nhận rủi ro. • Hướng dẫn xác định các biện pháp kiểm soát (điều 6.1.3.b): ✓ Tổ chức cần hết sức chú ý khi xác định các biện pháp kiểm soát ATTT. Việc này phải dựa trên kết quả đánh giá rủi ro ATTT đã thực hiện ở bước trước. Nếu tổ chức thực hiện bước đánh giá rủi ro không tốt thì sẽ không có cơ sở để lựa chọn các biện pháp kiểm soát ATTT. ✓ Việc xác định biện pháp kiểm soát thích hợp sẽ đảm bảo được: ❖ Tất cả các biện pháp kiểm soát cần thiết sẽ được đưa vào áp dụng, cũng như sẽ không lựa chọn các biện pháp không cần thiết; ❖ Việc thiết kế ra biện pháp kiểm soát cần thiết sẽ thỏa mãn cả chiều rộng và chiều sâu của việc quản lý rủi ro ATTT. ✓ Nếu lựa chọn biện pháp kiểm soát không hợp lý, có thể dẫn tới hiệu quả quản lý rủi ro thấp và tốn kém chi phí, nguồn lực không cần thiết. ✓ Tổ chức có thể áp dụng nhiều biện pháp kiểm soát để đạt được việc xử lý rủi ro như yêu cầu, ví dụ như nếu giải pháp được chọn là "Thay đổi hậu quả của một sự kiện ATTT cụ thể" nào đó, thì các biện pháp kiểm
--	---

	soát có thể bao gồm việc phát hiện ngay tức thời sự kiện ATTT, cũng như biện pháp để ứng phó với sự kiện và biện pháp để khôi phục sau sự kiện đó. ✓ Khi xác định biện pháp kiểm soát, tổ chức cũng cần chú ý đến các biện pháp kiểm soát cần thiết đối với các dịch vụ từ nhà cung cấp bên ngoài như các ứng dụng, các quá trình và chức năng do bên ngoài cung cấp. Đơn cử như, các biện pháp kiểm soát này là bắt buộc bằng cách nhập vào các yêu cầu ATTT trong thỏa thuận với các nhà cung cấp này, kể cả các cách thức để có thông tin về mức độ đáp ứng các yêu cầu này (ví dụ như quyền để đánh giá). • Hướng dẫn để so sánh các biện pháp kiểm soát với biện pháp kiểm soát nêu trong Phụ lục A của ISO/IEC 27001:2013 (điều 6.1.3.c): ✓ Phụ lục A của tiêu chuẩn ISO/IEC 27001:2013 là một danh mục toàn diện của các mục tiêu kiểm soát và biện pháp kiểm soát. Khi sử dụng Phụ lục này, người sử dụng được định hướng nhằm đảm bảo rằng sẽ không bỏ sót những biện pháp kiểm soát cần thiết. Tuy nhiên, tiêu chuẩn cũng khuyến cáo về việc, danh mục ở Phụ lục A cũng không phải là tuyệt đối toàn diện, theo đó các mục tiêu kiểm soát và biện pháp kiểm soát khác có thể được áp dụng bổ sung vào Phụ lục A nếu cần. Đồng thời, cũng không có nghĩa là mọi biện pháp kiểm soát trong Phụ lục A đều phải áp dụng bởi một tổ chức nhất định nào đó. Khi một biện pháp kiểm soát trong Phụ lục A không thể thực hiện hoặc không góp phần giải quyết rủi ro ATTT thì tổ
--	--

	chức sẽ loại bỏ việc áp dụng nó và có lý giải cho việc loại bỏ đó. • Hướng dẫn lập bản "Thông báo việc áp dụng" - SoA (điều 6.1.3d): ✓ SoA có các nội dung sau: ❖ Tất cả các biện pháp kiểm soát cần thiết (đã xác định theo điều 6.1.3.b) và 6.1.3.c)), và với từng biện pháp kiểm soát: ○ Lý giải cho việc áp dụng; và ○ Kể cả khi biện pháp đó có được thực hiện hay không (ví dụ: đã thực hiện đầy đủ; đang thực hiện; chưa thực hiện); và ❖ Lý giải về việc loại trừ/ không áp dụng đối với biện pháp kiểm soát nào được nêu trong Phụ lục A, ISO/IEC 27001:2013. ✓ Việc lý giải cho việc áp dụng một biện pháp kiểm soát có thể dựa trên hiệu quả của biện pháp đó để điều chỉnh một rủi ro ATTT. Việc tham chiếu đến hồ sơ kết quả đánh giá rủi ro và kế hoạch xử lý rủi ro ATTT trong bản SoA cũng được xem là thích hợp cho việc lý giải. ✓ Đối với việc loại trừ/ không áp dụng một biện pháp kiểm soát ở Phụ lục A thì có thể bao gồm: ❖ Biện pháp kiểm soát được xác định là không cần thiết để thực hiện các giải pháp xử lý rủi ro ATTT đã lựa chọn; ❖ Biện pháp kiểm soát là không thể áp dụng vì nó nằm ngoài phạm vi áp dụng ISMS của tổ chức
--	--

	(ví dụ, mục A.14.2.7 của Phụ lục A - "Việc phát triển được thuê ngoài" là không thể áp dụng được nếu tổ chức tự phát triển các hệ thống của tổ chức mình chứ không thuê ngoài); và ❖ Biện pháp kiểm soát bị cản trở bởi một biện pháp kiểm soát tùy chỉnh (ví dụ, mục A.8.3.1 về "Quản lý các phương tiện lưu trữ di động/management of removable media" có thể loại trừ nếu tổ chức đã có biện pháp kiểm soát tùy chỉnh là "cấm sử dụng các phương tiện lưu trữ di động"). • Hướng dẫn lập Kế hoạch xử lý rủi ro/ RTP (điều 6.1.3.e): ✓ Tiêu chuẩn ISO/IEC 27001:2013 không quy định cụ thể cấu trúc hay nội dung của một bản RTP. Tuy nhiên, kế hoạch phải được lập trên cơ sở các đầu ra của việc thực hiện các điều khoản từ 6.1.3.a) đến 6.1.3.c). Theo đó, RTP phải lập thành tài liệu cho mỗi rủi ro được xử lý: ❖ Các giải pháp/ tùy chọn xử lý được lựa chọn; ❖ Các biện pháp kiểm soát cần thiết; và ❖ Tình trạng thực hiện. ✓ Các nội dung hữu ích khác có thể đưa vào RTP: ❖ Chủ thể rủi ro; và ❖ Rủi ro còn lại mong đợi sau khi thực hiện các hành động. ✓ Với mỗi hành động đã được yêu cầu trong RTP thì đều phải làm rõ trách nhiệm thực hiện và thời hạn thực hiện cụ thể.
--	---

Theo đó, tài liệu RTP có thể được trình bày theo dạng bảng, trong đó có cột liệt kê các rủi ro đã nhận biết; cột xác định các biện pháp kiểm soát, cột xác định trách nhiệm (bộ phận/ họ & tên người thực hiện thực hiện biện pháp), cột xác định thời gian thực hiện/ hoàn thành và cột để theo dõi tình trạng thực hiện theo mục tiêu đề ra.

Sau đây là một ví dụ minh họa cho RTP đối với quá trình xử lý rủi ro "Mất trộm điện thoại di động".

(a) Hậu quả của rủi ro đó là làm mất đi tính sẵn có (A) và tiềm ẩn việc tiết lộ thông tin không mong muốn (tức mất đi tính bảo mật/ C). Nếu việc đánh giá rủi ro cho thấy mức độ rủi ro là "không thể chấp nhận" được, thì tổ chức có thể quyết định hành động xử lý rủi ro là "thay đổi khả năng xảy ra", hoặc "thay đổi hậu quả của rủi ro".

(b) Để thay đổi "Khả năng xảy ra" của việc "mất hoặc bị trộm điện thoại di động", tổ chức có thể xác định một biện pháp kiểm soát thích hợp là "bắt buộc nhân viên thông qua việc tuân thủ Chính sách về thiết bị di động để cảnh trọng khi sử dụng điện thoại di động và thường xuyên kiểm tra tránh mất mát.

(c) Để thay đổi "Hậu quả" của việc mất hoặc bị trộm điện thoại di động, tổ chức có thể xác định biện pháp kiểm soát như:

- thiết lập quá trình quản lý sự cố, theo đó người sử dụng điện thoại di động có thể báo cáo về việc mất điện thoại;

	- áp dụng giải pháp quản lý thiết bị di động (Mobile Device Management - MDM) để theo dõi xóa (delete) nội dung/ thông tin trong điện thoại nếu bị mất; - thiết lập và thực hiện kế hoạch sao lưu (back-up) cho điện thoại di động để khôi phục dữ liệu. (d) Khi xây dựng SoA (điều 6.1.3.d), tổ chức có thể đưa các biện pháp kiểm soát đã chọn vào (tức là Chính sách kiểm soát thiết bị di động và MDM), lý giải cho việc đưa vào dựa trên tác động của chúng đối với khả năng xảy ra và hậu quả của việc điện thoại di động bị mất hoặc bị trộm, từ đó giúp giảm các rủi ro còn sót lại. (e) Khi đối chiếu các biện pháp kiểm soát này với biện pháp liệt kê trong Phụ lục A, có thể thấy rằng Chính sách đối với thiết bị di động là nhất quán với mục A.6.2.1 trong Phụ lục A, còn biện pháp kiểm soát MDM thì lại không trực tiếp liên quan, mà nó phải được xem như biện pháp kiểm soát bổ sung. Nếu MDM và các biện pháp kiểm soát khác được xác định như những biện pháp kiểm soát cần thiết trong RTP của tổ chức, chúng phải được đưa vào trong SoA. (f) Nếu tổ chức muốn giảm thêm rủi ro này thì có thể cân nhắc mục A.9.1.1 của Phụ lục A (Chính sách kiểm soát truy cập), ở đó tổ chức đã thiếu biện pháp kiểm soát việc truy cập đến điện thoại di động và tổ chức sẽ điều chỉnh lại Chính sách
--	---

	<i>kiểm soát thiết bị di động của mình để quy định việc sử dụng mã PIN trên tất cả các điện thoại di động. Việc này theo đó sẽ kiểm soát tiếp theo để thay đổi hậu quả của việc mất hoặc bị trộm điện thoại di động.</i> <i>(g) Khi lập RTP, tổ chức phải đưa các hành động để thực hiện Chính sách kiểm soát thiết bị di động và MDM vào và ấn định rõ trách nhiệm và khung thời gian thực hiện.</i> - Hướng dẫn để có sự chấp nhận của các chủ thể rủi ro (điều 6.1.3.f): ✓ Khi RTP được lập ra, tổ chức phải có được sự cho phép/ thông qua của các chủ thể rủi ro. Sự cho phép đó phải dựa trên tiêu chí chấp nhận rủi ro đã định hoặc những sự nhượng bộ đã được lý giải nếu có bất cứ sai lệch nào tiêu chí đó. ✓ Tổ chức phải lập hồ sơ về sự chấp nhận của chủ thể rủi ro về các rủi ro còn sót lại và việc phê duyệt RTP của lãnh đạo.
6.2. Mục tiêu ATTT và hoạch định để đạt được mục tiêu	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> Tổ chức phải thiết lập các Mục tiêu ATTT và lập kế hoạch để đạt được các mục tiêu đó ở các cấp độ chức năng của mình.
	<i>Giải thích:</i> Mục tiêu ATTT giúp thực hiện các mục tiêu chiến lược của tổ chức, cũng như để thực hiện Chính sách ATTT. Từ đó, các mục tiêu của ISMS là những Mục tiêu ATTT đối với các đặc tính về Tính bảo mật (C), Tính toàn vẹn (I) và

	Tính sẵn có (A) của các tài sản thông tin trong phạm vi của ISMS. Các Mục tiêu ATTT cũng giúp quy định cụ thể và đo lường kết quả thực hiện các biện pháp kiểm soát ATTT và các quá trình phù hợp với Chính sách ATTT (theo điều 5.2). • Tổ chức phải hoạch định, thiết lập và ban hành Mục tiêu ATTT tương ứng với các chức năng và cấp độ trong tổ chức. • Các yêu cầu trong ISO/IEC 27001 liên quan đến các Mục tiêu ATTT được áp dụng cho tất cả các Mục tiêu ATTT. Nếu Chính sách ATTT có đưa luôn nội dung các mục tiêu vào, thì chúng phải đáp ứng các tiêu chí trong điều 6.2. Nếu Chính sách chỉ đề ra khuôn khổ để lập ra các mục tiêu, thì các mục tiêu được lập ra theo khuôn khổ đó phải đáp ứng các yêu cầu của điều 6.2. • Khi lập Mục tiêu ATTT, phải chú ý đến kết quả của việc xác định bối cảnh ở điều 4.1 và kết quả xác định nhu cầu, mong đợi của các bên quan tâm ở điều 4.2. • Các kết quả của việc đánh giá rủi ro và xử lý rủi ro cũng sẽ được sử dụng làm đầu vào cho việc xem xét thường xuyên các mục tiêu để đảm bảo rằng chúng là thích hợp với bối cảnh hoạt động của tổ chức. • Các Mục tiêu ATTT là đầu vào cho đánh giá rủi ro: các tiêu chí chấp nhận rủi ro và các tiêu chí để thực hiện đánh giá rủi ro ATTT ở điều 6.1.2 sẽ có xem xét đến các Mục tiêu ATTT này và theo đó đảm bảo được các mức độ rủi ro sẽ nhất quán với chúng. • Theo ISO/IEC 27001, các Mục tiêu ATTT phải:
--	---

	✓ Nhất quán với Chính sách ATTT; ✓ Đo lường được khi có thể, nghĩa là có thể xác định được liệu có đạt hay không đạt được một mục tiêu; ✓ Kết nối với các yêu cầu về ATTT thích hợp và các kết quả từ đánh giá rủi ro và xử lý rủi ro; ✓ Được truyền đạt; và ✓ Được cập nhật khi thích hợp. • Tổ chức phải lưu giữ Mục tiêu ATTT dưới dạng thông tin bằng văn bản. • Khi hoạch định cách thức để đạt được Mục tiêu ATTT, tổ chức phải xác định cho được: ✓ Phải thực hiện điều gì/ biện pháp nào; ✓ Cần có các nguồn lực nào; ✓ Ai chịu trách nhiệm; ✓ Khi nào thì hoàn thành; và ✓ Cách thức đánh giá kết quả thực hiện.
	<i>Hướng dẫn:</i> • Chính sách ATTT phải nêu các Mục tiêu ATTT hoặc tạo khuôn khổ để thiết lập ra các mục tiêu. Các Mục tiêu ATTT có thể được thể hiện theo các cách khác nhau, nhưng dù cách nào thì cũng phải đáp ứng được yêu cầu về tính đo lường được (khi có thể) như nêu ở điều 6.2.b. • Ví dụ, các Mục tiêu ATTT có thể được thể hiện theo: ✓ Các trị số với giới hạn của chúng, ví dụ như "Không quá một giới hạn nhất định về...", và "Đạt cấp độ 4 về ..";

	✓ Các chỉ tiêu đo lường về kết quả hoạt động về ATTT; ✓ Các chỉ tiêu đo lường về tính hiệu lực của ISMS (theo điều 9.1); ✓ Sự tuân thủ với yêu cầu ISO/IEC 27001; ✓ Sự tuân thủ với các quy trình/ thủ tục/ chính sách kiểm soát ATTT trong ISMS của tổ chức; ✓ Nhu cầu hoàn thành các kế hoạch, hành động; ✓ Đạt được tiêu chí rủi ro. • Đối với việc hoạch định để đạt được các Mục tiêu ATTT, có thể sử dụng bất kỳ phương pháp hay cơ chế nào miễn là giúp triển khai và đạt được mục tiêu ATTT của tổ chức, trong đó kết quả đầu ra của hoạch định phải làm rõ: ✓ Các hoạt động sẽ thực hiện; ✓ Các nguồn lực cần thiết để thực hiện các hoạt động; ✓ Trách nhiệm; ✓ Khung thời gian và mốc hoàn thành các hoạt động; ✓ Phương pháp và phép đo để đánh giá xem các kết quả có đạt được các mục tiêu không, và bao gồm cả thời gian để thực hiện các đánh giá đó. • Đối với yêu cầu lưu giữ thông tin dạng văn bản Mục tiêu ATTT, có thể là: ✓ Các kế hoạch, các hành động, các nguồn lực, trách nhiệm, thời hạn và phương pháp đánh giá; và ✓ Các yêu cầu, các nhiệm vụ, nguồn lực, trách nhiệm, tần suất và phương pháp đánh giá.
--	--

Điều 7 - Hỗ trợ

7.1 Nguồn lực	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Tổ chức phải xác định và cung cấp các nguồn lực để thiết lập, thực hiện, duy trì và cải tiến thường xuyên ISMS.
	<i>Giải thích:</i> • Các nguồn lực là nền tảng để thực hiện bất kỳ hoạt động nào. Các loại nguồn lực có thể gồm: ✓ Nhân sự để định hướng và thực hiện các hoạt động; ✓ Thời gian để tiến hành các hoạt động và thời gian để giải quyết các kết quả trước khi chuyển qua một bước khác; ✓ Tài chính để thực hiện hoạt động; ✓ Thông tin để hỗ trợ cho việc ra quyết định, đo lường kết quả thực hiện và để cải thiện tri thức; và ✓ Cơ sở hạ tầng và các phương tiện khác cần có, như công nghệ, các công cụ, vật liệu, bất kể chúng là sản phẩm của công nghệ thông tin hay không. • Các nguồn lực phải nhất quán với nhu cầu của ISMS và từ đó đáp ứng được khi cần.
	<i>Hướng dẫn:</i> • Tổ chức phải: ✓ xác định các nguồn lực nào là cần thiết cho các hoạt động trong ISMS xét về số lượng lẫn chất lượng (năng lực và khả năng); ✓ tìm kiếm/ thu nhận nguồn lực yêu cầu;

	✓ cung cấp nguồn lực; ✓ duy trì nguồn lực trong toàn bộ các quá trình của ISMS và các hoạt động cụ thể; ✓ xem xét các nguồn lực được cung cấp so với nhu cầu của ISMS và có hiệu chỉnh khi cần. • Hình thức và mức độ của các thông tin dạng văn bản cho hoạt động này và kết quả đầu ra là do tổ chức quyết định để đảm bảo tính hiệu lực của ISMS (điều 7.5.1.b - ISO/IEC 27001:2013).
7.2 Năng lực	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Tổ chức phải xác định năng lực của các nhân sự cần thiết cho kết quả thực hiện ATTT và đảm bảo những người đó có năng lực.
	<i>Giải thích:</i> • Năng lực là khả năng áp dụng kiến thức và kỹ năng để đạt được kết quả dự kiến. Năng lực chịu ảnh hưởng của tri thức, kinh nghiệm và trí khôn. • Năng lực có thể là cụ thể (ví dụ như về công nghệ hay các lĩnh vực quản lý cụ thể như quản lý rủi ro) hoặc chung chung (ví dụ như các kỹ năng mềm, đáng tin cậy, các chủ đề về công nghệ hay quản lý cơ bản). • Năng lực liên quan đến những người làm việc dưới sự kiểm soát của tổ chức, nghĩa là, năng lực phải được quản lý đối với những người bao gồm cả nhân viên của tổ chức và cả người khác khi cần (ví dụ: người của nhà thầu/ bên cung cấp dịch vụ có liên quan đến ATTT cho tổ chức). • Tổ chức có thể thu nhận được năng lực và kỹ năng cao hơn

	hay mới hơn qua cả nguồn bên ngoài và nội bộ thông qua kinh nghiệm, đào tạo (ví dụ mở khóa đào tạo, hội thảo...), qua học hỏi, thuê chuyên gia bên ngoài. • Đối với các năng lực chỉ có nhu cầu tạm thời cho một hoạt động cụ thể hoặc trong một thời gian ngắn, ví dụ như để bù lại sự thiếu hụt nhân sự nội bộ tạm thời, tổ chức có thể thuê mướn hay hợp đồng với bên ngoài, khi đó năng lực của người được thuê phải được mô tả và được kiểm tra xác nhận bởi tổ chức.
	<i>Hướng dẫn:</i> • Tổ chức phải: ✓ Xác định năng lực cần thiết cho mỗi vai trò trong ISMS và quyết định về việc văn bản hóa điều đó (ví dụ như đưa vào bản Mô tả công việc); ✓ Phân công các vai trò trong ISMS cho những người có năng lực được yêu cầu bằng cách: ❖ Xác định ai trong tổ chức có được các năng lực (dựa trên giáo dục, kinh nghiệm hoặc chứng chỉ); hoặc ❖ Hoạch định và thực hiện các hành động để những người đó có được năng lực như yêu cầu (ví dụ qua đào tạo, giảng dạy, phân công lại nhân sự hiện có); hoặc ❖ Nhận người mới có năng lực (ví dụ như thuê mướn, hợp đồng). ✓ Đánh giá tính hiệu lực của các hành động nêu trên. Ví dụ 1: xem xét lại liệu người đã qua đào tạo thì đã

	thu nhận được năng lực yêu cầu hay chưa; Ví dụ 2: phân tích năng lực của những người được thuê/ hợp đồng sau một thời gian họ đến làm việc cho tổ chức; Ví dụ 3: Kiểm tra xác nhận xem kế hoạch thu nhận nhân sự mới đã được hoàn tất như mong đợi không. ✓ Kiểm tra xác nhận rằng nhân sự có năng lực đáp ứng yêu cầu ở vai trò, vị trí của họ trong ISMS; và ✓ Đảm bảo rằng năng lực sẽ phát theo thời gian khi cần để đáp ứng được mong đợi. • Tổ chức phải có bằng chứng dạng thông tin văn bản (hồ sơ) cho thấy năng lực được đáp ứng.
7.2 Nhận thức	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Những người làm việc dưới sự kiểm soát của tổ chức phải có nhận thức về Chính sách ATTT, về sự đóng góp của họ vào hiệu lực của ISMS, những lợi ích khi kết quả thực hiện ATTT được cải thiện cũng như hậu quả khi không phù hợp với các yêu cầu của ISMS.
	<i>Giải thích:</i> • Sự nhận thức của những người làm việc dưới sự kiểm soát của tổ chức có nghĩa là họ có sự hiểu biết cần thiết và sự tham gia vào việc thực hiện các yêu cầu về ATTT. • Nhận thức liên quan đến việc những người này sẽ biết, hiểu và chấp nhận để: ✓ Hỗ trợ thực hiện các mục tiêu được công bố trong Chính sách ATTT; và ✓ Tuân thủ các quy định để làm đúng nhiệm vụ hàng ngày

	của họ nhằm hỗ trợ đảm bảo ATTT. • Ngoài ra, những người làm việc dưới sự kiểm soát của tổ chức cũng cần phải biết, hiểu và chấp nhận hậu quả của việc không phù hợp với các yêu cầu của ISMS. Các hậu quả có thể là tiêu cực về ATTT hoặc những hậu quả đối với con người. • Những người này phải có nhận thức về Chính sách ATTT và biết được nơi để có thể tìm thấy văn bản đó. Nhiều nhân viên trong một tổ chức không cần phải biết các nội dung chi tiết của Chính sách. Thay vào đó, họ phải biết, hiểu, chấp nhận và thực hiện các Mục tiêu ATTT và các yêu cầu được rút ra từ Chính sách có ảnh hưởng đến vai trò, công việc của họ. Các yêu cầu này có thể được đưa vào trong các văn bản (quy trình, quy định, chính sách kiểm soát) về ATTT để họ tuân thủ khi thực hiện công việc của mình. <i>Hướng dẫn:</i> • Tổ chức phải: ✓ Có chương trình với nội dung cụ thể để truyền đạt đến các đối tượng cụ thể (nội bộ, bên ngoài) về Chính sách ATTT và các yêu cầu của ISMS; ✓ Đưa các nhu cầu, mong đợi về ATTT vào trong các tài liệu đào tạo và nhận thức để gắn các nhu cầu này vào trong các hoạt động nghiệp vụ tương ứng; ✓ Kiểm tra xác nhận việc đã thu được kiến thức và hiểu biết sau những lần truyền đạt nâng cao nhận thức; hoặc ngẫu nhiên giữa những lần truyền đạt; ✓ Kiểm tra xác nhận lại xem những người được truyền đạt có hành động theo đúng những gì được truyền đạt hay
--	--

	không và có thể sử dụng những điển hình mẫu/ gương "tốt" và những hành vi "xấu" để tăng cường hiệu quả truyền đạt nâng cao nhận thức. Hình thức và mức độ của các thông tin dạng văn bản cho hoạt động này và kết quả đầu ra là do tổ chức quyết định để đảm bảo tính hiệu lực của ISMS (điều 7.5.1.b - ISO/IEC 27001:2013).
	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> - Tổ chức phải xác định các nhu cầu đối với việc trao đổi thông tin nội bộ và bên ngoài liên quan đến ISMS. <i>Giải thích:</i> - Trao đổi thông tin là một quá trình chủ chốt trong ISMS. Việc trao đổi thông tin thỏa đáng là cần thiết với các bên quan tâm trong nội bộ và bên ngoài. - Trao đổi thông tin có thể là giữa các bên trong nội bộ ở các cấp độ trong tổ chức hoặc giữa tổ chức với các bên quan tâm ở bên ngoài. Việc trao đổi thông tin có thể được kích hoạt trong tổ chức hoặc bởi bên quan tâm từ bên ngoài. - Tổ chức phải xác định: ✓ Nội dung trao đổi thông tin là gì, ví dụ: về Chính sách ATTT, Mục tiêu, các thủ tục về ATTT, sự thay đổi của các văn bản này, kiến thức về các rủi ro ATTT, các yêu cầu đối với các nhà cung cấp và phản hồi về kết quả thực hiện về ATTT; ✓ Các thời điểm tốt/ tối ưu về thời gian cho các hoạt động trao đổi thông tin; ✓ Những ai tham gia vào các hoạt động trao đổi thông tin,

	và với đối tượng nhắm đến cho việc trao đổi thông tin nào; ✓ Ai sẽ kích hoạt các hoạt động trao đổi thông tin, ví dụ nội dung cụ thể có thể yêu cầu việc trao đổi thông tin được kích hoạt bởi một người hoặc một tổ chức cụ thể; và ✓ Những quá trình nào đang định hướng hoặc đang kích hoạt các hoạt động trao đổi thông tin, và những quá trình nào được nhắm đến hoặc chịu ảnh hưởng bởi hoạt động trao đổi thông tin. • Việc trao đổi thông tin có thể xảy ra thường xuyên hoặc khi phát sinh nhu cầu, và nó có thể là chủ động hay thụ động. <i>Hướng dẫn:</i> • Việc trao đổi thông tin dựa trên các quá trình, các kênh trao đổi hay các thể thức trao đổi. Tổ chức có thể lựa chọn để đảm bảo nội dung được trao đổi sẽ được tiếp nhận một cách đầy đủ, được hiểu đúng và khi thích hợp, được thực thi thích hợp. • Tổ chức phải xác định nội dung trao đổi thông tin là gì, ví dụ: ✓ Kế hoạch và kết quả quản lý rủi ro đến các bên quan tâm khi cần và khi thích hợp, trao đổi về việc nhận diện, phân tích, đánh giá, xử lý các rủi ro; ✓ Các mục tiêu ATTT; ✓ Các Mục tiêu ATTT đã đạt được, kể cả những vấn đề có thể hỗ trợ định vị thị trường (ví dụ: chứng chỉ ISO/IEC 27001 được cấp; phản nản về sự phù hợp với luật bảo vệ dữ liệu cá nhân);
--	--

	✓ Các sự cố hoặc khủng hoảng, ở đó sự minh mạch thường là vấn đề quan trọng để bảo toàn và tăng sự tin cậy và lòng tin vào khả năng của tổ chức trong việc quản lý ATTT và giải quyết các tình huống không mong muốn; ✓ Các vai trò, trách nhiệm và quyền hạn; ✓ Thông tin được trao đổi giữa các chức năng và vai trò theo yêu cầu của các quá trình trong ISMS; ✓ Các thay đổi đối với ISMS; ✓ Các vấn đề khác được xác định bằng cách xem xét các biện pháp kiểm soát và các quá trình thuộc phạm vi của ISMS; ✓ Các vấn đề (ví dụ các thông báo sự cố hay khủng hoảng) có yêu cầu phải trao đổi thông tin với cơ quan quản lý hoặc với các bên quan tâm khác; và ✓ Các yêu cầu hoặc các trao đổi thông tin khác từ các bên quan tâm bên ngoài như khách hàng, khách hàng tiềm năng, người sử dụng dịch vụ hoặc các cơ quan thẩm quyền. • Tổ chức phải xác định yêu cầu trao đổi thông tin về các vấn đề có liên quan: ✓ Ai được phép để trao đổi thông tin nội bộ và với bên ngoài (ví dụ trong những trường hợp đặc biệt như rò rỉ dữ liệu), phân công các vai trò cụ thể cùng quyền hạn thích hợp. Ví dụ: các nhân viên trao đổi thông tin chính thức (người phát ngôn) có thể được xác định cùng với quyền hạn thích hợp. Họ có thể là một nhân viên làm nhiệm vụ quan hệ công chúng (PR) đối với
--	---

	các trao đổi thông tin với bên ngoài và một nhân viên an toàn đối với trao đổi thông tin nội bộ; ✓ Các yếu tố kích hoạt hoặc tần suất trao đổi thông tin (ví dụ, đối với trao đổi thông tin về một sự kiện, yếu tố kích hoạt là việc nhận diện một sự kiện về ATTT); ✓ Nội dung của các thông điệp cho các bên quan tâm chính (ví dụ: khách hàng, cơ quan quản lý, công chúng, các người dùng quan trọng) dựa trên các kịch bản tác động. Việc trao đổi thông tin sẽ hiệu quả hơn khi các thông điệp được chuẩn bị và được phê duyệt trước bởi cấp lãnh đạo thích hợp như là một phần trong kế hoạch trao đổi thông tin, kế hoạch ứng phó với sự cố hoặc kế hoạch liên tục kinh doanh; ✓ Các bên nhận thông tin dự định: trong một số trường hợp, phải lập ra danh sách bên nhận thông tin (ví dụ đối với việc trao đổi thông tin về các thay đổi dịch vụ hoặc khi xảy ra các khủng hoảng); ✓ Các phương tiện và kênh trao đổi thông tin: phải được xác định để đảm bảo rằng các thông điệp được trao đổi là chính thống và bởi người có thẩm quyền thích hợp. Các kênh trao đổi thông tin phải xác định mọi nhu cầu để bảo vệ tính bảo mật, tính toàn vẹn của thông tin được truyền đi; và ✓ Quá trình đã định và cách thức để đảm bảo các thông điệp được gửi và được nhận, được hiểu một cách chính xác. • Phải phân loại và thực hiện trao đổi thông tin phù hợp với yêu cầu của tổ chức.
--	--

	Hình thức và mức độ của các thông tin dạng văn bản cho hoạt động này và kết quả đầu ra là do tổ chức quyết định để đảm bảo tính hiệu lực của ISMS (điều 7.5.1.b - ISO/IEC 27001:2013).
	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> Hệ thống thông tin dạng văn bản thuộc ISMS của tổ chức bao gồm những loại thông tin văn bản theo yêu cầu của tiêu chuẩn và theo nhu cầu quản lý của tổ chức để đảm bảo tính hiệu lực của ISMS.
	<i>Giải thích:</i> - Việc lập thành thông tin dạng văn bản là để giúp xác định và truyền đạt các mục tiêu ATTT, chính sách, hướng dẫn, các biện pháp kiểm soát ATTT, các quy trình đến những người liên quan trong hệ thống ISMS. Bên cạnh đó, việc lập thành thông tin dạng văn bản cũng cần thiết cho hoạt động đánh giá ISMS và duy trì tính ổn định của hệ thống khi có sự thay đổi về nhân sự. Ngoài ra, thông tin dạng văn bản cũng cần thiết cho việc ghi lại các hành động, quyết định và kết quả thực hiện các quá trình trong ISMS và kết quả thực hiện các biện pháp kiểm soát ATTT. - Thông tin dạng văn bản có thể gồm: ✓ Thông tin về các Mục tiêu ATTT, các rủi ro, các yêu cầu và tiêu chuẩn; ✓ Thông tin về các quá trình và thủ tục phải được thực hiện; và ✓ Các hồ sơ về đầu vào (ví dụ các cuộc xem xét của lãnh đạo) và các kết quả của quá trình (kể cả các kế hoạch

	và các kết quả của các hoạt động điều hành). • Có nhiều hoạt động trong ISMS dẫn đến việc sử dụng/ tạo ra thông tin dạng văn bản, trong nhiều trường hợp, trở thành đầu vào cho hoạt động khác. • Tiêu chuẩn ISO/IEC 27001 yêu cầu bộ thông tin dạng văn bản bắt buộc và chứa các yêu cầu chung và các yêu cầu văn bản bổ sung nếu cần thiết để đảm bảo tính hiệu lực của ISMS. Số lượng văn bản phụ thuộc vào quy mô của tổ chức. Nói chung, các văn bản bắt buộc và văn bản bổ sung có chứa các thông tin đủ để cho phép thực hiện các yêu cầu về đánh giá kết quả thực hiện như quy định ở Điều 9 của tiêu chuẩn.
	<i>Hướng dẫn:</i> • Ngoài các văn bản bắt buộc phải có theo yêu cầu tiêu chuẩn, tổ chức phải xác định những văn bản bổ sung nào là cần thiết để đảm bảo tính hiệu lực của ISMS,. • Các ví dụ về các thông tin dạng văn bản được xem là cần thiết để đảm bảo tính hiệu lực của ISMS như sau: ✓ Các kết quả của việc xác định bối cảnh của tổ chức (xem điều 4); ✓ Các vai trò, trách nhiệm, quyền hạn trong tổ chức (xem điều 5); ✓ Các báo cáo của các bước khác nhau của việc quản lý rủi ro ATTT (xem điều 6); ✓ Kết quả xác định và cung cấp các nguồn lực (xem điều 7.1); ✓ Năng lực cần thiết (xem điều 7.2);

	✓ Việc hoạch định và các kết quả của các hoạt động nâng cao nhận thức (xem điều 7.3); ✓ Việc hoạch định và các kết quả của hoạt động trao đổi thông tin (xem điều 7.4); ✓ Các thông tin dạng văn bản có nguồn gốc từ bên ngoài cần thiết cho ISMS (xem điều 7.5.3); ✓ Quá trình kiểm soát thông tin dạng văn bản (xem điều 7.5.3); ✓ Các chính sách, quy định, chỉ dẫn để định hướng và thực hiện các hoạt động đảm bảo ATTT; ✓ Các quá trình và thủ tục được sử dụng để thực hiện, duy trì và cải tiến ISMS và tình trạng tổng thể về ATTT (xem điều 9); ✓ Các kế hoạch hành động; và ✓ Bằng chứng về các kết quả của các quá trình trong ISMS (ví dụ: quản lý sự cố, kiểm soát truy cập, tính liên tục về ATTT, việc bảo trì thiết bị, ...). • Thông tin dạng văn bản có thể có nguồn gốc từ nội bộ và từ bên ngoài.
7.5.3 Thông tin dạng văn bản	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Tổ chức phải đảm bảo việc nhận biết, mô tả thích hợp về việc định dạng và phương tiện, cũng như việc xem xét và phê duyệt khi tạo ra và cập nhật thông tin dạng văn bản.
	<i>Giải thích:</i> • Tổ chức phải xác định chi tiết cách cấu trúc thông tin dạng văn bản và xác định phương pháp văn bản hóa thích hợp. • Việc xem xét và phê duyệt bởi cấp lãnh đạo thích hợp sẽ

	đảm bảo sự chính xác, phù hợp của văn bản, và theo thể thức thích hợp và cụ thể cho những đối tượng thực hiện dự kiến. Việc thường xuyên xem xét cũng sẽ đảm bảo các thông tin dạng văn bản tiếp tục phù hợp và thỏa đáng.
	<i>Hướng dẫn:</i> • Tổ chức có thể lưu giữ thông tin dạng văn bản dưới bất kỳ hình thức nào, ví dụ theo cách văn bản truyền thống (dạng bản cứng và bản điện tử), trên trang thông tin điện tử (web), trong cơ sở dữ liệu, nhật ký máy tính (computer logs), các báo cáo được máy tính tạo ra, dạng âm thanh và video. Ngoài ra, thông tin dạng văn bản có thể bao gồm các quy định về các nội dung (ví dụ Chính sách ATTT) hoặc các hồ sơ thực hiện (ví dụ các báo cáo của một đợt đánh giá) hoặc kết hợp của cả hai. Các hướng dẫn sau đây áp dụng trực tiếp cho các tài liệu truyền thống và phải được diễn dịch một cách thích hợp khi áp dụng cho các hình thức khác của thông tin dạng văn bản. • Tổ chức phải tạo ra một thư mục thông tin dạng văn bản đã được cấu trúc, có liên kết các phần khác nhau của thông tin dạng văn bản, bằng cách: ✓ Xác định cấu trúc của hệ thống thông tin dạng văn bản; ✓ Xác định cấu trúc/ bố cục chuẩn của thông tin dạng văn bản; ✓ Tạo các dạng thức mẫu (template) cho các loại thông tin dạng văn bản khác nhau; ✓ Xác định trách nhiệm đối với việc biên soạn, phê duyệt, phát hành và quản lý thông tin dạng văn bản; ✓ Xác định và lập thành tài liệu đối với việc sửa đổi và

	phê duyệt lại nhằm đảm bảo tiếp tục phù hợp, thỏa đáng của văn bản. • Phải xác định cách tiếp cận của hệ thống văn bản, bao gồm các thuộc tính chung của mỗi tài liệu để giúp nhận biết rõ ràng và duy nhất. Các thuộc tính này thường bao gồm: loại văn bản (ví dụ như chính sách, quy định, chỉ dẫn, hướng dẫn, kế hoạch, biểu mẫu và quy trình), mục đích và phạm vi, tiêu đề, ngày ban hành, phân nhóm, số tham chiếu/ mã hiệu, phiên bản sửa đổi và lịch sử sửa đổi. Việc nhận diện người biên soạn và những người chịu trách nhiệm hiện tại đối với văn bản, việc áp dụng và phát triển văn bản, cũng như những người phê duyệt hoặc thẩm quyền phê duyệt cũng phải được đưa vào. • Yêu cầu về định dạng/ thể thức văn bản có thể bao gồm cả việc xác định ngôn ngữ thể hiện, định dạng file, phần mềm để xây dựng văn bản và các nội dung đồ họa, hình ảnh. Các yêu cầu về phương tiện lưu trữ dạng vật lý hay điện tử phải đảm bảo sẵn có. • Nội dung và thể thức lập văn bản phải thích hợp đối với đối tượng sử dụng và phạm vi của hệ thống văn bản ISMS. • Tránh in, sao văn bản và cần áp dụng cách tham chiếu qua lại giữa các văn bản thay vì nêu lặp lại cùng nội dung ở các văn bản khác nhau. • Phương pháp quản lý văn bản cũng phải đảm bảo việc xem xét kịp thời các thông tin dạng văn bản và việc phê duyệt lại các thay đổi lên thông tin dạng văn bản. Các tiêu chí để xem xét thích hợp có thể là quy định về tần suất của việc xem xét hoặc về nội dung được xem xét. Chuẩn mực để phê duyệt cũng phải được xác định, nhằm đảm bảo thông
--	--

	tin dạng văn bản là chính xác, phù hợp cho việc sử dụng và ở dạng thích hợp cho người sử dụng.
	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Tổ chức phải quản lý các thông tin dạng văn bản của ISMS trong suốt vòng đời của văn bản và đảm bảo sẵn có ở nơi và thời điểm yêu cầu.
	<i>Giải thích:</i> • Sau khi được phê duyệt, hệ thống thông tin dạng văn bản phải được phổ biến, truyền đạt đến các đối tượng liên quan. Phải đảm bảo chúng sẵn có ở nơi cần là khi cần, đồng thời phải bảo vệ tính toàn vẹn, tính bảo mật và tính thực tế trong suốt vòng đời của văn bản. <i>Hướng dẫn:</i> • Tổ chức cần tạo ra thư mục được cấu trúc cho các thông tin dạng văn bản trong ISMS nhằm thuận lợi cho việc tiếp cận đến chúng.
7.5.2 Việc có thể thực hiện	• Phải có sự phân loại các thông tin dạng văn bản (xem mục A.8.2.1, ISO/IEC 27001:2013) sao cho phù hợp với hệ thống phân loại của tổ chức. Phải bảo vệ và sử dụng các thông tin dạng văn bản phù hợp với cấp độ theo đó chúng được phân loại (xem mục A.8.2.3, ISO/IEC 27001:2013). • Việc quản lý các thay đổi của hệ thống thông tin dạng văn bản phải đảm bảo rằng chỉ những người có thẩm quyền mới có quyền thay đổi và phân phối văn bản theo các hình thức thích hợp đã được xác định. Phải bảo vệ các thông tin dạng văn bản để đảm bảo giá trị sử dụng và tính xác thực

	của chúng. • Tổ chức phải phân phối và đảm bảo sự sẵn có của thông tin dạng văn bản cho các bên liên quan được phép. Theo đó, phải xác định rõ các bên liên quan thích hợp đối với từng loại thông tin dạng văn bản (hoặc từng nhóm thông tin dạng văn bản), xác định cách thức phân phối, tiếp cận, truy cập và sử dụng (ví dụ một trang web với cơ chế kiểm soát truy cập thích hợp). Việc phân phối phải phù hợp với các yêu cầu liên quan để bảo vệ và xử lý các thông tin được phân loại). • Tổ chức phải thiết lập thời gian lưu giữ thích hợp cho các thông tin dạng văn bản ứng với giá trị sử dụng dự kiến và các yêu cầu khác có liên quan. Theo đó, phải đảm bảo rằng thông tin dạng văn bản là rõ ràng cho việc sử dụng trong thời gian lưu giữ (ví dụ: sử dụng định dạng có thể đọc bằng các phần mềm có sẵn, hoặc kiểm tra xác nhận xem văn bản giấy có bị hư hỏng trong thời gian lưu hay không). • Tổ chức cũng phải quy định cách xử lý như thế nào mỗi khi hết hạn lưu giữ thông tin dạng văn bản. • Tổ chức phải quản lý các văn bản có nguồn gốc từ bên ngoài (ví dụ như từ khách hàng, đối tác, nhà cung cấp, văn bản pháp luật,...). • Hình thức và mức độ của các thông tin dạng văn bản cho hoạt động này và kết quả đầu ra là do tổ chức quyết định để đảm bảo tính hiệu lực của ISMS (điều 7.5.1.b - ISO/IEC 27001:2013).
--	--

Điều 8 - Thực hiện

8.1 Hoạch định và kiểm soát việc thực hiện

Các hoạt động theo yêu cầu tiêu chuẩn:

- Tổ chức phải lập kế hoạch, thực hiện và kiểm soát các quá trình nhằm đáp ứng các yêu cầu về ATTT và để đạt được các mục tiêu ATTT của tổ chức.
- Phải lưu giữ các thông tin dạng văn bản cần thiết để cung cấp lòng tin rằng các quá trình đã được thực hiện như đã hoạch định.
- Tổ chức phải kiểm soát các thay đổi đã được hoạch định và tiến hành xem xét hậu quả của các thay đổi ngoài dự kiến, cũng như đảm bảo việc nhận biết, xác định và kiểm soát các quá trình có nguồn từ bên ngoài.

Giải thích:

- Các quá trình được tổ chức áp dụng để đáp ứng các yêu cầu về ATTT của mình cần được hoạch định, và mỗi khi được thực hiện thì phải được kiểm soát, nhất là khi có các thay đổi.
- Căn cứ theo kết quả của giai đoạn hoạch định (điều 6.1, 6.2), tổ chức sẽ tiến hành hoạch định và thực hiện các hoạt động để triển khai các quá trình cần thiết nhằm thỏa mãn các yêu cầu về ATTT.
- Các quá trình để thỏa mãn các yêu cầu về ATTT bao gồm:
 - ✓ Các quá trình thuộc ISMS (ví dụ xem xét của lãnh đạo, đánh giá nội bộ);
 - ✓ Các quá trình theo yêu cầu để thực hiện kế hoạch xử lý rủi ro ATTT (RTP);

	• Tổ chức phải làm rõ trách nhiệm đối với việc hoạch định và kiểm soát bất kỳ quá trình có nguồn gốc từ bên ngoài nào để đạt được các mục tiêu ATTT của mình. Theo đó, phải: ✓ Xác định các quá trình có nguồn bên ngoài, có xét đến đến các rủi ro ATTT liên quan đến nguồn bên ngoài đó; và ✓ Đảm bảo kiểm soát được các quá trình có nguồn bên ngoài (tức là, phải được hoạch định, được giám sát và được xem xét) theo cách thức sao cho đảm bảo chúng được thực hiện như dự kiến (cũng có xét đến các mục tiêu ATTT và kế hoạch xử lý rủi ro ATTT). • Sau khi hoàn thành việc thực hiện, các quá trình bên ngoài đó phải được quản lý, giám sát và xem xét để đảm bảo rằng chúng tiếp tục đáp ứng các yêu cầu đã xác định (xem kết quả của điều 4.2). • Các thay đổi xảy ra trong quá trình thực hiện ISMS có thể là theo hoạch định của tổ chức hoặc ngoài dự kiến. Bất cứ khi nào tổ chức thực hiện sự thay đổi lên ISMS, kể cả theo kế hoạch hoặc ngoài dự kiến, tổ chức phải đánh giá các hậu quả tiềm tàng của sự thay đổi nhằm kiểm soát được các tác động bất lợi của chúng. • Tổ chức có thể có được lòng tin về hiệu lực thực hiện các kế hoạch bằng cách lập văn bản các hoạt động và sử dụng các thông tin dạng văn bản làm đầu vào cho việc đánh giá kết quả thực hiện theo quy định ở Điều 9. <i>Hướng dẫn:</i> • Các quá trình đã được xác định từ kết quả áp dụng Điều 6
--	--

	phải được thực hiện, áp dụng và kiểm tra xác nhận trong toàn tổ chức. Tổ chức phải xem xét và thực hiện những nội dung sau: ✓ Các quá trình cụ thể để quản lý ATTT (như quản lý rủi ro, quản lý sự cố, quản lý tính liên tục, đánh giá nội bộ, xem xét của lãnh đạo); ✓ Các quá trình nảy sinh từ các biện pháp kiểm soát ATTT theo Kế hoạch xử lý rủi ro ATTT (RTP); ✓ Cơ chế về việc báo cáo (nội dung, tần suất, định dạng, trách nhiệm, ...) về ATTT, ví dụ các báo cáo sự cố, các báo cáo về đo lường mức độ thực hiện các mục tiêu ATTT, các báo cáo về các hoạt động đã thực hiện; và ✓ Cơ chế cho các cuộc họp (tần suất, thành phần tham dự, mục đích, thẩm quyền) về ATTT. Các hoạt động ATTT phải được điều phối bởi địa diện các đơn vị phòng ban khác nhau trong tổ chức ứng với các vai trò và chức năng, nhiệm vụ để quản lý ATTT có hiệu quả. • Đối với các thay đổi theo hoạch định, tổ chức phải: ✓ Lập kế hoạch thực hiện, phân công nhiệm vụ, trách nhiệm, thời hạn hoàn thành và các nguồn lực; ✓ Thực hiện các thay đổi theo kế hoạch; ✓ Theo dõi việc thực hiện các thay đổi để khẳng định chúng được thực hiện như kế hoạch; và ✓ Thu thập và lưu giữ các thông tin dạng văn bản về việc thực hiện các thay đổi làm bằng chứng việc thực hiện chúng theo kế hoạch (ví dụ như các trách nhiệm, thời
--	--

	hạn hoàn thành và đánh giá hiệu lực thực hiện). • Đối với các thay đổi ngoài dự kiến, tổ chức phải: ✓ Xem xét hậu quả của chúng; ✓ Xác định liệu có bất kỳ tác động bất lợi nào đã xảy ra hoặc có thể xảy ra trong tương lai; ✓ Hoạch định và thực hiện các hành động để giảm nhẹ các tác động bất lợi khi cần; và ✓ Thu thập, lưu giữ các thông tin dạng văn bản về các thay đổi ngoài dự kiến đó và các hành động đã thực hiện để giảm nhẹ các tác động bất lợi. • Nếu có phần nào đó hoặc quá trình nào đó của tổ chức được giao cho nhà cung cấp bên ngoài, tổ chức phải: ✓ Xác định tất cả các mối quan hệ với bên ngoài; ✓ Thiết lập các giao diện thích hợp với các nhà cung cấp; ✓ Xác định các vấn đề liên quan ATTT trong các thỏa thuận với nhà cung cấp; ✓ Theo dõi và xem xét các dịch vụ của nhà cung cấp để đảm bảo chúng được thực hiện như dự kiến và các rủi ro về ATTT liên quan đáp ứng các tiêu chí chấp nhận rủi ro của tổ chức; và ✓ Quản lý các thay đổi đối với dịch vụ của nhà cung cấp khi cần thiết.
8.2 Đánh giá rủi ro ATTT	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Tổ chức phải thực hiện đánh giá rủi ro ATTT và lưu giữ các thông tin dạng văn bản về kết quả thực hiện.
	<i>Giải thích:</i>

	• Khi đánh giá rủi ro ATTT, tổ chức thực hiện các quá trình nêu ở Điều 6.1.2. Việc đánh giá này được tiến hành theo lịch trình được xác định trước, cũng như khi có các thay đổi quan trọng hoặc các sự cố ATTT. Các kết quả đánh giá rủi ro ATTT phải được lưu giữ dưới dạng thông tin bằng văn bản để có bằng chứng các quá trình ở Điều 6.1.2 được thực hiện như quy định. • Các thông tin dạng văn bản từ đánh giá rủi ro ATTT là thiết yếu cho việc xử lý rủi ro ATTT và có ý nghĩa quan trọng đối với việc đánh giá kết quả thực hiện (xem Điều 9). <i>Hướng dẫn:</i> • Tổ chức phải có kế hoạch cho việc đánh giá rủi ro ATTT. Khi có bất kỳ sự thay đổi quan trọng nào đối với ISMS (hoặc bối cảnh của tổ chức) hoặc các sự cố ATTT đã xảy ra, tổ chức phải xác định: ✓ Điều gì trong các thay đổi đó, hoặc các sự cố đòi hỏi phải có việc đánh giá bổ sung rủi ro ATTT; và ✓ Bằng cách nào việc đánh giá đó được kích hoạt để thực hiện. • Tổ chức phải nêu được mức độ chi tiết của việc từng bước nhận diện rủi ro ở các lần đánh giá tiếp theo trên quan điểm cải tiến liên tục ISMS. Việc đánh giá rủi ro ATTT thường phải được tiến hành hàng năm ít nhất một lần.
8.3 Xử lý rủi ro ATTT	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Tổ chức phải thực hiện Kế hoạch xử lý rủi ro ATTT (RTP) và lưu giữ các thông tin dạng văn bản về kết quả xử lý.

	<i>Giải thích:</i> • Để xử lý các rủi ro ATTT, tổ chức phải thực hiện quá trình xử lý rủi ro ATTT như yêu cầu ở Điều 6.1.3. Trong quá trình triển khai ISMS, bất cứ khi nào việc đánh giá rủi ro được cập nhật theo Điều 8.2, tổ chức phải áp dụng việc xử lý rủi ro theo 6.1.3 và cập nhật vào Kế hoạch xử lý rủi ro. Kế hoạch xử lý rủi ro được cập nhật theo đó lại được thực hiện. • Tổ chức phải lưu giữ các thông tin dạng văn bản về kết quả xử lý rủi ro ATTT làm bằng chứng thực hiện các quá trình nêu ở Điều 6.1.3.
	<i>Hướng dẫn:</i> • Quá trình xử lý rủi ro ATTT phải được thực hiện sau mỗi lần tiến hành đánh giá rủi ro ATTT theo Điều 8.2, hoặc khi việc thực hiện kế hoạch xử lý rủi ro hoặc một phần của kế hoạch đó không đạt được yêu cầu đề ra. • Tổ chức phải theo dõi tiến độ thực hiện kế hoạch xử lý rủi ro.

Điều 9 - Đánh giá kết quả thực hiện

9.1 Theo dõi, đo lường, phân tích và đánh giá

Các hoạt động theo yêu cầu tiêu chuẩn:

- Tổ chức phải đánh giá kết quả thực hiện về ATTT và hiệu lực của ISMS.

Giải thích:

- Mục đích của theo dõi và đo lường là để giúp tổ chức xem xét liệu có đạt được các kết quả mong đợi của các hoạt động về ATTT, kể cả đánh giá và xử lý rủi ro hay không.
- Việc theo dõi giúp xác định tình trạng của một hệ thống, một quá trình hay một hoạt động, trái lại, đo lường là một quá trình để xác định một giá trị. Theo đó, việc theo dõi có thể đạt được thông qua một loạt các phép đo lường trong một quãng thời gian.
- Để theo dõi và đo lường, tổ chức phải thiết lập:
 - ✓ Theo dõi, đo lường CÁI GÌ;
 - ✓ AI, KHI NÀO thực hiện theo dõi, đo lường; và
 - ✓ CÁC PHƯƠNG PHÁP được sử dụng để cho ra kết quả có giá trị (tức là, có thể so sánh được và có thể tái lập).
- Để phân tích và đánh giá, tổ chức phải thiết lập:
 - ✓ AI, KHI NÀO phân tích và đánh giá các kết quả thu được từ theo dõi, đo lường; và
 - ✓ CÁC PHƯƠNG PHÁP được sử dụng để cho ra các kết quả có giá trị.
- Có hai khía cạnh của việc đánh giá:

	✓ Đánh giá kết quả thực hiện về ATTT: để xác định xem tổ chức có đang thực hiện như mong đợi không, trong đó có việc xác định mức độ các quá trình trong ISMS đáp ứng tốt tới đâu những gì đã quy định; và ✓ Đánh giá tính hiệu lực của ISMS: để xác định xem tổ chức có đang thực hiện những gì cần làm không, trong đó có việc xác định mức độ đạt được các mục tiêu ATTT.
	<i>Hướng dẫn:</i> • Việc xác định nhu cầu thông tin là một thực hành tốt khi hoạch định cho việc theo dõi, đo lường, phân tích và đánh giá. Một nhu cầu thông tin thường được thể hiện về vấn đề hay tuyên bố nhằm giúp tổ chức đánh giá kết quả thực hiện về ATTT và hiệu lực của ISMS. Nói cách khác, việc theo dõi và đo lường phải được tiến hành để đạt được nhu cầu thông tin đã xác định. • Tổ chức cần cân trọng khi xác định các thuộc tính để đo lường. Sẽ là không thực tế, tốn kém chi phí và phản tác dụng khi đo lường quá nhiều, hoặc đo lường các thuộc tính không đúng. Bên cạnh vấn đề chi phí của đo lường, phân tích và đánh giá quá nhiều các thuộc tính, còn có khả năng là các vấn đề chủ yếu có thể bị che đậy hoặc bị trộn lẫn với nhau. • Có 02 dạng đo lường tổng quát: ✓ Đo lường kết quả thực hiện: thể hiện các kết quả đã hoạch định dưới dạng các đặc điểm của hoạt động đã hoạch định, ví dụ như đếm số người tham dự, các mốc hoàn thành công việc, hoặc mức độ thực hiện

	các biện pháp kiểm soát ATTT; và ✓ Đo lường hiệu lực: thể hiện kết quả thực hiện những hoạt động đã hoạch định có trong các mục tiêu ATTT của tổ chức. • Tổ chức có thể phân công các vai trò riêng biệt cho những người tham gia vào việc theo dõi, đo lường, phân tích và đánh giá. Các vai trò này có thể là khách hàng của phép đo, người hoạch định phép đo, người xem xét phép đo, chủ thể thông tin, người thu thập thông tin, người phân tích thông tin và người trao đổi thông tin của đầu vào và đầu ra của phép đo. • Các trách nhiệm đối với việc theo dõi và đo lường và đối với việc phân tích, đánh giá thường được phân công cho các nhân sự riêng rẽ có năng lực khác nhau được yêu cầu.
9.2 Đánh giá nội bộ	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Tổ chức phải thực hiện đánh giá nội bộ để cung cấp thông tin về sự phù hợp của ISMS theo các yêu cầu.
	<i>Giải thích:</i> • Đánh giá ISMS theo tần suất đã hoạch định qua hình thức đánh giá nội bộ sẽ cung cấp sự đảm bảo về tình trạng của ISMS cho lãnh đạo cao nhất. Có một số nguyên tắc của đánh giá, gồm tính nhất quán, báo cáo đúng, cân trọng nghề nghiệp, tính bảo mật, tính độc lập và cách tiếp cận dựa trên bằng chứng (tham khảo tiêu chuẩn ISO 19011:2018). • Các cuộc đánh giá nội bộ cung cấp thông tin về sự phù hợp của ISMS với các yêu cầu của tổ chức quy định trong ISMS, cũng như yêu cầu của ISO/IEC 27001. Các yêu

	cầu của chính tổ chức bao gồm: ✓ Các yêu cầu được công bố trong Chính sách và các thủ tục về ATTT; ✓ Các yêu cầu được lập ra theo khuôn khổ thiết lập các mục tiêu ATTT, kể cả các kết quả của quá trình xử lý rủi ro; ✓ Các yêu cầu của pháp luật và quy định hợp đồng; và ✓ Các yêu cầu về thông tin dạng văn bản. • Chuyên gia đánh giá cũng đánh giá xem ISMS có được thực hiện và duy trì có hiệu lực hay không. • Chương trình đánh giá phải mô tả khuôn khổ chung đối với một số cuộc đánh giá, được hoạch định trong một quãng thời gian cụ thể (ví dụ hàng năm) và hướng đến những mục đích cụ thể. Chương trình đánh giá khác với kế hoạch đánh giá, ở đó mô tả các hoạt động và sắp xếp cho một cuộc đánh giá cụ thể. Chuẩn mực đánh giá là tập hợp các chính sách, thủ tục hay các yêu cầu được sử dụng làm gốc để theo đó các bằng chứng đánh giá được so sánh, nghĩa là, các chuẩn mực đánh giá mô tả điều mà chuyên gia đánh giá mong đợi sẽ được đáp ứng. • Một cuộc đánh giá có thể nhận diện các điểm không phù hợp, các rủi ro và các cơ hội. Sự không phù hợp được quản lý theo các yêu cầu ở Điều 10.1. Các rủi ro và cơ hội được quản lý theo các yêu cầu ở Điều 4.1 và 6.1. • Tổ chức phải lưu giữ thông tin dạng văn bản về chương trình đánh giá và kết quả đánh giá. <i>Hướng dẫn:</i>
--	--

• Quản lý Chương trình đánh giá:

- ✓ Chương trình đánh giá xác định cơ cấu và trách nhiệm cho việc hoạch định, thực hiện, lập báo cáo và theo dõi các hoạt động đánh giá riêng rẽ. Theo đó, chương trình đánh giá phải đảm bảo rằng các cuộc đánh giá đã được tiến hành là thích hợp, có phạm vi thỏa đáng, giảm thiểu các tác động lên các hoạt động của tổ chức và duy trì chất lượng cần thiết của cuộc đánh giá. Chương trình đánh giá cũng phải đảm bảo năng lực của các nhóm đánh giá, duy trì các hồ sơ đánh giá thích hợp, và theo dõi, xem xét các hoạt động, rủi ro và hiệu lực của cuộc đánh giá. Ngoài ra, chương trình đánh giá cũng phải đảm bảo rằng ISMS (các quá trình, các chức năng và các biện pháp kiểm soát) sẽ được đánh giá trong khung thời gian quy định. Cuối cùng, chương trình đánh giá phải gồm các thông tin dạng văn bản về loại hình đánh giá, thời gian, các địa điểm và lịch trình của cuộc đánh giá.
- ✓ Mức độ và tần suất của các cuộc đánh giá nội bộ phải dựa trên quy mô và bản chất hoạt động của tổ chức, cũng như trên bản chất, chức năng, tính phức tạp và mức độ chín muồi của ISMS (cách tiếp cận đánh giá dựa trên rủi ro).
- ✓ Tổ chức phải xem xét hiệu lực của các biện pháp kiểm soát đã thực hiện trong phạm vi của đánh giá nội bộ. Chương trình đánh giá phải được thiết kế để đảm bảo sự bao quát tất cả các biện pháp kiểm soát cần thiết và bao gồm việc đánh giá tính hiệu lực của các biện pháp kiểm soát đã lựa chọn theo thời gian. Các biện

	pháp kiểm soát trọng yếu (theo chương trình đánh giá) phải được đưa vào trong từng cuộc đánh giá, trái lại, các biện pháp kiểm soát được thực hiện để quản lý các rủi ro ở cấp độ thấp hơn có thể được đánh giá với tần suất thưa hơn. ✓ Chương trình đánh giá cũng phải xem xét các quá trình và các biện pháp kiểm soát đã được thực hiện một thời gian nhất định để có thể đánh giá được bằng chứng thích hợp. ✓ Các cuộc đánh giá nội bộ về ISMS có thể được thực hiện hiệu quả theo cách kết hợp với các cuộc đánh giá khác của tổ chức (đánh giá tích hợp). Một chương trình đánh giá có thể bao gồm các đánh giá liên quan đến một hoặc nhiều hệ thống quản lý theo tiêu chuẩn, được thực hiện riêng rẽ hay kết hợp. ✓ Chương trình đánh giá phải bao gồm các thông tin dạng văn bản về: chuẩn mực đánh giá; phương pháp đánh giá; việc lựa chọn nhóm đánh giá; các quá trình xử lý tính bảo mật, an toàn thông tin, các đồ cung cấp về sức khỏe và an toàn cho chuyên gia đánh giá, và các vấn đề tương tự khác. • Năng lực và lựa chọn chuyên gia đánh giá: tổ chức phải ✓ Xác định các yêu cầu năng lực của chuyên gia đánh giá của tổ chức; ✓ Lựa chọn chuyên gia đánh giá nội bộ và bên ngoài theo năng lực phù hợp; ✓ Sẵn có quá trình để theo dõi kết quả thực hiện của chuyên gia đánh giá và nhóm đánh giá; và
--	--

	✓ Bao gồm nhân sự trong nhóm đánh giá nội bộ đến từ bộ phận thích hợp và có kiến thức về ATTT cụ thể. ✓ Phải lựa chọn chuyên gia đánh giá trên cơ sở xem xét về năng lực, tính độc lập và được đào tạo thích hợp. Việc này đôi lúc là khó khăn đối với tổ chức có quy mô nhỏ. Vì vậy, khi nguồn lực nội bộ là hạn chế, việc sử dụng chuyên gia đánh giá bên ngoài phải được áp dụng. Khi đó, tổ chức phải đảm bảo chuyên gia ngoài có kiến thức đầy đủ về bối cảnh của tổ chức, các thông tin này sẽ do các nhân sự của tổ chức cung cấp. ✓ Tổ chức phải cân nhắc về việc các nhân sự của tổ chức tham gia vào đánh giá nội bộ có thể có hiểu biết về bối cảnh của tổ chức, nhưng lại có thể không hiểu biết tốt về cách thực hiện đánh giá. Trong trường hợp đó, tổ chức có thể lập ra nhóm đánh giá bao gồm cả nhân sự đánh giá của mình và chuyên gia đánh giá từ bên ngoài. • Tiến hành đánh giá: ✓ Khi tiến hành cuộc đánh giá, trưởng nhóm đánh giá phải chuẩn bị kế hoạch đánh giá, có xem xét đến kết quả các cuộc đánh giá trước đó và nhu cầu của các hành động tiếp theo đối với các điểm không phù hợp và các rủi ro không thể chấp nhận đã được báo cáo trước đó. Kế hoạch đánh giá phải được lưu giữ dưới dạng thông tin văn bản và có bao gồm chuẩn mực, phạm vi và phương pháp đánh giá. ✓ Nhóm đánh giá phải xem xét: - Sự thỏa đáng và tính hiệu lực của các quá trình và
--	--

	các biện pháp kiểm soát đã định; - Việc hoàn thành các mục tiêu ATTT; - Việc tuân thủ các yêu cầu xác định ở điều khoản từ 4 ~ 10 của ISO/IEC 27001:2013; - Việc tuân thủ các yêu cầu về ATTT của chính tổ chức; - Tính nhất quán của bản Thông báo việc áp dụng (SoA) theo các kết quả của quá trình xử lý rủi ro ATTT; - Tính nhất quán của kế hoạch xử lý rủi ro ATTT thực tế với các rủi ro đã được đánh giá và các tiêu chí chấp nhận rủi ro; - Sự tương thích (tùy quy mô và sự phức tạp của tổ chức) của đầu vào xem xét của lãnh đạo với các đầu ra; và - Các tác động của các đầu ra xem xét của lãnh đạo (kể cả các nhu cầu cải tiến) lên tổ chức. ✓ Mức độ và độ tin cậy của việc theo dõi sẵn có đối với tính hiệu lực của các biện pháp kiểm soát được tạo ra bởi ISMS (xem Điều 9.1) có thể cho phép chuyên gia đánh giá giảm bớt khối lượng công việc đánh giá của chính họ, với điều kiện họ đã xác nhận về tính hiệu lực của các phương pháp đo lường. ✓ Nếu đầu ra của đánh giá bao gồm các điểm không phù hợp, bên được đánh giá phải lập kế hoạch hành động cho từng điểm không phù hợp và được chấp nhận bởi trưởng nhóm đánh giá. Các hoạt động tiếp theo sau đánh giá có thể gồm:
--	---

	- Mô tả sự không phù hợp đã phát hiện; - Mô tả nguyên nhân của sự không phù hợp; - Mô tả việc khắc phục tức thời và hành động khắc phục để loại bỏ sự không phù hợp đã phát hiện trong thời hạn xác định; và - Các nhân sự chịu trách nhiệm thực hiện kế hoạch. ✓ Các báo cáo đánh giá, kèm theo kết quả đánh giá phải được gửi đến cho lãnh đạo cao nhất. ✓ Tổ chức phải xem xét các kết quả của các cuộc đánh giá trước đó và điều chỉnh chương trình đánh giá để quản lý tốt hơn các khu vực có thể có các rủi ro cấp độ cao hơn nảy sinh từ các vấn đề không phù hợp.
9.3 Xem xét của lãnh đạo	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Lãnh đạo cao nhất phải định kỳ xem xét ISMS.
	<i>Giải thích:</i> • Mục đích của xem xét của lãnh đạo là nhằm đảm bảo ISMS tiếp tục phù hợp, thỏa đáng và có hiệu lực. Phù hợp hàm ý việc tiếp tục nhất quán với các mục tiêu của tổ chức. Thỏa đáng và hiệu lực hàm ý đến thiết kế phù hợp và gắn kết về mặt tổ chức của ISMS, cũng như hiệu lực thực hiện các quá trình và biện pháp kiểm soát được quy định trong ISMS. • Việc xem xét của lãnh đạo là quá trình được tiến hành ở các cấp độ khác nhau trong tổ chức. Các hoạt động này có thể khác nhau từ các cuộc họp hàng ngày, hàng tuần hoặc hàng tháng ở cấp đơn vị cho đến các thảo luận đơn giản của các báo cáo. Lãnh đạo cao nhất chịu trách nhiệm

	cuối cùng đối với hoạt động xem xét của lãnh đạo, với các đầu vào đến từ tất cả các cấp độ trong tổ chức.
	<i>Hướng dẫn:</i> • Lãnh đạo cao nhất phải yêu cầu và tiến hành xem xét thường xuyên kết quả thực hiện của ISMS. Có nhiều cách theo đó lãnh đạo cao nhất có thể xem xét về ISMS, như việc tiếp nhận và xem xét các phép đo lường và các báo cáo, các hình thức trao đổi thông tin bằng điện tử và các cập nhật thông tin bằng lời trực tiếp. • Các đầu vào chủ yếu để xem xét là các kết quả đo lường về ATTT như nêu ở Điều 9.1, các kết quả của các cuộc đánh giá nội bộ nêu ở Điều 9.2 và các kết quả đánh giá rủi ro và tình trạng thực hiện kế hoạch xử lý rủi ro. Khi xem xét các kết quả đánh giá rủi ro ATTT và tình trạng của kế hoạch xử lý rủi ro ATTT, lãnh đạo phải khẳng định về các rủi ro còn lại là đáp ứng các tiêu chí chấp nhận rủi ro, và về việc kế hoạch xử lý rủi ro đã xác định tất cả các rủi ro tương ứng và các giải pháp xử lý rủi ro. • Tất cả các khía cạnh của ISMS phải được xem xét bởi lãnh đạo theo tần suất hoạch định, ít nhất là hàng năm, bằng cách thiết lập lịch trình phù hợp cho cuộc họp xem xét của lãnh đạo. Các hệ thống ISMS mới thiết lập hoặc chưa đạt được sự chín muồi thì phải được lãnh đạo xem xét theo tần suất dày hơn để giúp tăng cường hiệu lực thực hiện. • Chương trình xem xét của lãnh đạo phải xác định các chủ đề sau: ✓ Tình trạng của các hành động từ các lần xem xét của

	lãnh đạo trước đó; ✓ Các thay đổi từ bên ngoài và nội bộ (xem điều 4.1) có liên quan đến ISMS; ✓ Phản hồi về kết quả thực hiện ATTT, kể cả các xu hướng, về: - Sự không phù hợp và các hành động khắc phục; - Các kết quả theo dõi và đo lường; - Các kết quả đánh giá; và - Việc thực hiện các mục tiêu ATTT. ✓ Phản hồi từ các bên quan tâm, kể cả các đề xuất cải tiến, các yêu cầu thay đổi và các khiếu nại; ✓ Các kết quả đánh giá rủi ro ATTT và tình trạng của việc thực hiện kế hoạch xử lý rủi ro ATTT; và ✓ Các cơ hội để cải tiến liên tục, kể cả các cải tiến hiệu quả của cả ISMS và các biện pháp kiểm soát ATTT. • Các đầu vào cho xem xét của lãnh đạo phải cụ thể đến mức cần thiết, căn cứ theo các mục tiêu đã thiết lập đối với các cấp lãnh đạo liên quan đến việc xem xét. Ví dụ, lãnh đạo cao nhất phải đánh giá tóm tắt tất cả các nội dung, dựa theo các mục tiêu ATTT hoặc các mục tiêu ở cấp độ cao hơn. • Các đầu ra từ việc xem xét của lãnh đạo phải bao gồm các quyết định liên quan đến các cơ hội cải tiến liên tục và bất kỳ nhu cầu thay đổi đối với ISMS. Các đầu ra cũng có thể bao gồm các bằng chứng về các quyết định liên quan đến: ✓ Các thay đổi về Chính sách và Mục tiêu ATTT, ví dụ
--	---

	các thay đổi nảy sinh từ các thay đổi của các vấn đề bên ngoài và nội bộ và yêu cầu của các bên quan tâm; ✓ Các thay đổi của các tiêu chí chấp nhận rủi ro và các tiêu chí để thực hiện đánh giá rủi ro ATTT (xem điều 6.1.2); ✓ Các hành động, nếu cần, tiếp theo việc đánh giá kết quả thực hiện ATTT; ✓ Các thay đổi về nguồn lực hay ngân sách cho ISMS; ✓ Kế hoạch xử lý rủi ro ATTT hoặc bản SoA được cập nhật; và ✓ Các cải tiến cần thiết đối với các hoạt động theo dõi và đo lường. • Tổ chức phải lưu giữ các thông tin dạng văn bản của xem xét của lãnh đạo, làm bằng chứng cho thấy đã có sự xem xét đối với tất cả các nội dung được yêu cầu ở ISO/IEC 27001:2013, ngay cả khi việc xem xét có thể không đòi hỏi phải có hành động cần thiết nào. • Khi có nhiều cuộc xem xét của lãnh đạo được thực hiện ở các cấp độ khác nhau trong tổ chức thì chúng phải được liên kết với nhau theo cách thích hợp.
--	--

Điều 10 - Cải tiến

10.1 Sự không phù hợp và hành động khắc phục

Các hoạt động theo yêu cầu tiêu chuẩn:

- Tổ chức phải đối ứng các vấn đề không phù hợp, đánh giá chúng, thực hiện việc khắc phục và hành động khắc phục khi cần thiết.

Giải thích:

- Sự không phù hợp là sự không đáp ứng một yêu cầu của ISMS. Yêu cầu là nhu cầu hoặc mong đợi được tuyên bố, ngầm hiểu hay bắt buộc. Có các dạng không phù hợp như sau:
 - ✓ Không đáp ứng một yêu cầu (toàn bộ hay một phần) của ISO/IEC 27001 trong ISMS;
 - ✓ Thực hiện không đúng hoặc không phù hợp với một yêu cầu, quy định hay biện pháp kiểm soát được nêu trong ISMS; và
 - ✓ Không tuân thủ một phần hay toàn bộ với yêu cầu của pháp luật, hợp đồng hay thỏa thuận với khách hàng.
- Một số ví dụ về sự không phù hợp:
 - ✓ Nhân sự không thực hiện các quy trình hay chính sách theo quy định;
 - ✓ Nhà cung cấp không cung cấp các sản phẩm, dịch vụ đã thỏa thuận/ hợp đồng;
 - ✓ Các dự án không chuyển giao kết quả như mong đợi; và
 - ✓ Không thực hiện các biện pháp kiểm soát như quy

	định. • Có thể nhận diện sự không phù hợp qua các cách sau: ✓ Thiếu các hoạt động được tiến hành trong phạm vi của ISMS; ✓ Các biện pháp kiểm soát không hiệu quả không được xử lý một cách thích hợp; ✓ Phân tích các sự cố ATTT, cho thấy việc không đáp ứng một yêu cầu của ISMS; ✓ Khiếu nại của khách hàng; ✓ Cảnh báo từ người dùng hoặc nhà cung cấp; ✓ Các kết quả theo dõi và đo lường không đáp ứng với các tiêu chí chấp nhận; và ✓ Không đạt được các mục tiêu. • Việc khắc phục nhằm giải quyết tức thời sự không phù hợp và hậu quả của nó (Điều 10.1.a., tiêu chuẩn ISO/IEC 27001:2013). • Hành động khắc phục nhằm loại bỏ nguyên nhân của sự không phù hợp và ngăn ngừa sự tái diễn (Điều 10.1.b. đến g., tiêu chuẩn ISO/IEC 27001:2013). <i>Hướng dẫn:</i> • Các sự cố ATTT không nhất thiết ám chỉ đã xảy ra sự không phù hợp, nhưng chúng có thể là một chỉ thị/ dấu hiệu của sự không phù hợp. Các cuộc đánh giá nội bộ, bên ngoài và các khiếu nại của khách hàng là những nguồn quan trọng có thể giúp nhận biết sự không phù hợp. • Việc đối ứng với sự không phù hợp phải căn cứ theo một
--	--

	quá trình xử lý đã được định sẵn. Quá trình đó phải bao gồm: ✓ Nhận biết mức độ và tác động của sự không phù hợp; ✓ Quyết định về việc khắc phục để giới hạn tác động của sự không phù hợp. Việc khắc phục có thể bao gồm việc chuyển sang trạng thái trước đó hoặc các trạng thái thích hợp khác. Tổ chức phải cân trọng để việc khắc phục không làm cho tình huống trở nên xấu hơn; ✓ Trao đổi thông tin với các nhân sự liên quan để đảm bảo rằng việc khắc phục được thực hiện; ✓ Thực hiện việc khắc phục đã quyết định; ✓ Theo dõi tình hình để đảm bảo sự khắc phục đã có hiệu quả như dự kiến và không gây ra các tác động phụ ngoài dự kiến; ✓ Tiếp tục hành động để khắc phục sự không phù hợp nếu nó vẫn chưa được giải quyết; và ✓ Trao đổi thông tin với các bên quan tâm liên quan, khi thích hợp. • Việc khắc phục chỉ giải quyết tức thời sự không phù hợp và hậu quả của nó, chứ chưa ngăn ngừa sự tái diễn, vì thế, tổ chức phải xem xét nhu cầu có hành động khắc phục sự không phù hợp, có thể cùng lúc hoặc sau khi hoàn thành việc khắc phục. Tổ chức phải thực hiện các bước sau đây: ✓ Quyết định xem, liệu có cần thực hiện một hành động khắc phục, theo đúng tiêu chí đã lập (ví dụ, tác động của sự không phù hợp, tính lặp lại của sự không phù hợp,..);
--	---

	✓ Xem xét sự không phù hợp, cần cân nhắc về: - Liệu sự không phù hợp tương tự đã được ghi nhận? - Tất cả hậu quả và tác dụng phụ gây ra bởi sự không phù hợp; và - Việc khắc phục đã thực hiện. ✓ Thực hiện phân tích kỹ lưỡng nguyên nhân gốc của sự không phù hợp, cần cân nhắc về: - Sai lỗi là gì, yếu tố kích hoạt hay tình huống cụ thể nào đã dẫn tới sự không phù hợp (ví dụ như sai lỗi do con người, phương pháp, quá trình hay thủ tục, phần cứng hay các phần mềm, đo lường sai, do môi trường,..); và - Mô hình và chuẩn mực có thể giúp nhận biết các tình huống tương tự trong tương lai. ✓ Thực hiện phân tích các hậu quả tiềm tàng ảnh hưởng đến ISMS, cần cân nhắc về: - Liệu những sự không phù hợp tương tự có tồn tại ở các nơi/ khu vực khác, ví dụ như qua việc sử dụng các mô hình và chuẩn mực đã có khi phân tích nguyên nhân; và - Liệu các nơi khác/ khu vực khác có đúng với các mô hình và chuẩn mực đã xác định không, theo đó vấn đề còn lại chỉ là thời gian trước khi xảy ra sự không phù hợp tương tự. ✓ Các định các hành động cần thiết để khắc phục nguyên nhân, đánh giá xem các hành động này có tương ứng với các hậu quả và tác động của sự không phù hợp
--	--

	không, và kiểm tra xem chúng sẽ không có tác động phụ có thể dẫn tới các sự không phù hợp khác hoặc các rủi ro ATTT quan trọng mới không; ✓ Hoạch định cho các hành động khắc phục, xác định tính ưu tiên, nếu có thể, đối với các khu vực ở đó có khả năng tái diễn cao hơn và hậu quả của sự không phù hợp là nghiêm trọng hơn. Việc hoạch định phải bao gồm người chịu trách nhiệm cho hành động khắc phục và thời hạn hoàn thành hành động khắc phục; ✓ Triển khai các hành động khắc phục theo kế hoạch; và ✓ Đánh giá hành động khắc phục xem chúng có thực sự giải quyết được nguyên nhân của sự không phù hợp không, và liệu đã ngăn ngừa tái diễn sự không phù hợp liên quan không. Việc đánh giá này phải đảm bảo tính khách quan, công bằng, dựa trên bằng chứng rõ ràng và được lập thành văn bản. Việc đánh giá này cũng phải được truyền đạt, thông báo đến các vai trò và các bên quan tâm thích hợp. • Kết quả thực hiện khắc phục và hành động khắc phục sẽ dẫn tới các cơ hội mới để không ngừng cải tiến ISMS, vì thế chúng phải được tiến hành một cách nghiêm túc, bài bản. • Tổ chức phải lưu giữ đầy đủ các thông tin dạng văn bản để chứng tỏ tổ chức đã giải quyết sự không phù hợp một cách đúng đắn và đã xử lý các hậu quả liên quan. Tất cả các bước quan trọng của việc quản lý vấn đề không phù hợp (phân tích nguyên nhân, xem xét, quyết định thực hiện các hành động, xem xét và quyết định về các thay đổi đối với ISMS) đều phải được lập thành văn bản.
--	--

	Ngoài ra, cũng phải kèm theo các bằng chứng cho thấy các hành động đã thực hiện đã đạt được hiệu quả như dự kiến. • Một số tổ chức lập ra các biểu/ sổ để đăng ký, theo dõi sự không phù hợp và các hành động khắc phục. Việc này có thể thực hiện thành nhiều biểu/ sổ (ví dụ như lập, theo dõi theo cấp phòng ban, hay theo quá trình) và bằng các phương tiện khác nhau (lập sổ trên giấy, mở file điện tử để theo dõi hay bằng ứng dụng phần mềm). Nếu vậy, các biểu sổ này phải được thiết lập và được kiểm soát như là các thông tin dạng văn bản và phải giúp hiểu được đầy đủ về tất cả các điểm không phù hợp và các hành động khắc phục để đảm bảo việc đánh giá chính xác nhu cầu có các hành động. • Tiêu chuẩn ISO/IEC 27001 không đề cập cụ thể bất cứ yêu cầu đối với "hành động phòng ngừa". Lý do là vì, một trong những mục đích chính của một hệ thống quản lý chính thức là để tạo ra công cụ phòng ngừa rồi. Theo đó, các tiêu chuẩn về các hệ thống quản lý do ISO ban hành đều có chung yêu cầu về việc đánh giá "các vấn đề bên ngoài và nội bộ có liên quan đến mục đích của tổ chức và có ảnh hưởng đến khả năng của tổ chức để đạt được các kết quả dự kiến" ở Điều 4.1, và để "xác định các rủi ro và cơ hội cần được giải quyết để: đảm bảo ISMS có thể đạt được các kết quả dự kiến; để ngăn ngừa, giảm các kết quả không mong muốn; để đạt được sự cải tiến liên tục" ở Điều 6.1. Bởi vậy, hai yêu cầu này được xem xét để bao quát cho khái niệm "hành động phòng ngừa" và cũng cho ta cái nhìn rộng hơn về các rủi ro và cơ hội.
--	---

10.2 Cải tiến liên tục	<i>Các hoạt động theo yêu cầu tiêu chuẩn:</i> • Tổ chức phải cải tiến thường xuyên sự phù hợp, thỏa đáng và tính hiệu lực của ISMS.
	<i>Giải thích:</i> • Tổ chức và bối cảnh của tổ chức không bao giờ ở trạng thái tĩnh hoàn toàn. Bên cạnh đó, các rủi ro đối với hệ thống thông tin, các cách thức mà theo đó chúng có thể bị xâm phạm cũng gia tăng nhanh chóng. Cuối cùng, không có hệ thống ISMS nào là tuyệt hảo mà luôn luôn có cách gì đó để hệ thống được tốt hơn, ngay cả khi nếu tổ chức và bối cảnh của tổ chức không có sự thay đổi. • Khi tổ chức cải tiến liên tục bằng phương pháp tiếp cận có hệ thống thì sẽ giúp ISMS hiệu quả hơn, từ đó giúp cải thiện về ATTT cho tổ chức. Việc quản lý ATTT sẽ giúp cho các hoạt động tác nghiệp của tổ chức trở nên chủ động chứ không bị động, nghĩa là hầu hết các nguồn lực được sử dụng để xác định và giải quyết các vấn đề. Lãnh đạo cao nhất có thể thiết lập ra các mục tiêu cho cải tiến liên tục, ví dụ thông qua việc đo lường tính hiệu lực, chi phí hoặc độ chín muồi của các quá trình. • Kết quả là, tổ chức sẽ xem ISMS như là một phần không ngừng được phát triển, học hỏi để tiến bộ và gắn kết với các hoạt động kinh doanh của mình. Để giữ cho ISMS luôn đi song hành với các thay đổi, tổ chức phải thường xuyên đánh giá xét về mục đích, hiệu lực, đồng bộ với các mục tiêu của tổ chức.
	<i>Hướng dẫn:</i> • Cải tiến liên tục ISMS đòi hỏi việc hệ thống ISMS và các

yếu tố của hệ thống đều phải được đánh giá xét về các vấn đề bên ngoài và nội bộ (điều 4.1), các yêu cầu của các bên quan tâm (điều 4.2) và kết quả của việc đánh giá kết quả thực hiện (điều 9). Việc đánh giá phải bao gồm sự phân tích về:

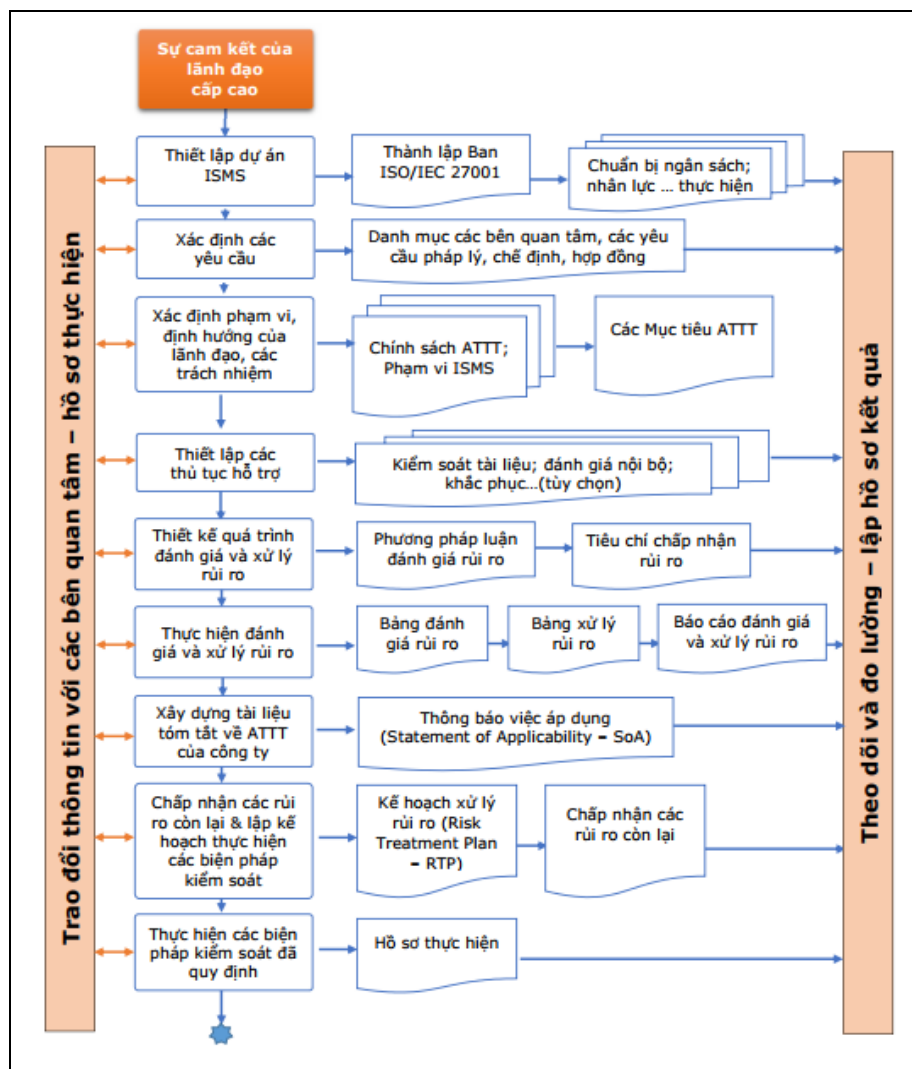
- ✓ Sự thích hợp của ISMS: xem xét liệu các vấn đề bên ngoài và nội bộ, các yêu cầu của các bên quan tâm, các mục tiêu ATTT đã thiết lập và các rủi ro ATTT đã nhận biết đã được đánh giá đầy đủ trong quá trình hoạch định và thực hiện ISMS và các biện pháp kiểm soát ATTT hay không;
- ✓ Tính thỏa đáng của ISMS: xem xét liệu các quá trình của ISMS và các biện pháp kiểm soát ATTT có tương thích với mục đích tổng thể, các hoạt động và các quá trình của tổ chức không; và
- ✓ Tính hiệu lực của ISMS: xem xét liệu các kết quả dự kiến của ISMS đã đạt được chưa, các yêu cầu của các bên quan tâm đã được đáp ứng chưa, các rủi ro ATTT đã được quản lý để đạt các mục tiêu ATTT chưa, các vấn đề không phù hợp đã được quản lý chưa, các nguồn lực cần thiết để thiết lập, thực hiện, duy trì và cải tiến liên tục ISMS có tương xứng với các kết quả không.
- Việc đánh giá có thể bao gồm việc phân tích hiệu quả của ISMS và các yếu tố của nó, xem xét liệu việc sử dụng các nguồn lực có thích hợp không, liệu các rủi ro mà nếu không hiệu quả thì sẽ dẫn tới việc mất đi tính hiệu lực hoặc liệu có được cơ hội để tăng hiệu quả lên không.
- Có thể nhận diện các cơ hội cải tiến qua việc quản lý sự

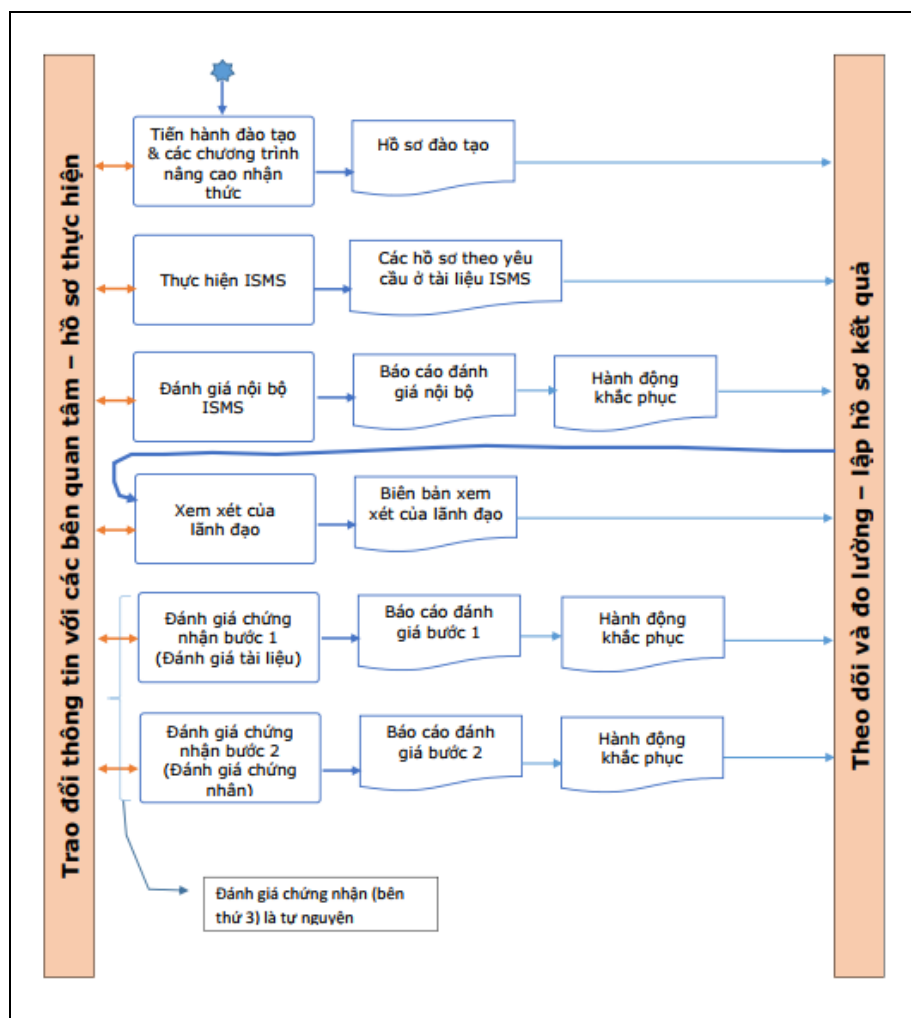
	không phù hợp và hành động khắc phục. Mỗi khi xác định được cơ hội cải tiến, tổ chức phải (theo điều 6.1.1): ✓ Đánh giá cơ hội để khẳng định có đáng để khai thác nó hay không; ✓ Xác định các thay đổi đối với ISMS và các yếu tố của hệ thống để đạt được sự cải tiến; ✓ Hoạch định và thực hiện các hành động để khai thác được cơ hội bằng cách đảm bảo các lợi ích sẽ thu được và các vấn đề không phù hợp sẽ không xảy ra; và ✓ Đánh giá tính hiệu lực của các hành động.
--	---

3. Lộ trình triển khai hệ thống quản lý ATTT theo ISO/IEC 27001:2013

Để triển khai thành công hệ thống quản lý ATTT theo ISO/IEC 27001:2013, việc xác định đúng đắn mục đích thực hiện và sự quan tâm, cam kết của lãnh đạo cấp cao của tổ chức, doanh nghiệp, cùng với việc chuẩn bị các nguồn lực cần thiết để thiết lập, vận hành, cải tiến hệ thống là những điều kiện tiên quyết. Mỗi khi các điều kiện này được thỏa mãn, quá trình thực hiện sẽ được thiết kế dựa theo chu trình P-D-C-A và các yêu cầu cụ thể của tiêu chuẩn ISO/IEC 27001:2013.

Hình 1-4 mô tả tổng quan lộ trình thực hiện các hoạt động chính để xây dựng, áp dụng, đánh giá, cải tiến một hệ thống quản lý ATTT theo ISO/IEC 27001:2013 cho đến khi hoàn thành giai đoạn đánh giá chứng nhận hệ thống bởi tổ chức chứng nhận.





Hình 1-4: Sơ đồ lộ trình triển khai hệ thống quản lý ATTT theo ISO/IEC 27001:2013

Phần 2

HƯỚNG DẪN TRIỂN KHAI ISO/IEC 27001:2013

TẠI DOANH NGHIỆP

Chương 1

Tóm tắt quá trình triển khai ISO/IEC 27001:2013

tại doanh nghiệp

1. Các giai đoạn triển khai ISO/IEC 27001:2013

Dựa theo lộ trình tổng thể được mô tả ở **Hình 1-4**, tổ chức, doanh nghiệp cần xây dựng Kế hoạch tổng thể triển khai hệ thống quản lý ATTT theo ISO/IEC 27001:2013, trong đó vạch ra các giai đoạn cơ bản thực hiện dự án, bao gồm:

1. Chuẩn bị
2. Xây dựng hệ thống
3. Thực hiện hệ thống
4. Đánh giá nội bộ, xem xét của lãnh đạo và cải tiến
5. Đánh giá chứng nhận

Kế hoạch tổng thể phải làm rõ các hoạt động, nội dung thực hiện cụ thể ở từng giai đoạn của dự án, xác định trách nhiệm thực hiện, đầu ra kết quả dự kiến ở từng giai đoạn và khung thời gian thực hiện để có cơ sở quản lý việc triển khai kế hoạch.

Tùy thuộc vào quy mô của tổ chức, lĩnh vực và phạm vi hoạt động, mức độ phức tạp của các quá trình của tổ chức xét về khía cạnh ATTT, sự sẵn có của các nguồn lực phục vụ cho từng giai đoạn triển khai và một số yếu tố khác mà thời gian để hoàn thành các giai đoạn nêu trên có thể khác nhau.

Bên cạnh đó, cũng tùy theo sự sẵn có về các điều kiện nguồn lực, đặc biệt là nguồn nhân lực có kinh nghiệm tổ chức triển khai xây dựng, thực hiện hệ thống quản lý theo tiêu chuẩn (ví dụ như ISO 9001:2015), nắm chắc và có khả năng vận dụng các yêu cầu của tiêu chuẩn ISO/IEC 27001:2013 cho bối cảnh ATTT của doanh nghiệp, có kinh nghiệm quản lý rủi ro nói chung theo hướng dẫn quản lý rủi ro ở tiêu chuẩn ISO 31000 để vận dụng cho quản lý các rủi ro về ATTT đối với các loại tài sản thông tin của mình... mà tổ chức, doanh nghiệp có thể lựa chọn phương án tự tổ chức thiết lập, thực hiện, đánh giá, cải tiến hệ thống quản lý ATTT theo ISO/IEC 27001:2013 hoặc sử dụng các nguồn lực từ bên ngoài (ví dụ dịch vụ đào tạo, tư vấn) đối với một phần hoặc toàn bộ các hoạt động cần thiết để triển khai dự án ISO/IEC 27001.

2. Kế hoạch tổng thể triển khai ISO/IEC 27001:2013

Bảng 2-1 trình bày nội dung cơ bản của Kế hoạch tổng thể triển khai xây dựng, áp dụng hệ thống quản lý ATTT theo ISO/IEC 27001:2013 đi theo 5 giai đoạn triển khai nêu trên trong trường hợp tổ chức, doanh nghiệp có sử dụng dịch vụ tư vấn, hướng dẫn từ bên ngoài cho toàn bộ các giai đoạn của dự án. Khi doanh nghiệp chọn phương án tự thực hiện với nguồn nhân lực nội bộ của mình thì cũng cần phải triển khai đầy đủ các hoạt động, nội dung công việc như khi có sự tư vấn, hướng dẫn của chuyên gia bên ngoài.

Bảng 2-1
KẾ HOẠCH TỔNG THỂ TRIỂN KHAI DỰ ÁN XÂY DỰNG,
ÁP DỤNG HỆ THỐNG QUẢN LÝ AN TOÀN THÔNG TIN (ISMS) THEO ISO/IEC 27001:2013
TẠI DOANH NGHIỆP

TT	Nội dung công việc	Trách nhiệm	Kết quả/ Đầu ra dự kiến	Thời gian (tháng thứ) ¹							
				1	2	3	4	5	6	7	8
1	CHUẨN BỊ										
1.1	Lập Ban điều hành triển khai ISMS theo ISO/IEC 27001	Doanh nghiệp	Quyết định thành lập Ban điều hành ISO/IEC 27001								
1.2	Lập Tổ Thư ký ISO/IEC 27001	Doanh nghiệp	Quyết định thành lập Tổ Thư ký ISO/IEC 27001								
1.3	Đào tạo nhận thức chung về ISMS theo	Tư vấn + Doanh	Nhận thức về yêu cầu đảm bảo ATTT và các yêu cầu của ISO/IEC 27001 cho nhóm								

¹ Thời gian 08 tháng ở bản Kế hoạch này chỉ để tham khảo và áp dụng cho trường hợp tổ chức/ doanh nghiệp có sử dụng dịch vụ tư vấn từ bên ngoài. Thời gian thực tế để hoàn thành 05 giai đoạn thực hiện ISMS phụ thuộc vào quy mô, loại hình doanh nghiệp, mức độ phức tạp của các quá trình kinh doanh, sự cam kết của lãnh đạo doanh nghiệp và sự sẵn có của các nguồn lực xây dựng, áp dụng hệ thống quản lý.

TT	Nội dung công việc	Trách nhiệm	Kết quả/ Đầu ra dự kiến	Thời gian (tháng thứ) ¹							
				1	2	3	4	5	6	7	8
	ISO/IEC 27001:2013 (Khóa 1)	ngành	dự án (Ban ISO/ IEC 27001, Tổ Thư ký ISO/ IEC 27001, CBCV chủ chốt ở tất cả các đơn vị thuộc phạm vi triển khai là các thành phần bắt buộc tham dự)								
1.4	Đánh giá thực trạng quản lý ATTT hiện tại của doanh nghiệp	Tư vấn + Doanh nghiệp	Xác định thực trạng đáp ứng các yêu cầu của tiêu chuẩn; dự kiến phạm vi áp dụng hệ thống và thông tin để lập Kế hoạch chung và kế hoạch văn bản.								
1.5	Xác định Phạm vi (ISMS scope) của ISMS	Doanh nghiệp + Tư vấn	Phạm vi áp dụng được xác định rõ để sau này công bố chính thức trong bản Công bố áp dụng (SoA)								
1.6	Thông nhất, phê duyệt kế hoạch tổng thể triển khai ISMS và dự kiến kế hoạch xây dựng văn bản	Tư vấn + Doanh nghiệp	Các kế hoạch được thông nhất/ xác nhận.								

TT	Nội dung công việc	Trách nhiệm	Kết quả/ Đầu ra dự kiến	Thời gian (tháng thứ) ¹							
				1	2	3	4	5	6	7	8
2	XÂY DỰNG HỆ THỐNG ISMS										
2.1	Đào tạo phương pháp xây dựng văn bản theo ISO/IEC 27001 (Khóa 2)	Tư vấn + Doanh nghiệp	Hiểu và thực hành được phương pháp soạn thảo các văn bản theo yêu cầu của ISO/IEC 27001. Thành phần cần tham dự: như Khóa 1.								
2.2	Đào tạo phương pháp đánh giá rủi ro ATTT (Khóa 3)	Tư vấn + Doanh nghiệp	Hiểu và thực hành được việc đánh giá rủi ro đối với các tài sản thông tin thuộc phạm vi triển khai ISMS. Thành phần cần tham dự: như Khóa 1.								
2.3	Xác định các thông tin, yêu cầu hỗ trợ cho ISMS	Tư vấn + Doanh nghiệp	- Danh mục các quá trình / chức năng chính; địa điểm; các hệ thống thông tin; các mạng truyền thông. - Các yêu cầu của tổ chức đối với C-I-A của tài sản thông tin. - Các yêu cầu của tổ chức nhằm xác định các yêu cầu pháp luật, hợp đồng và								

TT	Nội dung công việc	Trách nhiệm	Kết quả/ Đầu ra dự kiến	Thời gian (tháng thứ) ¹							
				1	2	3	4	5	6	7	8
			ATTT.								
2.4	Thiết lập Chính sách ATTT, Mục tiêu ATTT	Doanh nghiệp + Tư vấn	- Chính sách ATTT bằng văn bản, thể hiện cam kết của lãnh đạo cao nhất và định hướng cho các hoạt động, quá trình trong hệ thống. Mục tiêu được công bố dạng văn bản, thể hiện mức độ thực hiện các cam kết trong chính sách và có thể đo lường được.								
2.5	Nhận biết các tài sản thông tin thuộc phạm vi hệ thống ISMS	Doanh nghiệp + Tư vấn	- Mô tả các quá trình chính trong tổ chức; - Danh mục xác định các tài sản thông tin của các quá trình chính; - Các quá trình trọng yếu / phân loại tài sản thông tin; - Tình trạng kiểm soát ATTT hiện tại và các biện pháp kiểm soát hiện có; đánh giá mức độ hiệu quả và xác định biện pháp kiểm soát bổ sung.								

TT	Nội dung công việc	Trách nhiệm	Kết quả/ Đầu ra dự kiến	Thời gian (tháng thứ) ¹							
				1	2	3	4	5	6	7	8
2.6	Xây dựng, ban hành Phương pháp đánh giá rủi ro về ATTT	Tư vấn + Doanh nghiệp	Tài liệu quy định cách thức đánh giá rủi ro ATTT cần thiết để làm căn cứ cho các bước tiếp theo của đánh giá rủi ro.								
2.7	Nhận biết rủi ro về ATTT đối với các tài sản	Doanh nghiệp + Tư vấn	Xác định được các mối đe dọa và các điểm yếu đối với tài sản. Xác định được mức độ về tính bảo mật, tính toàn vẹn và tính sẵn có của từng tài sản (C/I/A).								
2.8	Đánh giá trị rủi ro về ATTT đối với các tài sản	Doanh nghiệp + Tư vấn	Xác định được các rủi ro quan trọng cần có biện pháp kiểm soát để giảm tới mức có thể chấp nhận. (Kết quả đánh giá rủi ro ATTT).								
2.9	Xác định các Mục tiêu kiểm soát, Biện pháp kiểm soát rủi ro và Kế hoạch xử lý rủi ro	Doanh nghiệp + Tư vấn	Bản "Thông báo việc áp dụng" (Statement Of Applicability - SoA). Kế hoạch xử lý rủi ro (Risk Treatment Plan - RTP).								
2.10	Thiết lập/ tích hợp (vào các thủ tục hiện	Doanh nghiệp	Các thủ tục văn bản theo yêu cầu tiêu chuẩn (kiểm soát tài liệu; kiểm soát hồ sơ;								

TT	Nội dung công việc	Trách nhiệm	Kết quả/ Đầu ra dự kiến	Thời gian (tháng thứ) ¹							
				1	2	3	4	5	6	7	8
	có), ban hành các thủ tục dạng văn bản để kiểm soát ISMS	+ Tư vấn	đánh giá nội bộ; hành động khắc phục; hành động phòng ngừa); ngoài ra, có thể lập quy trình cho hoạt động xem xét của lãnh đạo về ISMS.								
2.11	Thiết lập/ tích hợp, ban hành các văn bản xác định vai trò, trách nhiệm, quyền hạn về ATTT	Doanh nghiệp + Tư vấn	Văn bản (cơ cấu tổ chức, các vai trò, trách nhiệm-quyền hạn liên quan ATTT). Tích hợp vào hệ thống các bản Mô tả công việc.								
2.12	Thiết lập các Chính sách ATTT cụ thể và / hoặc các Thủ tục/ Hướng dẫn kiểm soát rủi ro ATTT cụ thể	Doanh nghiệp + Tư vấn	Các tài liệu chính sách, thủ tục ATTT cụ thể cần thiết tương thích với kết quả đánh giá rủi ro; tài liệu quy định đo lường hiệu lực của biện pháp kiểm soát.								
3	TRIỂN KHAI ÁP DỤNG HỆ THỐNG										
3.1	Hướng dẫn áp dụng hệ thống văn bản	Doanh nghiệp	CBNV thuộc phạm vi ISMS hiểu được cơ bản về ISMS của doanh nghiệp và nhận								

TT	Nội dung công việc	Trách nhiệm	Kết quả/ Đầu ra dự kiến	Thời gian (tháng thứ) ¹							
				1	2	3	4	5	6	7	8
	(chính sách, mục tiêu, thủ tục, biện pháp kiểm soát, kế hoạch xử lý rủi ro...)	+ Tư vấn	thức được trách nhiệm tuân thủ theo các quy định văn bản trong hệ thống.								
3.2	Phân phối hệ thống văn bản đến các phòng/ bộ phận có liên quan.	Doanh nghiệp	HTVB được phân phối tới các phòng/ bộ phận.								
3.3	Đào tạo nhận thức về an toàn thông tin và về hệ thống quản lý ATTT cho CBNV của doanh nghiệp	Doanh nghiệp (Ban ISO/ Thư ký ISO)	CBNV có trách nhiệm thực hiện các biện pháp kiểm soát an toàn thông tin hiểu được các rủi ro về an toàn và trách nhiệm, cách thức họ đóng góp vào việc đảm bảo hiệu lực của các biện pháp kiểm soát đã xác định trong hệ thống.								
3.4	Hướng dẫn và kiểm tra áp dụng tại các phòng/ đơn vị trong	Doanh nghiệp + Tư	HTVB của ISMS được phổ biến và áp dụng.								

TT	Nội dung công việc	Trách nhiệm	Kết quả/ Đầu ra dự kiến	Thời gian (tháng thứ) ¹							
				1	2	3	4	5	6	7	8
	hệ thống ISMS	vấn									
4	ĐÁNH GIÁ NỘI BỘ & XEM XÉT, CẢI TIẾN HỆ THỐNG ISMS										
4.1	Thực hiện giám sát, đo lường hiệu lực của hệ thống ISMS và hiệu lực của các biện pháp kiểm soát	Doanh nghiệp + Tư vấn	Hồ sơ kết quả đo lường kết quả thực hiện và đo lường hiệu lực hệ thống ISMS								
4.2	Đào tạo Phương pháp đánh giá nội bộ hệ thống quản lý ATTT (Khóa 3)	Tư vấn + Doanh nghiệp	Tài liệu đào tạo, danh sách tham dự, chứng chỉ (Ban ISO/ IEC 27001, Tổ Thư ký ISMS, các CBCV chủ chốt ở các đơn vị là thành phần bắt buộc tham dự)								
4.3	Lập kế hoạch và đánh giá nội bộ	Doanh nghiệp + Tư vấn	Kế hoạch, chương trình đánh giá và báo cáo đánh giá.								
4.4	Khắc phục, cải tiến	Doanh nghiệp	Kết quả khắc phục tại các đơn vị.								

TT	Nội dung công việc	Trách nhiệm	Kết quả/ Đầu ra dự kiến	Thời gian (tháng thứ) ¹							
				1	2	3	4	5	6	7	8
	sau đánh giá	ngành + Tư vấn									
4.5	Xem xét của lãnh đạo về hệ thống ISMS	Doanh nghiệp	Báo cáo, biên bản họp.								
5	ĐÁNH GIÁ CHỨNG NHẬN HỆ THỐNG										
5.1	Lựa chọn Tổ chức chứng nhận	Doanh nghiệp	Doanh nghiệp quyết định lựa chọn tổ chức chứng nhận thích hợp đáp ứng nhu cầu của mình								
5.2	Thực hiện đánh giá chứng nhận (2 giai đoạn: đánh giá sơ bộ/ tài liệu và đánh giá chính thức)	Tổ chức chứng nhận + Doanh nghiệp	Ban ISO/ IEC 27001 chủ trì hoạch định kế hoạch để xử lý kết quả sau mỗi giai đoạn đánh giá dựa theo báo cáo đánh giá cho từng giai đoạn của tổ chức chứng nhận.								
5.3	Khắc phục sau đánh giá chứng nhận (nếu	Doanh nghiệp									

TT	Nội dung công việc	Trách nhiệm	Kết quả/ Đầu ra dự kiến	Thời gian (tháng thứ) ¹							
				1	2	3	4	5	6	7	8
	có)	+ Tư vấn									

Viết tắt:

- HTVB: hệ thống văn bản
- SoA (Statement of Applicability): Bản Thông báo việc áp dụng
- C/ Confidentiality: Tính bảo mật; I/ Integrity: Tính nhất quán; A/ Availability: Tính sẵn có

Chương 2

HƯỚNG DẪN CÁCH THỰC HIỆN DỰ ÁN ISMS TẠI TỔ CHỨC, DOANH NGHIỆP, NHỮNG LỢI ÍCH DỰ KIẾN SẼ THU ĐƯỢC VÀ CÁC YẾU TỐ ĐẢM BẢO THỰC HIỆN THÀNH CÔNG

1. Hướng dẫn cách thực hiện và một số kết quả đầu ra theo từng bước triển khai Kế hoạch tổng thể xây dựng, thực hiện ISO/IEC 27001:2013

Phần này hướng dẫn cách thức thực hiện các nội dung chính để thu được các kết quả đầu ra dự kiến theo từng giai đoạn của Kế hoạch tổng thể triển khai hệ thống quản lý ATTT theo ISO/IEC 27001:2013 (theo **Bảng 2-1**). Phương pháp thực hiện cho từng kết quả đầu ra được thể hiện tại các Phụ lục của tài liệu hướng dẫn này, chi tiết theo bảng sau:

Giai đoạn của dự án	Hướng dẫn và minh họa một số kết quả đầu ra tiêu biểu theo từng giai đoạn triển khai ISMS	Phụ lục
Chuẩn bị	1.Quyết định thành lập Ban điều hành triển khai thực hiện ISMS theo ISO/IEC 27001:2013	Phụ lục 1
	2.Quyết định phân công vai trò Lãnh đạo an toàn thông tin theo ISO/IEC 27001:2013	Phụ lục 2
	3.Quyết định thành lập Tổ thư ký ISO/IEC 27001:2013	Phụ lục 3
	4.Báo cáo đánh giá thực trạng dựa theo yêu cầu ISO/IEC 27001:2013 (Gap Analysis)	Phụ lục 4

	5.Xác định phạm vi áp dụng ISMS	Phụ lục 5
	6.Kế hoạch xây dựng hệ thống văn bản ISMS	Phụ lục 6
Xây dựng và triển khai áp dụng	7.Chính sách chung về ATTT	Phụ lục 7
	8.Bảng kiểm kê tài sản thông tin	Phụ lục 8
	9.Bảng đánh giá rủi ro về ATTT	Phụ lục 9
	10. Mục tiêu ATTT	Phụ lục 10
	11. Kế hoạch xử lý rủi ro ATTT	Phụ lục 11
	12. Bản Thông báo việc áp dụng SoA	Phụ lục 12
	13. Chính sách kiểm soát ATTT cụ thể - ví dụ Chính sách an toàn nguồn nhân lực khi kết thúc công việc	Phụ lục 13
Đánh giá nội bộ, xem xét, cải tiến	14. Kế hoạch đo lường hiệu lực của ISMS	Phụ lục 14
	15. Hoạch định cụ thể đo lường hiệu lực của ISMS - đo lường chất lượng mật khẩu	Phụ lục 15
	16. Kế hoạch đánh giá nội bộ ISMS	Phụ lục 16

2. Một số yếu tố quyết định sự thành công của việc thực hiện ISMS theo ISO/IEC 27001

Để thực hiện thành công hệ thống quản lý ATTT theo ISO/IEC 27001, các nguyên tắc cơ bản sau đây phải được vận dụng triệt để, xuyên suốt trong toàn bộ quá trình (nguồn: ISO/IEC 27000:2018 - Công nghệ thông tin - Kỹ thuật an toàn - Hệ thống quản lý an toàn thông tin - Khái quát và từ vựng):

a) Chính sách ATTT, các mục tiêu ATTT và các hoạt động phải đồng bộ với các mục tiêu kinh doanh của tổ chức;

b) Phương pháp tiếp cận và khuôn khổ để thiết kế, thực hiện, theo dõi, duy trì và cải thiện các kết quả về ATTT phải nhất quán với văn hóa của tổ chức;

c) Phải có sự cam kết, hỗ trợ đầy đủ của tất cả các cấp độ lãnh đạo để triển khai hệ thống, nhất là lãnh đạo cao nhất của tổ chức. Lãnh đạo cao nhất phải chứng minh sự cam kết đối với việc thiết lập, thực hiện, vận hành, giám sát, xem xét, duy trì, và cải tiến hệ thống ISMS. Cam kết của lãnh đạo phải bao gồm cả các hoạt động như đảm bảo sự sẵn có các nguồn lực cần thiết cho ISMS và đảm bảo rằng tất cả những nhân viên có ảnh hưởng đến hệ thống ISMS đều phải được đào tạo, nâng cao nhận thức và có năng lực thích hợp.

d) Phải hiểu rõ các yêu cầu về bảo vệ các tài sản thông tin của tổ chức thông qua việc áp dụng quản lý rủi ro ATTT (tham khảo tiêu chuẩn ISO/IEC 27005);

e) Đảm bảo thực hiện có hiệu quả các chương trình giáo dục, đào tạo, nâng cao nhận thức về ATTT; thông báo đến mọi nhân viên và các bên quan tâm liên quan về yêu cầu/ ràng buộc về ATTT đối với họ theo đúng các Chính sách và tiêu chuẩn về ATTT và khích lệ sự tham gia thực hiện của họ. Tổ chức phải đảm bảo phân bổ nguồn lực (nhân lực, tài chính, thời gian..) để hệ thống ISMS và các biện pháp kiểm soát đã đề ra sẽ vận hành trên thực tế. Đồng thời, các nhân viên làm việc trong phạm vi của ISMS (duy trì hệ thống ISMS, các văn bản của hệ thống và người có trách nhiệm thực hiện các biện pháp kiểm soát) phải được đào tạo thích hợp, trong đó, các nội dung đào tạo tối thiểu là:

- Nhận thức về ATTT nói chung và về yêu cầu của tiêu chuẩn ISO/IEC 27001;

- Phương pháp thực hiện: đào tạo phương pháp kiểm kê TSTT, phương pháp đánh giá rủi ro ATTT, các biện pháp kiểm soát ATTT;

- Phương pháp theo dõi, đánh giá: đào tạo về theo dõi, đánh giá

hiệu lực của hệ thống ISMS; hiệu lực của các biện pháp kiểm soát ATTT; đào tạo đánh giá nội bộ hệ thống ISMS.

f) Phải có quá trình quản lý sự cố ATTT có hiệu quả;

g) Phải thiết lập, thực hiện có hiệu quả phương pháp quản lý kinh doanh liên tục;

h) Phải thiết lập, thực hiện hệ thống đo lường để đánh giá kết quả thực hiện ISMS và xử lý, phản hồi các khuyến nghị để cải tiến hệ thống ISMS;

i) Cải tiến liên tục theo chu trình PDCA:

Để đảm bảo rằng hệ thống ISMS có hiệu quả và được duy trì, tiêu chuẩn ISO/IEC 27001 yêu cầu:

- Việc xem xét của lãnh đạo đối với ISMS theo tần suất đã định để đánh giá các cơ hội cải tiến, nhu cầu thay đổi đối với ISMS, kể cả Chính sách ATTT và các mục tiêu ATTT, có chú ý tới các hành động khắc phục, phòng ngừa và tính hiệu lực của các hành động này.

- Các cuộc đánh giá nội bộ định kỳ: Kết quả của đánh giá nội bộ giúp xác định được mức độ phù hợp với các yêu cầu áp dụng cho ISMS, các điểm không phù hợp và các hành động khắc phục, phòng ngừa liên quan.

Phần 3

THỰC TIỄN TRIỂN KHAI ÁP DỤNG THỬ NGHIỆM HỆ THỐNG QUẢN LÝ AN TOÀN THÔNG TIN THEO ISO/IEC 27001 TẠI DOANH NGHIỆP

Chương 1

Tóm tắt kết quả triển khai ISO/IEC 27001:2013 tại 2 doanh nghiệp

Phần này nhằm mục đích minh họa cho những nội dung hướng dẫn thực hiện hệ thống quản lý ATTT đã được trình bày ở Phần 2, trên cơ sở cung cấp thông tin cơ bản về quá trình và một số kết quả áp dụng thử nghiệm hệ thống quản lý ATTT theo tiêu chuẩn ISO/IEC 27001 tại hai doanh nghiệp có lĩnh vực kinh doanh dịch vụ khác nhau ở khu vực Miền Trung, gồm:

- Công ty Cổ phần NETPLUS;
- Chi nhánh Công ty TNHH Kiểm toán và tư vấn Phan Dũng tại Đà Nẵng.

Đây là hai trong tổng số 10 doanh nghiệp tham gia xây dựng, áp dụng thử nghiệm hệ thống quản lý ATTT theo ISO/IEC 27001, thuộc nhiệm vụ khoa học - công nghệ “Nghiên cứu, hướng dẫn áp dụng Hệ thống quản lý an toàn thông tin (ISO/IEC 27001) và Chỉ số đánh giá hoạt động chính (KPIs)” (mã số 03.2/2013-DA2), thuộc Dự án “Thúc đẩy hoạt động năng suất và chất lượng”, thuộc Chương trình quốc gia “Nâng cao năng suất và chất lượng sản phẩm, hàng hoá của doanh nghiệp Việt Nam đến năm 2020”.

Tình huống 1: Công ty Cổ phần NETPLUS

1. Giới thiệu về doanh nghiệp:

Tên giao dịch: Công ty Cổ phần NETPLUS

Địa chỉ: 11. Nguyễn Thị Minh Khai, Q. Hải Châu, TP. Đà Nẵng

Ngành nghề kinh doanh:

- Dịch vụ giá trị gia tăng trên mạng;
- Đại lý tên miền, hosting, chứng thư số;
- Bán buôn thiết bị điện tử, viễn thông;
- Quảng cáo thương mại;
- Sản xuất phần mềm;
- Xây lắp và bảo dưỡng công trình viễn thông.

2. Tóm tắt quá trình hình thành, phát triển:

• NETPLUS thành lập vào cuối năm 2008 với khởi đầu cung cấp dịch vụ và giải pháp nội dung số trên môi trường mạng.

• Qua một thời gian phát triển dựa trên dịch vụ chính là SMS, công ty đã phát triển mạnh sang các dịch vụ mạng khác (như làm web, cung cấp Domain, hosting,...) cũng như phát triển thêm về cung cấp thiết bị cũng như dịch vụ liên quan đến văn phòng và cảnh báo từ xa.

• NETPLUS là công ty tiên phong về phát triển hệ thống SMS điều hành và quản lý học tập của học sinh ở khu vực miền Trung và Tây Nguyên.

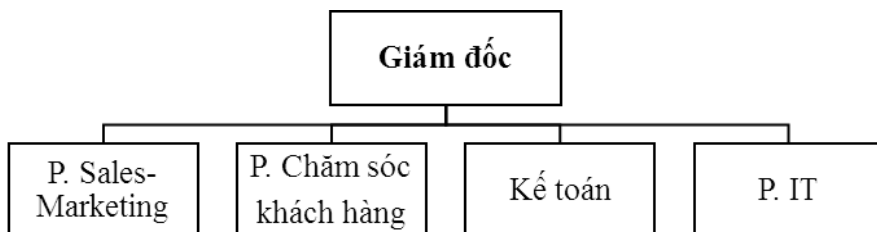
• Với dịch vụ chính là SMS giao tiếp giữa nhà trường và phụ

huynh, NETPLUS đang là công ty lớn nhất cung cấp dịch vụ này ở miền Trung và Tây Nguyên.

- Với hệ thống SMS, NETPLUS đã phát triển đa dạng các dịch vụ khách hàng liên quan đến SMS: SMS Điều hành, SMS Học tập, SMS Marketing, SMS Cảnh báo...

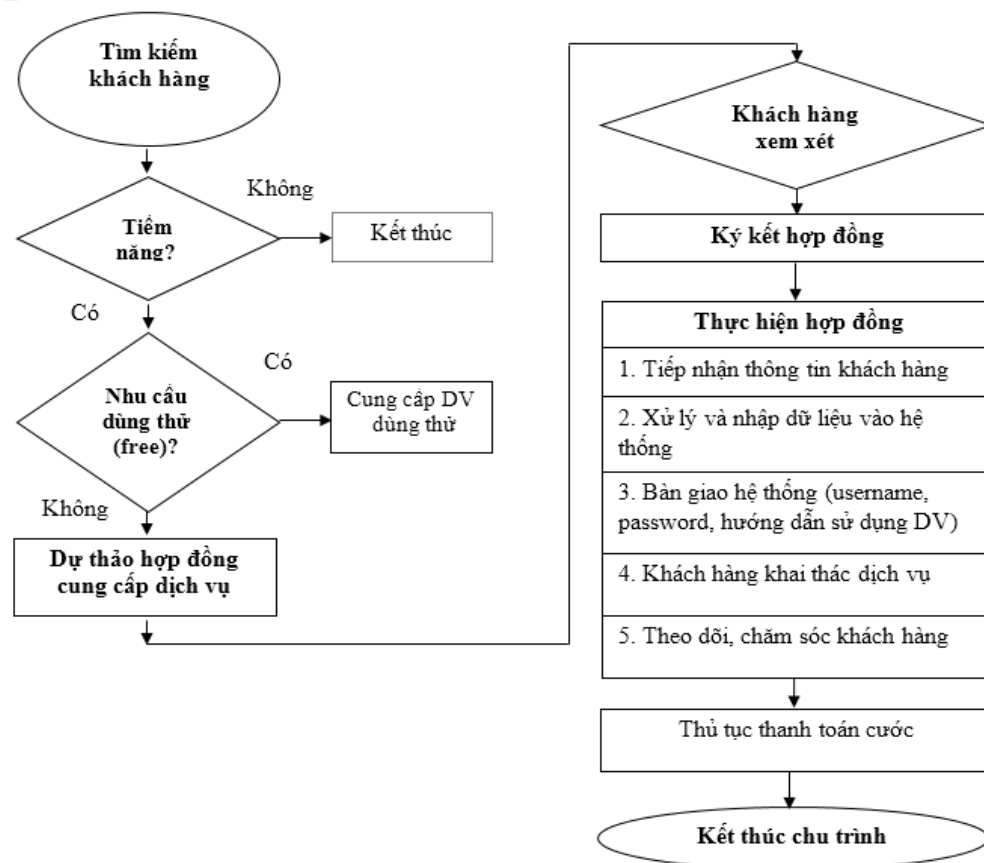
3. Cơ cấu tổ chức và quá trình cung cấp dịch vụ chính của doanh nghiệp

3.1. Cơ cấu tổ chức



3.2. Lưu đồ quá trình cung cấp dịch vụ chính (dịch vụ tin nhắn SMS)

Xem trang tiếp theo



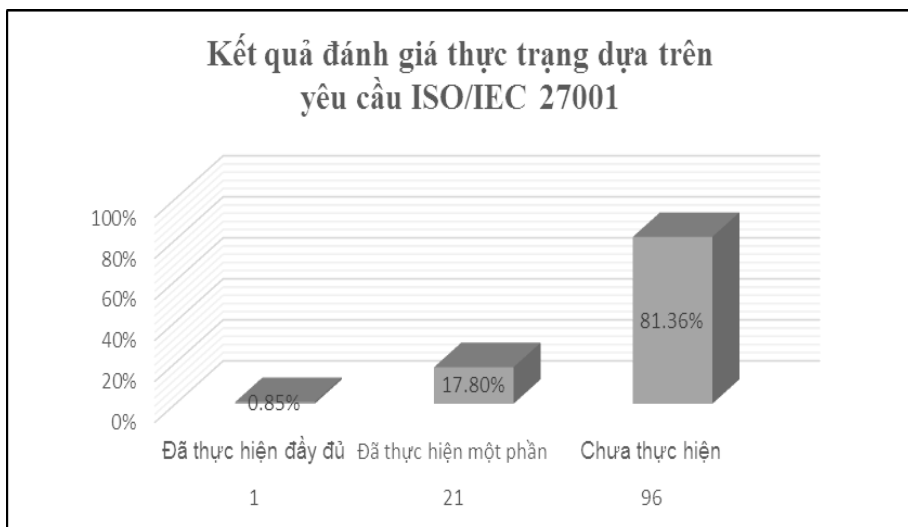
4. Hiện trạng đáp ứng yêu cầu đảm bảo ATTT trước khi áp dụng ISO/IEC 27001

- Mặc dù lãnh đạo công ty đã có sự quan tâm đến vấn đề đảm bảo an toàn thông tin trong quá trình cung cấp dịch vụ tin nhắn SMS, vừa để đảm bảo đáp ứng các yêu cầu của khách hàng sử dụng dịch vụ tin nhắn, lẫn đáp ứng các yêu cầu của pháp luật liên quan đến loại dịch vụ này, tuy nhiên, do chưa có phương pháp tiếp cận bài bản, có tính hệ thống, nên công ty vẫn có nguy cơ đối diện với các rủi ro có thể phương hại đến các tài sản thông tin của khách hàng và của chính công ty.

- Trong quá trình cung cấp các dịch vụ tin nhắn SMS điều hành và quản lý học tập của học sinh mà đối tượng khách hàng trực tiếp ký hợp đồng mua dịch vụ của công ty là các trường học ở khu vực, các rủi ro và mối đe dọa về an toàn thông tin đã xảy ra hoặc tiềm ẩn chủ yếu liên quan đến tính bảo mật thông tin của khách hàng (được hiểu là các thông tin cá nhân của phụ huynh học sinh đăng ký sử dụng dịch vụ SMS phải được bảo vệ để không bị lộ và khai thác bởi các đối tượng thứ ba không có quyền sử dụng), tính toàn vẹn của thông tin (nội dung thông điệp/ tin nhắn để phục vụ trao đổi thông tin giữa nhà trường và với phụ huynh phải được bảo vệ để không bị làm sai lệch, mất đi giá trị so với thông tin gốc trong quá trình xử lý, truyền thông tin dưới dạng tin nhắn SMS), và tính sẵn có của thông điệp/ tin nhắn SMS mà nhà trường muốn truyền đến phụ huynh học sinh khi cần. Điều này có liên quan đến yêu cầu đảm bảo tính kinh doanh/ cung cấp dịch vụ liên tục mà công ty cam kết và được ràng buộc trong hợp đồng ký với các khách hàng của mình.

- Đối chiếu với các yêu cầu của tiêu chuẩn ISO/IEC 27001, mức độ đáp ứng của công ty tại thời điểm khởi động mô hình thử nghiệm là thấp (đáp ứng đầy đủ yêu cầu: 0,85% ; đáp ứng một phần: 17,80%, chưa đáp ứng: 81,36% tính trên tổng số 118 hạng mục/ yêu cầu của

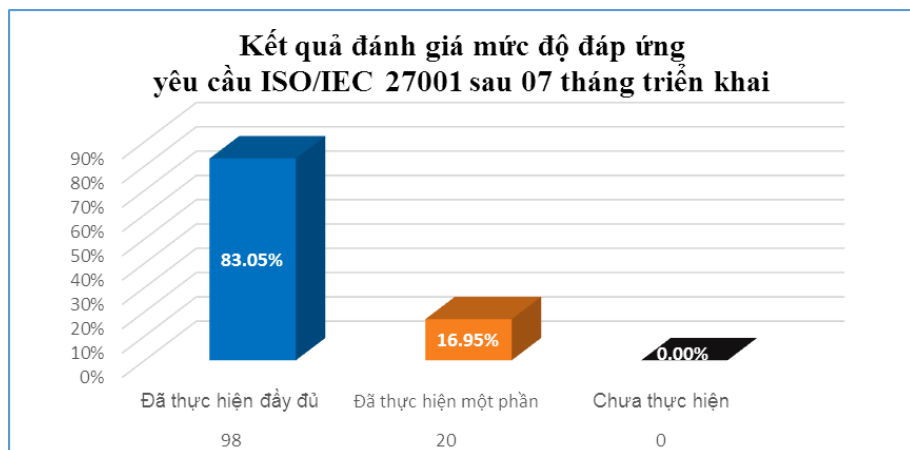
tiêu chuẩn).



5. Kết quả cải thiện mức độ đáp ứng về đảm bảo ATTT sau khi áp dụng ISO/IEC 27001:

• Sau 7 tháng triển khai xây dựng và hoàn thành các hoạt động đánh giá nội bộ, thực hiện hành động khắc phục, xem xét của lãnh đạo về hệ thống ISMS: mức độ đáp ứng yêu cầu tiêu chuẩn đã được cải thiện nhiều (đáp ứng đầy đủ yêu cầu: 83,05% ; đáp ứng một phần: 16,95%, chưa đáp ứng: 0% trong tổng số 118 hạng mục/ yêu cầu của tiêu chuẩn). Đối với các hạng mục được xem là “đáp ứng một phần” chủ yếu là do yếu tố thời gian thực hiện áp dụng hệ thống quản lý ở doanh nghiệp thử nghiệm là chưa nhiều, nhất thiết phải tiếp tục vận hành, duy trì, thường xuyên cải tiến hệ thống theo đúng chu trình PDCA trong thời gian tiếp theo để có đủ thông tin, dữ liệu về hiệu lực và hiệu quả lâu dài của hệ thống. Các kết quả hoạt động an toàn thông tin trên thực tế cũng đã được ghi nhận, trong đó việc tiếp tục duy trì hiệu quả bảo vệ các tài sản thông tin của khách hàng sử dụng dịch vụ tin nhắn SMS trường học, không xảy ra sự cố nào gây hại cho C, I, A của thông tin dịch vụ và thông tin của khách hàng được xử lý và

truyền đến phụ huynh học sinh dưới dạng tin nhắn SMS. Đặc biệt nhờ có hệ thống dự phòng (máy chủ, đường truyền) nên công ty đã duy trì tốt tính liên tục của dịch vụ theo cam kết với khách hàng.



Tình huống 2: Chi nhánh Công ty TNHH Kiểm toán và tư vấn Phan Dũng tại Đà Nẵng

1. Giới thiệu về doanh nghiệp:

Tên giao dịch: Chi nhánh Công ty TNHH Kiểm toán và Tư vấn Phan Dũng tại Đà Nẵng

Địa chỉ: 89. Phạm Văn Bạch, Q. Hải Châu, TP. Đà Nẵng

Ngành nghề kinh doanh:

- Dịch vụ kiểm toán.
- Dịch vụ kiểm toán Báo cáo quyết toán vốn đầu tư.
- Tư vấn thuế, tư vấn tài chính.
- Dịch vụ kế toán, dịch vụ quyết toán thuế.

2. Tóm tắt quá trình hình thành, phát triển:

2.1. Công ty TNHH Kiểm toán và tư vấn Phan Dũng (công ty

mẹ)

- Thành lập theo giấy chứng nhận đăng ký kinh doanh lần đầu số 4102042818 ngày 11/09/2006, đăng ký thay đổi lần 2 số 0304572721 ngày 24/12/2010 do Sở kế hoạch và Đầu tư thành phố Hồ Chí Minh cấp.

- Địa chỉ trụ sở chính: 108-E7 Cộng Hòa, Phường 4, Quận Tân Bình, Tp.Hồ Chí Minh.

- Hiện tại Công ty có các văn phòng đại diện ở Nha Trang, Cần Thơ và chi nhánh tại Đà Nẵng.

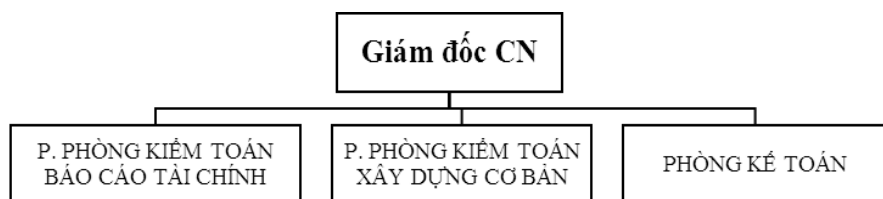
2.2. Chi nhánh Công ty TNHH Kiểm toán và tư vấn Phan Dũng tại Đà Nẵng (viết gọn là Chi nhánh PDAC tại Đà Nẵng).

- Thành lập theo giấy chứng nhận đăng ký kinh doanh lần đầu số 0304572721-002 ngày 25/12/2012.

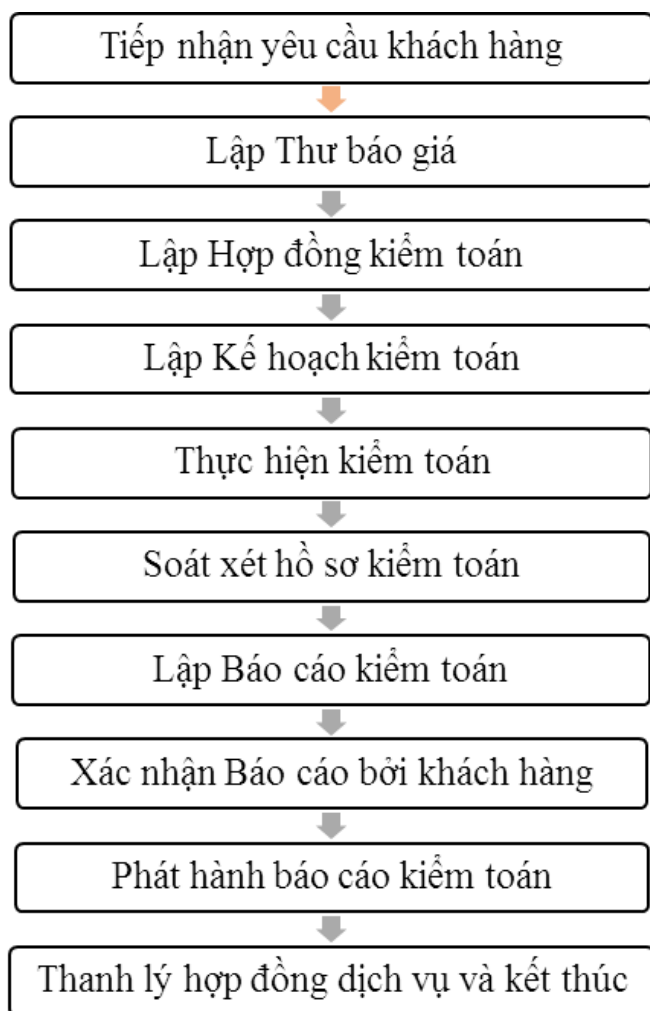
- Địa chỉ: 89 Phạm Văn Bạch, P. Hòa Cường Nam, Q. Hải Châu, Tp. Đà Nẵng.

3. Cơ cấu tổ chức và quá trình cung cấp dịch vụ chính của doanh nghiệp:

3.1. Cơ cấu tổ chức



3.2. Lưu đồ quá trình cung cấp dịch vụ chính (dịch vụ kiểm toán)



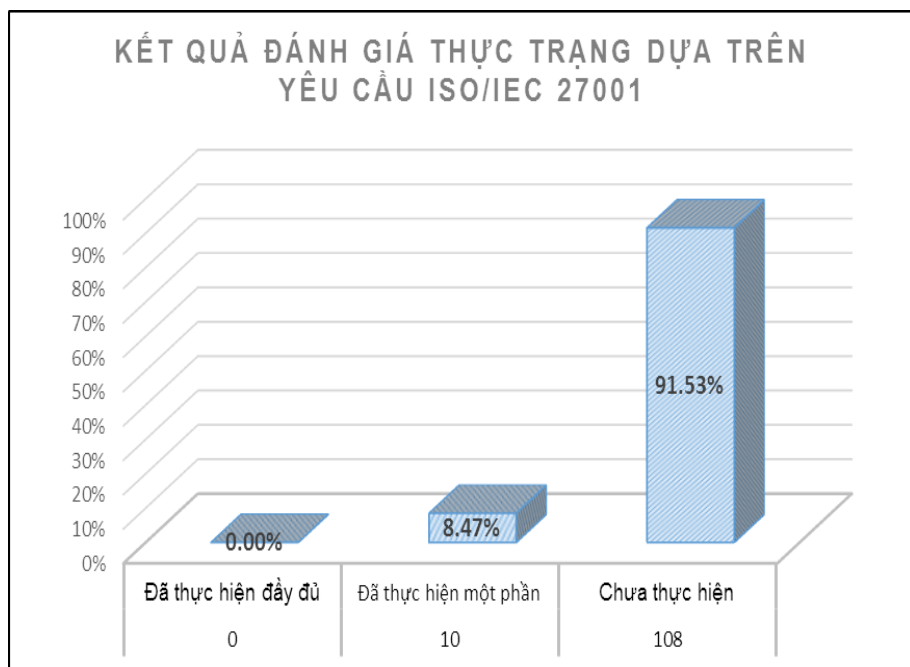
4. Hiện trạng đáp ứng yêu cầu đảm bảo ATTT trước khi áp dụng ISO/IEC 27001

- Lãnh đạo Chi nhánh đã có sự quan tâm nhất định đến vấn đề đảm bảo an toàn thông tin trong quá trình cung cấp dịch vụ kiểm toán (báo cáo tài chính, xây dựng cơ bản), vừa để đảm bảo đáp ứng các yêu cầu của khách hàng sử dụng dịch vụ kiểm toán, lẫn đáp ứng các yêu

cầu của pháp luật liên quan đến loại dịch vụ này. Tuy nhiên, do chưa có phương pháp tiếp cận bài bản, có tính hệ thống, nên Chi nhánh vẫn có nguy cơ đối diện với các rủi ro có thể phương hại đến các tài sản thông tin của khách hàng và của Chi nhánh.

- Các rủi ro về an toàn thông tin đối với hoạt động dịch vụ kiểm toán của Chi nhánh tập trung chủ yếu đối với các loại tài sản thông tin của Chi nhánh để triển khai dịch vụ (ví dụ: cơ sở dữ liệu khách hàng; các quy trình nghiệp vụ và kiểm soát nội bộ; các thiết bị ICT như máy tính; các ổ ghi lưu dữ liệu; ...), các thông tin của khách hàng sử dụng dịch vụ kiểm toán mà Chi nhánh có cơ hội tiếp cận trong quá trình cung cấp dịch vụ (được xem là tài sản của khách hàng) mà Chi nhánh có trách nhiệm, nghĩa vụ pháp lý phải tuân thủ thông qua hợp đồng theo quy định của pháp luật. Việc để xảy ra các rủi ro gây ảnh hưởng đến tính bảo mật, toàn vẹn và sẵn có đối với các tài sản thông tin của Chi nhánh lẫn của khách hàng đều có thể gây thiệt hại về kinh doanh cho Chi nhánh, có thể dẫn tới vi phạm hợp đồng và khi nghiêm trọng thì có thể vi phạm pháp luật và gây tổn thất hình ảnh, uy tín của Chi nhánh.

- Đối chiếu với các yêu cầu của tiêu chuẩn ISO/IEC 27001, mức độ đáp ứng của Chi nhánh là thấp (đáp ứng đầy đủ yêu cầu: 0%; đáp ứng một phần: 8,477%, chưa đáp ứng: 91,53% tính trên tổng số 118 hạng mục/ yêu cầu của tiêu chuẩn).



5. Kết quả cải thiện mức độ đáp ứng về đảm bảo ATTT sau khi áp dụng ISO/IEC 27001:

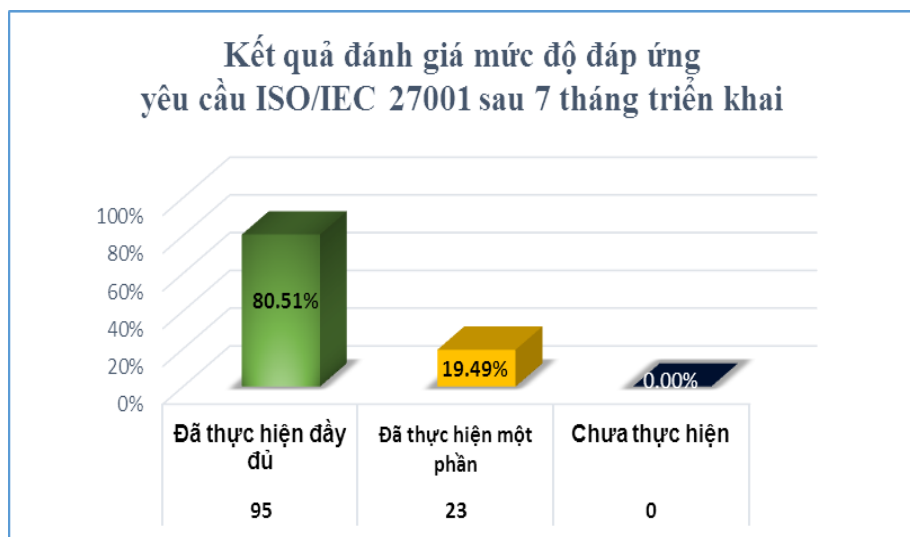
- Sự cải thiện rõ rệt về nhận thức của lãnh đạo và CBNV Chi nhánh đối với yêu cầu bảo vệ Tính bảo mật, Tính toàn vẹn và Tính sẵn có (C-I-A) của các tài sản thông tin của doanh nghiệp và của khách hàng sử dụng dịch vụ kiểm toán, từ đó làm nền tảng cho việc công bố và thực thi các cam kết của lãnh đạo doanh nghiệp, nhằm huy động các nguồn lực cần thiết để thực hiện các quá trình quản lý, các biện pháp kiểm soát về an toàn thông tin được xác định trong hệ thống.

- Doanh nghiệp được trang bị phương pháp quản lý theo cách thức có hệ thống dựa trên tiêu chuẩn quốc tế ISO nói chung và ISO/IEC 27001 nói riêng để quản lý, điều hành hoạt động cung cấp dịch vụ của công ty theo cách chuyên nghiệp, bài bản dựa trên nguyên lý P-D-C-A, trong đó có việc xác định Chính sách, thiết lập Mục tiêu,

quá trình kiểm soát cần thiết để đảm bảo an toàn thông tin dựa trên phương pháp tiếp cận đánh giá rủi ro.

- Nâng cao các kết quả hoạt động của Chi nhánh đối với quá trình cung cấp dịch vụ; đảm bảo tính liên tục của quá trình kinh doanh; phòng ngừa và giảm thiểu các rủi ro mất an toàn thông tin, tạo được lòng tin cho khách hàng và đối tác; duy trì sự tuân thủ theo các yêu cầu của pháp luật về đảm bảo an toàn thông tin được áp dụng đối với doanh nghiệp.

- Sau khi hoàn thành các hoạt động đánh giá nội bộ, thực hiện hành động khắc phục, xem xét của lãnh đạo về hệ thống ISMS: mức độ đáp ứng yêu cầu tiêu chuẩn được cải thiện đáng kể so với thời điểm chưa triển khai mô hình (đáp ứng đầy đủ yêu cầu: 80,51 % ; đáp ứng một phần: 19,49%, chưa đáp ứng: 0% trong tổng số 118 hạng mục/ yêu cầu của tiêu chuẩn):



Chương 2

MỘT SỐ NHẬN ĐỊNH VÀ BÀI HỌC ĐƯỢC RÚT RA TỪ 2 MÔ HÌNH THỬ NGHIỆM

1. Không có giới hạn về phạm vi, đối tượng doanh nghiệp khi áp dụng tiêu chuẩn ISO/IEC 27001 để quản lý các rủi ro về ATTT:

• Điều này được minh chứng bởi sự gia tăng về số lượng cũng như tầm ảnh hưởng ngày càng nhiều của các ứng dụng, cả phần cứng lẫn phần mềm và mạng internet vào các hoạt động sản xuất, kinh doanh cung cấp dịch vụ của doanh nghiệp, bất kể doanh nghiệp hoạt động trong lĩnh vực nào. Khi doanh nghiệp càng phát triển, quy mô và phạm vi thị trường càng lớn thì số lượng các tài sản thông tin (của doanh nghiệp, khách hàng, đối tác) theo đó cũng ngày càng nhiều hơn, đa dạng hơn và có liên quan đến nhiều quá trình khác nhau trong doanh nghiệp để đáp ứng các yêu cầu của khách hàng lẫn yêu cầu quản lý điều hành trong nội bộ doanh nghiệp. Việc này cũng đồng nghĩa với việc các tài sản đó sẽ đối diện với nhiều rủi ro, mối đe dọa có thể khai thác các điểm yếu của chúng, gây phương hại đến các đặc tính C-I-A của tài sản thông tin. Nếu bị ảnh hưởng ở mức độ nghiêm trọng, có thể dẫn tới gián đoạn kinh doanh, ảnh hưởng xấu đến uy tín, thương hiệu, thậm chí có thể dẫn đến sự vi phạm quy định của pháp luật.

• Do đó, khi doanh nghiệp có nhận thức đúng về mục đích, ý nghĩa, tính cần thiết của việc nhận biết và bảo vệ các tài sản thông tin, từ đó xác định cách tiếp cận, thực hiện, vận hành, duy trì và cải tiến thường xuyên một hệ thống quản lý an toàn thông tin theo ISO/IEC 27001 sẽ mang lại nhiều lợi ích trực tiếp cho chính doanh nghiệp, khách hàng, đối tác kinh doanh của họ. Khi có nhiều doanh nghiệp

thực hiện điều đó, sẽ mang lại tác động tích cực cho cả xã hội trong kỷ nguyên công nghệ thông tin.

- Mặc dù vậy, do đặc thù của các yêu cầu tiêu chuẩn ISO/IEC 27001, trong đó có nhiều yêu cầu mà để đáp ứng được đầy đủ, thực sự cần đến nguồn nhân lực tại chỗ, có năng lực thích hợp về công nghệ thông tin (IT) và được phân công chuyên trách về đảm bảo an toàn thông tin trong toàn doanh nghiệp. Đây lại là một điều kiện mà không phải doanh nghiệp có quy mô vừa và nhỏ nào cũng dễ dàng đáp ứng được.

2. Sự cam kết của lãnh đạo doanh nghiệp là yếu tố quyết định đến hiệu lực, hiệu quả kiểm soát ATTT của hệ thống ISMS:

- Mỗi khi lãnh đạo cấp cao nhất của doanh nghiệp hiểu đúng được mục đích của ISO/IEC 27001, họ mới cam kết, cung cấp các nguồn lực cần thiết, nhất là nguồn nhân lực có năng lực thích hợp để thiết lập, thực hiện, cải tiến hệ thống để đạt được lợi ích thiết thực cuối cùng. Sự tham gia của cấp lãnh đạo trong mọi giai đoạn triển khai ISO/IEC 27001, kể cả trực tiếp tham dự các khóa đào tạo, tập huấn về ISO/IEC 27001; đến giai đoạn xem xét, phê duyệt, ban hành tài liệu; giai đoạn đánh giá, xem xét hệ thống quản lý sẽ tạo được động lực, nhận thức cho cán bộ, nhân viên và thu hút họ tham gia có hiệu quả vào việc thiết lập, vận hành hệ thống.

3. Hiệu quả hoạt động của Ban điều hành triển khai ISO/IEC 27001:

- Đây là nhóm nòng cốt để giúp lãnh đạo doanh nghiệp tổ chức thực hiện đầy đủ, chính xác, đúng tiến độ tất cả các giai đoạn triển khai hệ thống theo kế hoạch đã định. Đối với doanh nghiệp quy mô nhỏ, Trưởng ban có thể chính là lãnh đạo cao nhất của doanh nghiệp để việc điều hành được hiệu quả, trực tiếp. Với các doanh nghiệp quy mô vừa hoặc lớn, Trưởng ban cũng phải là thành viên trong Ban lãnh đạo của doanh nghiệp để đủ thẩm quyền, quyền hạn, trách nhiệm để

chỉ đạo quá trình thực hiện và huy động được các nguồn lực cần thiết. Trong thành phần của Ban ISO/IEC 27001 cũng cần có đại diện của các đơn vị, bộ phận trực tiếp chịu trách nhiệm đối với các quá trình kinh doanh lẫn quá trình hỗ trợ trong doanh nghiệp thuộc phạm vi/ranh giới thực hiện ISMS để đảm bảo nhận diện đầy đủ các tài sản thông tin cần được bảo vệ, các rủi ro liên quan, cũng như làm đầu mối tổ chức thực hiện các chính sách về an toàn thông tin, các quá trình, các biện pháp kiểm soát an toàn thông tin được hệ thống quy định. Đặc biệt, việc có sẵn nhân sự tại chỗ được phân công chuyên trách về công nghệ thông tin và kiến thức nhất định về đảm bảo an toàn thông tin đối với các quá trình kinh doanh của doanh nghiệp tham gia vào Ban ISO/IEC 27001 là một điều kiện thuận lợi để tham mưu cho lãnh đạo doanh nghiệp về các vấn đề thuộc lĩnh vực này. Trường hợp không có sẵn nguồn nhân lực này, doanh nghiệp vẫn có thể sử dụng nguồn lực ở bên ngoài với cơ chế kiểm soát thích hợp để hỗ trợ, tư vấn cho doanh nghiệp triển khai xây dựng, áp dụng hệ thống ISMS.

4. Vấn đề đảm bảo thực thi quyền sở hữu trí tuệ (Intellectual property rights - IPR):

- Việc thiết lập, thực hiện các thủ tục thích hợp để đảm bảo tuân thủ theo các yêu cầu của pháp luật, chế định và các ràng buộc hợp đồng liên quan đến việc sử dụng các tài liệu, sản phẩm phần mềm có yêu cầu IPR được xem là một biện pháp kiểm soát theo yêu cầu ISO/IEC 27001:2013 mà tổ chức thực hiện ISMS phải áp dụng (Mục A.18.1.2 - Quyền sở hữu trí tuệ, theo Phụ lục A của ISO/IEC 27001:2013).

- Thực trạng ở Việt Nam, không phải tổ chức, doanh nghiệp nào cũng đáp ứng đầy đủ yêu cầu này, đặc biệt là các doanh nghiệp có quy mô vừa, nhỏ hoặc rất nhỏ khi trang bị, khai thác các phần mềm hệ điều hành cho máy tính, các phần mềm ứng dụng có yêu cầu bản quyền hợp pháp. Việc vượt qua được thách thức này để đáp ứng đầy

đủ yêu cầu ISO/IEC 27001 sẽ đòi hỏi sự nỗ lực của nhiều bên liên quan, gồm cơ quan quản lý nhà nước về IPR trong việc đảm bảo pháp luật về sở hữu trí tuệ được thực thi, của chính doanh nghiệp thực hiện ISMS để nhận thức được trách nhiệm và lợi ích khi khai thác các phần mềm hợp pháp, và cả áp lực từ phía khách hàng, đối tác kinh doanh của doanh nghiệp.

- Việc từng bước trang bị và sử dụng các phần mềm có bản quyền hợp pháp đối với các thiết bị, hệ thống thông tin, một mặt sẽ giúp tổ chức, doanh nghiệp đáp ứng được yêu cầu của luật pháp liên quan đến IPR mà Việt Nam đã ký kết thông qua các Hiệp định song phương, đa phương; đáp ứng yêu cầu về IPR khi thực hiện tiêu chuẩn ISO/IEC 27001, thì đồng thời điều này cũng sẽ trực tiếp mang lại lợi ích về an toàn thông tin cho chính các tài sản thông tin của doanh nghiệp, đảm bảo tính kinh doanh liên tục (Business Continuity) trước các mối đe dọa an toàn thông tin ngày càng nguy hiểm, có động cơ rõ ràng và tốc độ lây lan nhanh chóng như virus máy tính, các mã độc, phần mềm gián điệp..

CÁC PHỤ LỤC

Phụ lục 1: Mẫu Quyết định thành lập Ban điều hành triển khai ISMS theo ISO/IEC 27001:2013 tại doanh nghiệp

CÔNG TY ABC

CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM

Độc lập - Tự do - Hạnh phúc

Số: , ngày tháng năm

QUYẾT ĐỊNH

**V/v: Thành lập Ban điều hành Dự án xây dựng và áp dụng
Hệ thống quản lý an toàn thông tin theo tiêu chuẩn
ISO/IEC 27001:2013**

GIÁM ĐỐC CÔNG TY ABC

Căn cứ Điều lệ tổ chức và hoạt động của Công ty ABC, ban hành theo Quyết định số

Căn cứ yêu cầu của tiêu chuẩn quốc tế về hệ thống quản lý an toàn thông tin theo ISO/IEC 27001:2013 - Điều 5: Sự lãnh đạo;

Theo đề nghị của,

QUYẾT ĐỊNH:

Điều 1. Thành lập Ban điều hành dự án xây dựng và áp dụng Hệ thống quản lý an toàn thông tin theo ISO/IEC 27001 của Công ty ABC (sau đây gọi tắt là Ban ISO/IEC 27001), gồm các ông/ bà có tên

sau đây:

1. Ông: Giám đốc - Trưởng ban điều hành;
2. Ông: Phó Giám đốc - Phó Trưởng ban thường trực/ Đại diện Lãnh đạo về An toàn thông tin;
3. Ông: - Ủy viên thường trực;
4. Bà:..... - Ủy viên.

....

Điều 2. Ban điều hành dự án có nhiệm vụ, quyền hạn chung như sau:

- Tham mưu cho Giám đốc quyết định phạm vi, ranh giới thích hợp cho hệ thống an toàn thông tin phù hợp với đặc điểm sản xuất - kinh doanh, cơ cấu tổ chức, địa điểm áp dụng, các tài sản thông tin và công nghệ trong phạm vi áp dụng;

- Phối hợp với các chuyên gia tư vấn lập và thống nhất kế hoạch xây dựng hệ thống tài liệu; trực tiếp phổ biến, đào tạo phương pháp áp dụng các tài liệu của hệ thống quản lý an toàn thông tin theo ISO/IEC 27001 cho những người có trách nhiệm liên quan (kể cả nhân viên trong nội bộ và các bên liên quan bên ngoài khi cần);

- Chủ trì, trực tiếp hoặc phân công trách nhiệm biên soạn các tài liệu của hệ thống quản lý an toàn thông tin theo yêu cầu của ISO/IEC 27001;

- Chủ trì phân công, huy động nguồn lực cần thiết và điều hành để thực hiện quá trình phân loại tài sản thông tin và đánh giá rủi ro an toàn thông tin đối với các tài sản thông tin thuộc phạm vi của hệ thống quản lý ISO/IEC 27001;

- Phối hợp chặt chẽ với các chuyên gia tư vấn trong suốt quá trình triển khai áp dụng;

- Được phép sử dụng và điều động nhân lực ở các đơn vị thuộc

phạm vi triển khai trong quá trình thực hiện nhiệm vụ;

- Trưởng ban điều hành có quyền áp dụng các biện pháp khen thưởng, các hình thức kỷ luật cần thiết để đảm bảo tiến độ và chất lượng công việc theo yêu cầu, kế hoạch triển khai;

- Phó Trưởng ban thường trực chịu trách nhiệm phân công nhiệm vụ cụ thể cho các ủy viên để đảm bảo kế hoạch xây dựng, áp dụng ISO/IEC 27001 được tổ chức thực hiện đúng tiến độ, có chất lượng.

Điều 3. Các Ông/ Bà trong công ty và các ông bà có tên tại Điều 1 căn cứ quyết định thi hành.

Quyết định này có hiệu lực kể từ ngày ký.

Nơi nhận:

- Như điều 3;
- Lưu ...

GIÁM ĐỐC

Phụ lục 2: Mẫu Quyết định phân công vai trò Lãnh đạo an toàn thông tin theo ISO/IEC 27001:2013 tại doanh nghiệp

CÔNG TY ABC CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM
Độc lập - Tự do - Hạnh phúc

Số:/..... , ngày tháng năm 201...

QUYẾT ĐỊNH

**V/v: Phân công trách nhiệm Đại diện Lãnh đạo về
an toàn thông tin theo ISO/IEC 27001**

GIÁM ĐỐC CÔNG TY ABC

Căn cứ Điều lệ tổ chức và hoạt động của Công ty ABC, theo Quyết định số....;

Căn cứ yêu cầu của tiêu chuẩn quốc tế về hệ thống quản lý an toàn thông tin ISO/IEC 27001 (điều khoản 5.3);

Theo đề nghị của,

QUYẾT ĐỊNH:

Điều 1. Phân công Ông/Bà ZZZ - vai trò Đại diện lãnh đạo về an toàn thông tin (Information Security Management System) theo ISO/IEC 27001.

Điều 2. Ông/Bà ZZZ có nhiệm vụ, quyền hạn sau:

- Chuẩn bị đầy đủ các điều kiện cần thiết để hệ thống quản lý an toàn thông tin được thiết lập, thực hiện, duy trì theo đúng các yêu cầu của tiêu chuẩn ISO/IEC 27001.

- Định kỳ hoặc đột xuất báo cáo trực tiếp cho Giám đốc Công ty ABC biết về kết quả hoạt động của hệ thống quản lý an toàn thông tin, mọi nhu cầu cải tiến và đề xuất việc cung cấp nguồn lực cho hoạt động, thực hiện các biện pháp kiểm soát rủi ro an toàn thông tin.

- Đảm bảo thực hiện các biện pháp cần thiết để thúc đẩy các đơn vị, trong Công ty nhận thức được đầy đủ các nhu cầu và mong đợi của các bên quan tâm, yêu cầu của pháp luật, cũng như các quy định thuộc hệ thống quản lý an toàn thông tin của Công ty.

- Đại diện cho lãnh đạo công ty trao đổi thông tin với các tổ chức bên ngoài các vấn đề về an toàn thông tin, kể cả với tổ chức chứng nhận hệ thống quản lý an toàn thông tin.

- Có quyền đề nghị Giám đốc Công ty ABC thực hiện các quyết định cần thiết để nâng cao hiệu lực và hiệu quả thực hiện các quy định trong hệ thống quản lý an toàn thông tin.

Điều 3. Các Ông/ Bà Trưởng/phó các đơn vị, bộ phận trong Công ty ABC và các Ông/Bà có tên ở Điều 1 căn cứ quyết định thi hành.căn cứ quyết định thi hành.

Quyết định này có hiệu lực kể từ ngày ký.

Nơi nhận:

- Như Điều 3;
- Lưu

GIÁM ĐỐC

Phụ lục 3: Mẫu Quyết định thành lập Tổ thư ký ISO/IEC 27001:2013

CÔNG TY ABC

CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM

Độc lập - Tự do - Hạnh phúc

Số: , ngày tháng năm 201.....

QUYẾT ĐỊNH

**V/v: Thành lập Tổ Thư ký dự án xây dựng và áp dụng
Hệ thống hệ thống quản lý an toàn thông tin theo yêu cầu
của ISO/IEC 27001**

GIÁM ĐỐC CÔNG TY ABC

Căn cứ Điều lệ tổ chức và hoạt động của Công ty, ban hành theo Quyết định;

Căn cứ yêu cầu của tiêu chuẩn quốc tế về hệ thống quản lý an toàn thông tin theo ISO/IEC 27001:2013 - Điều 5: Sự lãnh đạo;

Theo đề nghị của Phó Trưởng ban thường trực - Ban điều hành xây dựng và áp dụng Hệ thống quản lý an toàn thông tin theo ISO/IEC 27001,

QUYẾT ĐỊNH:

Điều 1. Thành lập Tổ Thư ký dự án xây dựng và áp dụng Hệ thống hệ thống quản lý an toàn thông tin theo yêu cầu của ISO/IEC 27001 (sau đây gọi tắt là Tổ Thư ký ISO/IEC 27001), gồm các Ông/Bà có tên sau đây:

1. Ông: - Tổ trưởng Tổ Thư ký ISO/IEC 27001;
2. Ông: -..... - Thư ký ISO/IEC 27001.....

Điều 2. Tổ Thư ký ISO/IEC 27001 có nhiệm vụ, quyền hạn sau:

- Làm đầu mối tập hợp, theo dõi, kiểm soát tiến độ viết và hoàn chỉnh các tài liệu do các đơn vị trong công ty biên soạn thuộc hệ thống quản lý an toàn thông tin, trình Giám đốc phê duyệt ban hành theo đúng kế hoạch tổng thể của dự án;

- Đầu mối quản lý, kiểm soát việc phát hành, phân phối tài liệu, lưu trữ các hồ sơ thuộc hệ thống quản lý an toàn thông tin theo yêu cầu của ISO/IEC 27001;

- Trực tiếp tham gia quá trình thiết lập hệ thống tài liệu quản lý an toàn thông tin theo yêu cầu của ISO/IEC 27001, theo phân công của Ban điều hành ISO/IEC 27001;

- Được quyền yêu cầu các cá nhân, đơn vị thực hiện việc áp dụng và duy trì hệ thống quản lý hệ thống an toàn thông tin theo yêu cầu của ISO/IEC 27001 và kịp thời kiến nghị các biện pháp thích hợp đến Giám đốc Công ty để xem xét quyết định nhằm tăng cường hiệu lực, hiệu quả công việc trong phạm vi dự án;

- Trong quá trình hoạt động, Thư ký ISO/IEC 27001 chịu sự chỉ đạo và điều hành trực tiếp của Phó Trưởng ban thường trực Ban điều hành ISO/IEC 27001.

Điều 3. Các ông/bà có tên ở Điều 1 căn cứ quyết định thi hành.

Quyết định này có hiệu lực kể từ ngày ký.

Nơi nhận:

Phụ lục 4: Báo cáo đánh giá thực trạng mức độ đáp ứng yêu cầu ISO/IEC 27001:2013 (Gap analysis)

Bảng kết quả khảo sát thực trạng hệ thống quản lý an toàn thông tin / ISMS theo yêu cầu của ISO/IEC 27001:2013		
Doanh nghiệp: Công ty ABC Phạm vi địa điểm áp dụng ISMS: số 123, đường, Phường, TP. Lĩnh vực áp dụng ISO/IEC 27001: Đảm bảo an toàn thông tin trong quá trình sản xuất, kinh doanh sản phẩm ABC và dịch vụ XYZ Ngày khảo sát thực trạng: .../.../2018		
Cột Mối của ISO/IEC 27001 :2013	Các yêu cầu bắt buộc đối với hệ thống ISMS	Tình trạng
4	Bối cảnh của tổ chức	
4.1	Hiểu về tổ chức và bối cảnh của tổ chức	
	Tổ chức phải xác định các vấn đề bên ngoài và nội bộ có liên quan đến mục đích của tổ chức và có ảnh hưởng đến khả năng đạt được kết quả mong muốn của hệ thống quản lý an toàn thông tin của tổ chức.	Chưa thực hiện
4.2	Hiểu nhu cầu và mong đợi của các bên quan tâm	
	Tổ chức phải xác định:	
	a) các bên quan tâm có liên quan đến hệ thống quản lý an toàn thông tin; và	Chưa thực hiện
	b) các yêu cầu của các bên quan tâm liên quan đến an toàn thông tin.	Chưa thực hiện
4.3	Xác định phạm vi của hệ thống quản lý an toàn thông tin	
	Tổ chức phải xác định ranh giới và phạm vi áp dụng hệ thống quản lý an toàn thông tin để thiết lập phạm vi của nó.	Chưa thực hiện
	Khi xác định phạm vi này, tổ chức phải xem xét:	Chưa thực hiện
	a) các vấn đề bên ngoài và nội bộ được đề cập trong 4.1;	Chưa thực hiện
	b) các yêu cầu nêu trong 4.2; và	Chưa thực hiện
	c) giao diện và những phụ thuộc giữa các hoạt động được thực hiện bởi tổ chức, và các hoạt động được thực hiện bởi các tổ chức khác.	Chưa thực hiện
5	Sự lãnh đạo	
5.1	Sự lãnh đạo và sự cam kết	
	Lãnh đạo cao nhất phải chứng tỏ sự lãnh đạo và sự cam kết liên quan đến hệ thống quản lý an toàn thông tin bằng cách:	Đã thực hiện một phần
	a) đảm bảo chính sách an toàn thông tin và các mục tiêu an toàn thông tin được thiết lập và tương thích với định hướng chiến lược của tổ chức;	Chưa thực hiện
	b) đảm bảo sự tích hợp các yêu cầu hệ thống quản lý an toàn thông tin vào các quá trình của tổ chức;	Đã thực hiện một phần
	c) đảm bảo rằng các nguồn lực cần thiết cho hệ thống quản lý an toàn thông tin sẵn có;	Đã thực hiện một phần
	d) truyền đạt tầm quan trọng của quản lý an toàn thông tin có hiệu lực và của sự phù hợp với các yêu cầu hệ thống quản lý an toàn thông tin;	Đã thực hiện một phần
	e) đảm bảo hệ thống quản lý an toàn thông tin đạt được (các) kết quả như dự kiến;	Đã thực hiện một phần
	f) chỉ đạo và hỗ trợ con người để đóng góp vào tính hiệu lực của hệ thống quản lý an toàn thông tin;	Đã thực hiện một phần
	g) thúc đẩy cải tiến liên tục, và	Đã thực hiện một phần
	h) hỗ trợ vai trò quản lý khác có liên quan để chứng tỏ vai trò lãnh đạo của họ khi hệ thống áp dụng trong các phạm vi thuộc trách nhiệm.	Đã thực hiện một phần

**Bảng kết quả khảo sát thực trạng hệ thống quản lý an toàn thông tin / ISMS
theo yêu cầu của ISO/IEC 27001:2013**

Doanh nghiệp: Công ty ABC

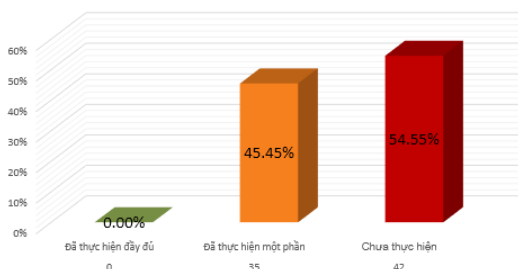
Phạm vi/ địa điểm áp dụng ISMS: số 123, đường ..., Phường ..., TP.

Lĩnh vực áp dụng ISO/IEC 27001: Đảm bảo an toàn thông tin trong quá trình sản xuất, kinh doanh sản phẩm ABC và dịch vụ XYZ

Ngày khảo sát thực trạng: .../.../2018

Đã khảo sát ISO/IEC 27001 2013	Các yêu cầu bắt buộc đối với hệ thống ISMS	Tình trạng
0	Đã thực hiện đầy đủ	0.00%
35	Đã thực hiện một phần	45.45%
42	Chưa thực hiện	54.55%
77	Tổng số	

**Kết quả khảo sát thực trạng về đảm bảo ATTT
dựa trên yêu cầu ISO/IEC 27001:2013**



Phụ lục 5: Phạm vi áp dụng ISMS (ví dụ minh họa)

BẢNG XÁC ĐỊNH PHẠM VI CỦA HỆ THỐNG QUẢN LÝ AN TOÀN THÔNG TIN THEO ISO/IEC 27001:2013			
Tên tổ chức:	CÔNG TY ABC		
Lĩnh vực sản xuất - kinh doanh chính:	Đảm bảo an toàn thông tin đối với các quá trình kinh doanh chính sau đây: (1) Sản xuất, kinh doanh sản phẩm ABC; (2) Cung cấp dịch vụ XYZ.		
Lĩnh vực, phạm vi áp dụng ISMS theo ISO/IEC 27001:2013:	Áp dụng tại: (1) Văn phòng quản lý điều hành của công ty tại trụ sở chính địa điểm: số 123, đường, Quận ..., Thành phố.....; và (2) Nhà máy sản xuất sản phẩm ABC, tại địa chỉ:; và (3) Trạm dịch vụ XYZ, tại địa chỉ: • Phạm vi của hệ thống ISMS được thiết lập, thực hiện phù hợp với bản Tuyên bố việc áp dụng (SoA), lần ban hành số; ngày/.../.....		
<i>Phê duyệt ngày:</i>			<i>Lập ngày:</i>
GIÁM ĐỐC		ĐẠI DIỆN LÃNH ĐẠO AN TOÀN THÔNG TIN	

Phụ lục 6: Kế hoạch xây dựng hệ thống thông tin dạng văn bản ISMS theo ISO/IEC 27001:2013
(trích lược)

**KẾ HOẠCH XÂY DỰNG HỆ THỐNG THÔNG TIN DẠNG VĂN BẢN
QUẢN LÝ AN TOÀN THÔNG TIN THEO ISO/IEC 27001:2013**

Doanh nghiệp: Công ty ABC

Phạm vi/ địa điểm áp dụng ISMS: số 123, đường, Quận....., TP.

Mục tiêu hoàn thành giai đoạn xây dựng văn bản & ĐGRR-ATTT:

từ:

đến:

STT	Tên thông tin dạng văn bản cần thiết lập trong hệ thống quản lý ATTT	Yêu cầu ISO/IEC 27001: 2013	Mã hiệu tài liệu	Phân loại tình trạng tài liệu	Trách nhiệm chủ trì biên soạn tài liệu	Theo dõi tiến độ (x)				Ngày hoàn thành dự kiến	Ngày hoàn thành thực tế
						HD	XXI	XX2	III		
A	Nhóm hệ thống văn bản chung:										
1	Văn bản xác định bối cảnh ATTT	4.1		Xây dựng mới	Ban ISO/IEC 27001						
2	Văn bản xác định nhu cầu, mong đợi của các bên quan tâm về ATTT	4.2		Xây dựng mới	Ban ISO/IEC 27001						
3	Phạm vi của hệ thống quản lý ATTT	4.3		Xây dựng mới	Thư ký ISO/IEC 27001						
4	Quy định các vai trò, trách nhiệm, quyền hạn về ATTT	5.3		Xây dựng mới	Ban ISO/IEC 27001						
5	QĐ phân công Lãnh đạo ATTT	5.3		Xây dựng mới							
6	Chính sách an toàn thông tin	5.2		Xây dựng mới							
7	Mục tiêu ATTT năm YYYY (công ty và đơn vị)	6.2		Xây dựng mới							
8	Kế hoạch thực hiện mục tiêu ATTT năm YYYY (đơn vị)	6.2		Xây dựng mới							
9	Quy trình kiểm kê, phân loại, gán nhãn tài sản thông tin	6.1; A.8.2 PL-A		Xây dựng mới							
10	Hồ sơ kết quả thực hiện QT kiểm kê, phân loại và gán nhãn tài sản thông tin	6.1		Hồ sơ thực hiện							
11	Quy trình ĐGRR - ATTT	6.1		Xây dựng mới							
12	Hồ sơ kết quả thực hiện Quy trình ĐGRR -ATTT	6.1		Hồ sơ thực hiện							
13	Thông báo áp dụng (Statement of Applicability – SoA)	6.1.3	SoA	Xây dựng mới							

STT	Tên thông tin dạng văn bản cần thiết lập trong hệ thống quản lý ATTT	Yêu cầu ISO/IEC 27001: 2013	Mã hiệu tài liệu	Phân loại tình trạng tài liệu	Trách nhiệm chủ trì biên soạn tài liệu	Theo dõi tiến độ (x)				Ngày hoàn thành dự kiến	Ngày hoàn thành thực tế
						MD	XX1	XX2	BI		
14	Kế hoạch xử lý rủi ro (Risk Treatment Plan – RTP)	6.1.3	RTP	Xây dựng mới							
15	Kế hoạch đảm bảo tính liên tục kinh doanh (Business Continuity Plan)	A.17-PLA	BCP	Xây dựng mới							
16	Quy trình kiểm soát tài liệu	7.5		Đã có sẵn-có thể khai thác							
17	Quy trình kiểm soát hồ sơ	7.5		Đã có sẵn-có thể khai thác							
18	Quy trình đánh giá nội bộ	9.2		Đã có sẵn-có thể khai thác							
19	Quy trình xử lý sự KPH và hành động khắc phục, phòng ngừa	10.1		Đã có sẵn-có thể khai thác							
20	Quy trình xem xét của lãnh đạo	9.3		Đã có sẵn-có thể khai thác							
21	Quy trình đo lường hiệu lực của hệ thống quản lý ATTT và các biện pháp kiểm soát	6.1.1; 9.1		Xây dựng mới							
B	Nhóm các quy định, chính sách, thủ tục về đảm bảo ATTT cụ thể										
1	Chính sách sử dụng phương tiện ICT cá nhân	A.6.2-PLA		Xây dựng mới							
2	Chính sách sử dụng thiết bị di động và làm việc từ xa	A.6.2-PLA		Xây dựng mới							
3	Chính sách sử dụng email	A.13.2-PLA		Xây dựng mới							
4	Chính sách sử dụng mạng xã hội	A.13-PLA		Xây dựng mới							

13	Quy định sử dụng hệ thống camera bảo vệ tại các khu vực làm việc			Xây dựng mới						
14	Thỏa ước lao động tập thể			Đã có sẵn-có thể khai thác						
15	Nội quy cơ quan			Đã có sẵn-có thể khai thác						
16	Quy định kiểm soát phương tiện PCCC	A.11.1-PLA		Đã có sẵn-có thể khai thác						
17	Quy định thực thiện công tác sửa chữa lớn tài sản cố định và quản lý công cụ dụng cụ	A.8-PLA		Đã có sẵn-có thể khai thác						
18	Thế thức và kỹ thuật trình bày văn bản			Đã có sẵn-có thể khai thác						
19	Kiểm tra, bảo trì thiết bị truyền dẫn			Xây dựng mới						
20	Kiểm tra, bảo trì thiết bị ghi lưu thoại			Xây dựng mới						

Ngày phê duyệt:

**TRƯỞNG BAN ĐIỀU HÀNH
ISO/IEC 27001**

Ngày kiểm tra:

**PHÓ TRƯỞNG BAN
THƯỜNG TRỰC BAN ISO/IEC 27001/
LÃNH ĐẠO AN TOÀN THÔNG TIN**

Ngày lập:

Tổ trưởng Thư ký ISO/IEC 27001

Phụ lục 7: Chính sách an toàn thông tin (ví dụ minh họa)

CHÍNH SÁCH AN TOÀN THÔNG TIN CỦA CÔNG TY ABC

A. MỤC ĐÍCH VÀ YÊU CẦU:

1. Chính sách an toàn thông tin này nhằm định hướng và đưa ra các cam kết đối với việc thực hiện các biện pháp kiểm soát rủi ro, nhằm bảo vệ các tài sản thông tin của Công ty, của khách hàng và các bên quan tâm khỏi các mối đe dọa từ nội bộ, bên ngoài do cố ý hay vô tình trong quá trình sản xuất - kinh doanh dịch vụ XYZ của công ty ABC

2. Chính sách này đảm bảo rằng:

- a) Thông tin sẽ được bảo vệ để chống lại việc truy cập trái phép.
- b) Tính bảo mật (Confidentiality) của thông tin sẽ được đảm bảo.
- c) Tính toàn vẹn (Integrity) của thông tin sẽ được duy trì.
- d) Tính sẵn có (Availability) của thông tin đối với các quá trình kinh doanh sẽ được duy trì.
- e) Các yêu cầu pháp luật và chế định, ràng buộc hợp đồng với khách hàng sẽ được đáp ứng.
- f) Các Kế hoạch đảm bảo tính liên tục của kinh doanh sẽ được thiết lập, duy trì và thử nghiệm.
- g) Đảm bảo việc đào tạo về an toàn thông tin cho mọi nhân viên liên quan để nhân sự có đủ năng lực cần thiết tham gia thực hiện hệ thống quản lý an toàn thông tin có hiệu quả.
- h) Tất cả các lỗ hổng về an toàn thông tin thực tế hay nghi ngờ

sẽ được báo cáo đến Lãnh đạo an toàn thông tin của công ty và sẽ được điều tra kỹ lưỡng để phòng ngừa, ngăn chặn, xử lý một cách thỏa đáng, hiệu quả.

3. Các thủ tục và các chính sách an toàn cụ thể sẽ được thiết lập để hỗ trợ triển khai các cam kết trong Chính sách tổng thể này, bao gồm các mục tiêu kiểm soát và các biện pháp kiểm soát an toàn phù hợp với yêu cầu tiêu chuẩn ISO/IEC 27001 và tương thích với các kết quả đánh giá rủi ro an toàn thông tin của công ty.

4. Công ty sẽ duy trì và huy động sự tham gia đóng góp của tất cả cán bộ, nhân viên vào việc cải tiến liên tục hệ thống quản lý an toàn thông tin phù hợp tiêu chuẩn ISO/IEC 27001.

B. TRÁCH NHIỆM:

1. Giám đốc Công ty sẽ đảm bảo truyền đạt chính sách này để mọi cán bộ, nhân viên đều có nhận thức và tuân thủ.

2. Đại diện lãnh đạo an toàn thông tin chịu trách nhiệm hỗ trợ, tham mưu cho Giám đốc công ty trong quá trình hoạch định, triển khai chính sách.

3. Tất cả các trưởng đơn vị/ bộ phận trong công ty trực tiếp chịu trách nhiệm tổ chức thực hiện chính sách này và đảm bảo sự tuân thủ của mọi nhân viên ở đơn vị/ bộ phận của mình.

4. Mỗi cán bộ, nhân viên phải có các trách nhiệm đối với an toàn thông tin và xem đây là một phần của công việc được giao.

5. Chính sách này được xem xét ít nhất hàng năm bởi Giám đốc công ty để đảm bảo luôn thích hợp.

Ngày tháng năm YYYY
GIÁM ĐỐC

Phụ lục 8: Bảng kiểm kê tài sản thông tin phục vụ cho đánh giá rủi ro ATTT (trích lược)

CÔNG TY ABC											
BẢNG KIỂM KÊ TÀI SẢN THÔNG TIN CẤP ĐƠN VỊ											
Đơn vị:		Phòng Tổ chức - Hành chính				Bộ phận:					
STT	Mã quá trình chức năng/ nghiệp vụ	Mô tả/ tên gọi của TSTT	Phân nhóm TSTT	Mã TSTT	C	I	A	C+I+A	Giá trị của TSTT	Bộ phận chịu trách nhiệm quản lý TSTT	Cá nhân được ủy quyền quản lý sử dụng TSTT
1	QL	Tài liệu nội bộ hiện hành thuộc các hệ thống quản lý đang được công ty áp dụng (ISO 9001, ISO/IEC 27001)	IF	TCHC.QL.IF.0001	3	3	3	9	3	TCHC	
2	QL	Hệ thống các công văn đi, đến trong Công ty	IF	TCHC.QL.IF.0002	3	3	3	9	3	TCHC	
3	HD	Thỏa thuận dịch vụ: mua sắm văn phòng phẩm, tạp phẩm,....	IF	TCHC.HD.IF.0001	2	1	1	4	1	TCHC	
4	NS	Hồ sơ khen thưởng, kỷ luật	IF	TCHC.NS.IF.0001	2	2	2	6	2	TCHC	
5	NS	Bảng tính lương	IF	TCHC.NS.IF.0002	3	3	3	9	3	TCHC	
6	NS	Hồ sơ tuyển dụng, hồ sơ nhân sự	IF	TCHC.NS.IF.0003	3	3	3	9	3	TCHC	
7	NS	Hồ sơ quy hoạch cán bộ	IF	TCHC.NS.IF.0004	3	3	3	9	3	TCHC	
8	NS	Hồ sơ đào tạo ngắn hạn (phục vụ cấp chứng chỉ, chứng nhận)	IF	TCHC.NS.IF.0005	1	2	2	5	2	TCHC	
9	NS	Hồ sơ thi nâng bậc, hồ sơ xét nâng lương	IF	TCHC.NS.IF.0006	3	2	2	7	3	TCHC	
10	IT	Phần mềm HRM	SW	TCHC.IT.SW.0001	2	2	2	6	2	TCHC	
11	IT	Phần mềm ERP	SW	TCHC.IT.SW.0002	2	2	2	6	2	TCHC	
12	VT	03 máy tính xách tay phục vụ công tác quản lý	HW	TCHC.VT.HW.0001	1	2	2	5	2	TCHC	
13	VT	01 máy tính xách tay phục vụ công tác đoàn thể	HW	TCHC.VT.HW.0002	1	2	2	5	2	TCHC	
14	VT	03 Máy tính phục vụ công tác tổng hợp	HW	TCHC.VT.HW.0003	1	2	2	5	2	TCHC	
15	VT	01 Máy tính phục vụ công tác văn thư	HW	TCHC.VT.HW.0004	1	2	2	5	2	TCHC	

BM01.01

Phụ lục 9: Bảng đánh giá rủi ro ATTT (trích lược)

BÁO CÁO KẾT QUẢ ĐÁNH GIÁ RỦI RO AN TOÀN THÔNG TIN													
Phạm vi thực hiện:		x Cấp đơn vị/ Tên đơn vị: Phòng Tổ chức - Hành chính Cấp công ty											
KIỂM KÊ TSTT			NHẬN DIỆN RỦI RO					ĐÁNH GIÁ RỦI RO					
ST T	Mã TSTT	Tên TSTT	Giá trị TSTT	Mối đe dọa	Điểm yếu	Biện pháp kiểm soát hiện có	Hiệu lực & hiệu quả của biện pháp hiện có	Biện pháp kiểm soát dự định/ bổ sung	Điểm Tồn thất lên SXKD	Điểm Tác động	Điểm Khả năng xảy ra	Điểm Mức độ rủi ro	Quyết định hành động giải quyết rủi ro
	(1)	(2)	(3)	(4)	(5)	(6)	(7)	(8)	(9)	(10)	(11)	(12)	(13)
1	TCHC.QL.IF.0001	Quy trình thuộc hệ thống quản lý tích hợp của Công ty theo chức năng của Phòng	3	T.P01 (Cháy); T.P02 (Thiết hại do nước); T.N03 (Hiện tượng núi lửa); T.N05 (Lũ lụt); T.I04 (Trộm phương tiện hoặc tài liệu).	V.H08 (Kho không được bảo vệ); V.P05 (Thiếu nhận thức về ATTT); V.P06 (Thiếu các cơ chế giám sát); V.O10 (Không có thủ tục kiểm soát sự thay đổi); V.O14 (Không phân công trách nhiệm về ATTT một cách thích hợp).	- Phương án chữa cháy tại trụ sở Văn phòng công ty ở số 123, đường.... (PA-TCHC-09); - Quy trình kiểm soát tài liệu (QT.01); - Quy trình kiểm soát hồ sơ (QT.02); - Bảng kiểm kê tài sản thông tin cấp đơn vị (BM01.01)	Đã có quy định (văn bản) và có hiệu lực, có hiệu quả.	Không	1	2	1	2	XL7
2	TCHC.QL.IF.0002	Hệ thống các công văn đi, đến trong Công ty	3	T.P01 (Cháy); T.P02 (Thiết hại do nước); T.N03 (Hiện tượng núi lửa); T.N05 (Lũ lụt); T.I04 (Trộm phương tiện hoặc tài liệu).	V.H08 (Kho không được bảo vệ); V.P05 (Thiếu nhận thức về ATTT); V.P06 (Thiếu các cơ chế giám sát); V.O10 (Không có thủ tục kiểm soát sự thay đổi); V.O14 (Không phân công trách nhiệm về ATTT một cách thích hợp).	- Phương án chữa cháy tại trụ sở Văn phòng công ty ở số 123, đường.... (PA-TCHC-09); - Quy trình kiểm soát tài liệu (QT.01); - Quy trình kiểm soát hồ sơ (QT.02); - Bảng kiểm kê tài sản thông tin cấp đơn vị (BM01.01)	Đã có quy định (văn bản) và có hiệu lực, có hiệu quả.	Không	1	2	1	2	XL7

Diễn giải về các hướng hành động xử lý rủi ro an toàn thông tin	
(1) Tránh rủi ro (quyết định không bắt đầu hay tiếp tục hoạt động gây ra rủi ro)	(5) Thay đổi (giảm) Hậu quả của rủi ro
Ký hiệu: XL1	Ký hiệu: XL5
(2) Nhận vào hay gia tăng rủi ro lên để theo đuổi 1 cơ hội	(6) Chuyển giao/ Chia sẻ rủi ro với bên/ các bên khác
Ký hiệu: XL2	Ký hiệu: XL6
(3) Loại bỏ nguồn gây ra rủi ro	(7) Giữ lại rủi ro bằng quyết định được thông báo
Ký hiệu: XL3	Ký hiệu: XL7
(4) Thay đổi (giảm) Khả năng xảy ra của rủi ro	
Ký hiệu: XL4	

Phụ lục 10: Mục tiêu an toàn thông tin (ví dụ minh họa)

MỤC TIÊU AN TOÀN THÔNG TIN NĂM YYYY

Để đảm bảo sự phù hợp và hiệu lực, hiệu quả liên tục của hệ thống quản lý an toàn thông tin (ISMS) theo định hướng trong Chính sách An toàn thông tin đã công bố, Công ABC đã thiết lập các Mục tiêu an toàn thông tin cho giai đoạn năm YYYY như dưới đây.

1. NỘI DUNG MỤC TIÊU:

Mục tiêu ATTT chung	Đo lường/ Phép đo/ Chỉ số đánh giá	Mục tiêu an toàn thông tin năm YYYY
(1) Bảo vệ Tính bảo mật, Tính toàn vẹn, Tính sẵn có của các tài sản thông tin phục vụ sản xuất - kinh doanh sản phẩm ABC; cung cấp dịch vụ XYZ.	- Số lần sự cố an toàn thông tin liên quan đến tổn thất dữ liệu hoặc lỗ hổng về bảo mật. - Hiệu quả của hệ thống firewall. - Hiệu quả của việc back-up dữ liệu.	- Đảm bảo giải quyết sự cố ATTT gây gián đoạn bất kỳ dịch vụ nào của hệ thống mạng kiểm soát điều hành của công ty do yếu tố ngoại vi trong vòng tối đa là 20 phút; - Giảm số lượng các lần khiếu nại, phàn nàn về ATTT bởi khách hàng (nội bộ) xuống dưới xxx lần/ năm. - Hệ thống tường lửa sẽ ngăn chặn 100% các trường hợp xâm nhập hệ thống thông tin không mong muốn. - Đảm bảo khôi phục 100% dữ liệu liên quan

		đến quá trình sản xuất - kinh doanh trọng yếu. 5. Đảm bảo 100% nhân viên công ty có liên quan đến khai thác, sử dụng các tài sản thông tin trọng yếu được đào tạo về các biện pháp kiểm soát rủi ro ATTT áp dụng kiểm soát rủi ro gắn với tài sản đó.
	• Cập nhật hồ sơ đánh giá rủi ro ATTT.	6. Hoàn thành xem xét và cập nhật hồ sơ đánh giá rủi ro ATTT ít nhất 1 năm/1 lần
(2) Bảo vệ các tài sản thông tin của công ty khỏi trộm cắp, bị lạm dụng và bất kỳ hình thức thiệt hại nào.	• Số lượng sự cố ATTT liên quan đến tổn thất/mất cắp thiết bị trong hệ thống thông tin.	7. Không có sự cố xảy ra.
	• Số điểm Không phù hợp nặng so với các Chính sách, Thủ tục/quy trình đảm bảo ATTT trong ISMS.	8. Không có tình huống vi phạm nghiêm trọng hoặc Điểm không phù hợp nặng được phát hiện qua kiểm tra của lãnh đạo và/hoặc qua đánh giá nội bộ, bên ngoài.
(3) Thiết lập, thực hiện	• Các hoạt động tuyên	9. Tổ chức 01 khóa đào tạo nội bộ nhằm nâng

các vai trò, trách nhiệm đối với an toàn thông tin trong công ty.	truyền, nâng cao nhận thức cho nhân viên.	cao nhận thức chung về hệ thống quản lý ATTT của công ty. 10. Tổ chức ít nhất 01 khóa đào tạo nội bộ về kỹ năng nhằm hỗ trợ thực hiện các biện pháp kiểm soát ATTT cho toàn thể cán bộ, chuyên viên khi thực hiện các quá trình nghiệp vụ.
	Đánh giá nội bộ, xem xét của lãnh đạo về ISMS để đảm bảo nâng cao nhận thức và sự tuân thủ của nhân viên.	11. Thực hiện, duy trì tần suất đánh giá nội bộ hệ thống ISMS theo đúng kế hoạch tiến độ triển khai ISMS và kế hoạch đánh giá nội bộ chung của công ty năm YYYY. 12. Thực hiện ít nhất 01 lần xem xét của lãnh đạo về ISMS vào tháng 6/YYYY theo đúng tiến độ triển khai ISMS.
(4) Đảm bảo công ty có thể tiếp tục các hoạt động sản xuất-kinh doanh của mình trong tình huống các sự cố	Số lượng các sự cố liên quan đến Tính sẵn có của các dịch vụ trọng yếu thông qua mạng điều hành chung	13. Duy trì ít nhất 1 lần test /1 tháng đối với mỗi loại dịch vụ qua hệ thống/ mạng.

về an toàn thông tin.	của công ty.	
	Mức độ thành công của các lần thử nghiệm kế hoạch đảm bảo tính liên tục kinh doanh.	14. Đảm bảo 99% mức độ thành công cho mỗi lần test. 15. Xử lý sự cố (nếu có) trong vòng 20 phút.
(5) Hoàn thành giai đoạn triển khai để được đánh giá chứng nhận ISMS theo ISO/IEC 27001:2013	Hoàn thành các bước triển khai ISMS theo kế hoạch tổng thể, đảm bảo hệ thống phù hợp và đầy đủ hồ sơ, bằng chứng liên quan theo yêu cầu.	16. Được tổ chức chứng nhận độc lập được công ty lựa chọn đánh giá chứng nhận vào đầu tháng 8/YYYY. 17. Hoàn thành hồ sơ khắc phục sau đánh giá trong tháng 8/YYYY.

2. TRÁCH NHIỆM TỔ CHỨC TRIỂN KHAI:

2.1. Giám đốc công ty, Đại diện Lãnh đạo ATTT sẽ áp dụng các hình thức thích hợp và hiệu quả để truyền đạt Mục tiêu an toàn thông tin hàng năm của công ty đến toàn thể nhân viên, nhằm đảm bảo mọi người đều thấu hiểu và thực hiện.

2.2. Đại diện Lãnh đạo ATTT chịu trách nhiệm đảm bảo xây dựng kế hoạch cụ thể để thực hiện

Mục tiêu ATTT hàng năm; phân công trách nhiệm theo dõi, đánh giá tiến độ thực hiện, tổng hợp báo cáo định kỳ hàng quý đến Giám đốc.

Ngày tháng năm YYYY

GIÁM ĐỐC

Phụ lục 11: Kế hoạch xử lý rủi ro an toàn thông tin (trích lược)

KẾ HOẠCH XỬ LÝ RỦI RO AN TOÀN THÔNG TIN													
Phạm vi thực hiện:				x		Cấp đơn vị/ Tên đơn vị: Phòng Kỹ thuật				Cấp công ty			
STT	Mã TSTT	Tên TSTT	Giá trị TSTT	Mối đe dọa	Điểm yếu	Điểm Mức độ rủi ro	Chủ rủi ro/ chủ rủi ro được ủy quyền		Quyết định hành động giải quyết rủi ro	Mô tả hành động giải quyết rủi ro	Tham chiếu đến biện pháp kiểm soát ở Phụ lục A, ISO/IEC 27001:201	Đơn vị/ bộ phận phối hợp thực hiện	Tiến độ Thời hạn hoàn thành
							Đơn vị	Cá nhân					
1	KT.IT.HW.0001	Các máy chủ	3	T.P01: Cháy; T.I02:Gián điệp từ xa; T.I10:Giả mạo phần mềm;	V.S15 (Quản lý mật khẩu không hiệu quả); V.P05 (Thiếu nhân thức về ATTT); V.P06 (Thiếu các	6	KT		XL4 XL5	Thay đổi (giảm) Khả năng xảy ra	A.11.2; A.12.2.1; A.12.3.1;	TCHC	1 tuần kể từ ngày
2	KT.IT.HW.0002	Switch, Router	3	T.P01: Cháy; T.F01: lỗi khi sử dụng T.T01: Lỗi thiết bị	V.H03:Nhảy cảm với độ ẩm, bụi, bắn V.Si01:Bất cẩn hoặc sử dụng	3	KT		XL4 XL5	Thay đổi (giảm) Khả năng xảy ra	A.11.2; A.12.4.1	TCHC	1 tuần kể từ ngày
3	KT.IT.HW.0003	Modem ADSL	3	T.P01: Cháy; T.F01: lỗi khi sử dụng T.T01: Lỗi thiết bị	V.H03:Nhảy cảm với độ ẩm, bụi, bắn V.Si01:Bất cẩn hoặc sử dụng	6	KT		XL4 XL5	Thay đổi (giảm) Khả năng xảy ra	A.11.2; A.12.4.1	TCHC	1 tuần kể từ ngày
4	KT.IT.HW.0004	UPS	2	T.P01: Cháy; T.F01: lỗi khi sử dụng T.T01: Lỗi thiết bị	V.H03:Nhảy cảm với độ ẩm, bụi, bắn V.Si01:Bất cẩn hoặc sử dụng	1	KT		XL7	Giữ lại rủi ro bằng quyết định được			
5	KT.IT.HW.0005	Tường lửa Cisco	3	T.P01: Cháy; T.F01: lỗi khi sử dụng T.T01: Lỗi thiết bị	V.H03:Nhảy cảm với độ ẩm, bụi, bắn V.Si01:Bất cẩn hoặc sử dụng	6	KT		XL4 XL5	Thay đổi (giảm) Khả năng xảy ra	A.11.2; A.12.4.1	TCHC	1 tuần kể từ ngày
6	KT.IT.HW.0006	Access Point	2	T.P01: Cháy; T.F01: lỗi khi sử dụng T.T01: Lỗi thiết bị	V.H03:Nhảy cảm với độ ẩm, bụi, bắn V.Si01:Bất cẩn hoặc sử dụng	2	KT		XL7	Giữ lại rủi ro bằng quyết định được			
7	KT.IT.HW.0007	Đầu ghi camera	3	T.P01: Cháy; T.F01: lỗi khi sử dụng T.T01: Lỗi thiết bị	V.H03:Nhảy cảm với độ ẩm, bụi, bắn V.Si01:Bất cẩn hoặc sử dụng	4	KT		XL4 XL5	Thay đổi (giảm) Khả năng xảy ra	A.11.2; A.12.4.1	TCHC	1 tuần kể từ ngày

Phụ lục 12: Thông báo việc áp dụng (SoA) (ví dụ)

Công ty ABC		THÔNG BÁO ÁP DỤNG/ STATEMENT OF APPLICABILITY (dựa theo Phụ lục A - ISO/IEC 27001:2013 & phạm vi ISMS của công ty)				Mã hiệu:	SoA			
						Lần ban hành:	1			
						Ngày hiệu lực:	.../.../....			
						Trang/Tổng trang:	xem footer			
Phụ lục A - ISO/IEC 27001: 2013	Chủ đề kiểm soát (A.I)/ Mục tiêu kiểm soát (A.I.I)/ Biện pháp kiểm soát (A.I.I.I)	Mô tả biện pháp kiểm soát qua Phụ lục A - ISO/IEC 27001:2013	Mức độ áp dụng hiện tại	Tóm tắt về Biện pháp kiểm soát đã / đang thực hiện tương ứng	Nhận xét về việc áp dụng/ Lý giải nếu đã chọn "Không áp dụng" ở cột (4)	Biện pháp kiểm soát đã chọn và lý do chọn (x)				Khái quát/ tóm tắt về việc thực hiện biện pháp kiểm soát đã chọn
(1)	(2)	(3)	(4)	(5)	(6)	PL	HD	NV	RR	
(7)	(8)	(9)	(10)	(11)						
A.5	Chính sách an toàn thông tin									
A.5.1	Định hướng của lãnh đạo về an toàn thông tin	Nhằm cung cấp định hướng và hỗ trợ của lãnh đạo về an toàn thông tin phù hợp với các yêu cầu kinh doanh, môi trường pháp lý và các quy định pháp luật, định chế liên quan.								
A.5.1.1	Các chính sách an toàn thông tin	Một tập hợp các chính sách an toàn thông tin phải được xác định, phê duyệt bởi lãnh đạo, được công bố và được truyền đạt tới nhân viên cũng như các bên bên ngoài có liên quan.	Áp dụng	Chính sách ISMS được duyệt ngày .../.../... bởi Giám đốc công ty, ban hành, phân phối đến tất cả CBCNV.	Sẵn có cho mọi CBCNV/ (bản cứng, điện tử) và sẵn sàng cho bên ngoài khi cần.			x	x	Các Chính sách đầy đủ, toàn diện và đã được truyền đạt, nhận thức.
A.5.1.2	Xem xét các chính sách an toàn thông tin.	Các chính sách an toàn thông tin phải được xem xét định kỳ hoặc khi có những thay đổi lớn xảy ra để đảm bảo chúng tiếp tục phù hợp, thỏa đáng và có hiệu lực.	Áp dụng	Các Chính sách ATTT được xem xét định kỳ ít nhất hàng năm thông qua đánh giá nội bộ (theo QT.03) và xem xét của lãnh đạo về ISMS (theo QT.05).	Hồ sơ ĐGNB ISMS & Hồ sơ xem xét của lãnh đạo hàng năm.			x	x	Đảm bảo duy trì tính phù hợp, thỏa đáng và có hiệu lực của Chính sách.
A.6	Tổ chức an toàn thông tin									
A.6.1	Tổ chức nội bộ	Nhằm thiết lập một nền tảng quản lý để khởi tạo và kiểm soát việc thực hiện và điều hành an toàn thông tin trong tổ chức.								
A.6.1.1	Vai trò và trách nhiệm an toàn thông tin	Tất cả các trách nhiệm an toàn thông tin phải được xác định và phân công	Áp dụng	Quy định về vai trò, trách nhiệm, quyền hạn trong ISMS (Quy-ATTT-01) được duyệt bởi Giám đốc công ty, ban hành, phân phối đến tất cả CBCNV.	Sẵn có cho mọi CBCNV/ (bản cứng, điện tử) và sẵn sàng cho bên ngoài khi cần.			x	x	Quy định đã được truyền đạt, nhận thức.
A.6.1.2	Phân tách nhiệm vụ	Các nhiệm vụ và phạm vi trách nhiệm đối lập nhau phải được phân tách nhằm giảm thiểu các cơ hội sửa đổi trái phép hoặc không	Áp dụng	Quy định trong phần Mô tả vắn tắt về trách nhiệm trong ISMS tại Quy-ATTT-01, ban hành,	Sẵn có cho mọi CBCNV/ (bản cứng, điện tử) và sẵn sàng cho			x	x	Quy định đã được truyền đạt, nhận thức.

A.18.2.1	Việc xem xét độc lập về an toàn thông tin	Phải tiến hành, theo định kỳ hoặc khi có xảy ra các thay đổi lớn, việc xem xét độc lập phương pháp quản lý an toàn thông tin của tổ chức và việc thực hiện chúng (ví dụ các mục tiêu kiểm soát, các chính sách, các quá trình, các thủ tục về an toàn thông tin).	Áp dụng	Được xem xét định kỳ ít nhất hàng năm thông qua đánh giá nội bộ (theo QT-HT-03) và xem xét của lãnh đạo về ISMS (theo QT-HT-05).	Hồ sơ ĐGNB ISMS & Hồ sơ xem xét của lãnh đạo hàng năm.	x		x	x	Đảm bảo duy trì tính phù hợp, thỏa đáng và có hiệu lực của Chính sách.
A.18.2.2	Tuân thủ theo các chính sách an toàn và các thủ tục	Các quản lý phải thường xuyên xem xét sự tuân thủ và xử lý thông tin và các thủ tục trong phạm vi trách nhiệm của họ so với các chính sách, tiêu chuẩn về an toàn thích hợp và theo bất kỳ yêu cầu an toàn khác.	Áp dụng	Được xem xét định kỳ ít nhất hàng năm thông qua đánh giá nội bộ (theo QT.03) và xem xét của lãnh đạo về ISMS (theo QT.05).	Hồ sơ ĐGNB ISMS & Hồ sơ xem xét của lãnh đạo hàng năm.	x		x	x	Đảm bảo duy trì tính phù hợp, thỏa đáng và có hiệu lực của Chính sách.
A.18.2.3	Xem xét sự tuân thủ về kỹ thuật	Phải xem xét thường xuyên các hệ thống thông tin về sự tuân thủ theo các chính sách và tiêu chuẩn về an toàn thông tin của tổ chức.	Áp dụng	Được xem xét định kỳ ít nhất hàng năm thông qua đánh giá nội bộ (theo QT.03) và xem xét của lãnh đạo về ISMS (theo QT.05).	Hồ sơ ĐGNB ISMS & Hồ sơ xem xét của lãnh đạo hàng năm.	x		x	x	Đảm bảo duy trì tính phù hợp, thỏa đáng và có hiệu lực của Chính sách.
										
Điểm mục	Nhân màu tình trạng của Biên pháp kiểm soát đã xác định	Ý nghĩa	Tỉ lệ							
100	Áp dụng	Biên pháp kiểm soát này hoàn toàn cần thiết để giảm thiểu các rủi ro không thể chấp nhận (giải thích lý do áp dụng biên pháp kiểm soát này ở cột (6)).	88%							
1	Áp dụng một phần	Biên pháp kiểm soát này, hoặc 1 tùy biến của nó, có thể cần thiết trong 1 số tình huống để giảm thiểu rủi ro không thể chấp nhận (giải thích lý do áp dụng 1 phần biên pháp kiểm soát này ở cột (6)).	1%							
13	Không áp dụng	Biên pháp kiểm soát này là không cần thiết, thường vì lãnh đạo tin rằng các rủi ro tương ứng là có thể chấp nhận được (giải thích lý do Không áp dụng biên pháp kiểm soát này ở cột (6)).	11%							
114	Tổng									
	Lập bởi:	Kiểm tra:	Xem xét:		Phê duyệt ngày:					
	TỔ TRƯỞNG THƯ KÝ ISO/IEC 27001		PHÓ GIÁM ĐỐC/ ĐẠI DIỆN LÃNH ĐẠO AN TOÀN THÔNG TIN		GIÁM ĐỐC					

Phụ lục 13: Chính sách cụ thể đảm bảo an toàn thông tin

AN TOÀN NGUỒN NHÂN LỰC
TRƯỚC KHI KẾT THÚC/ CHẤM DỨT HOẶC THAY ĐỔI CÔNG VIỆC
(ví dụ minh họa)

CÔNG TY ABC	CHÍNH SÁCH AN TOÀN NGUỒN NHÂN LỰC RƯỚC KHI KẾT THÚC/ CHẤM DỨT HOẶC THAY ĐỔI CÔNG VIỆC	Mã hiệu: CS.05
		Lần ban hành: 01
		Ngày ban hành:/ /yyyy
		Trang/Tổng số: 166/3
1. Mục đích: Để đảm bảo rằng các nhân viên của công ty, nhân viên của nhà thầu và nhà cung cấp rời khỏi công ty hoặc có thay đổi về vị trí việc làm theo một cách thức được kiểm soát để đảm bảo an toàn thông tin. 2. Phạm vi: Trách nhiệm phải được xác định để đảm bảo việc ra đi/ kết thúc việc làm của một nhân viên, nhà thầu hoặc nhà cung cấp được quản lý, và hoàn thành việc trả lại tất cả các thiết bị và loại bỏ tất cả các		

quyền truy cập. Các thay đổi về trách nhiệm và công việc trong công ty sẽ được quản lý phù hợp với phần quy định này, và bất kỳ việc làm nào mới cũng sẽ được quản lý theo chính sách an toàn hiện có.

Quy định an toàn nguồn nhân lực - trước khi kết thúc/chấm dứt, thay đổi công việc này được áp dụng cho tất cả nhân sự làm việc cho công ty.

3. Trách nhiệm và các yêu cầu cụ thể:

3.1. Quy định chung:

Công ty đảm bảo thiết lập các thủ tục theo đó nêu ra các bước mà nhân viên phải tuân theo để thông báo cho các cá nhân thích hợp khi tài khoản người dùng không còn cần thiết hoặc khi tài khoản người dùng phải được cập nhật khi có sự thay đổi trong nhiệm vụ chính của một nhân viên.

Các tình huống đòi hỏi phải có một sự thay đổi có thể bao gồm: chấm dứt, chuyển giao, hoặc thay đổi trong nhiệm vụ và mỗi tình huống phải được giải quyết theo các thủ tục, cũng như người chịu trách nhiệm cho mỗi bước của quá trình.

3.2. Chấm dứt trách nhiệm (theo mục A.7.3.1, Phụ lục A, tiêu chuẩn ISO/IEC 27001:2013)

- a) Trách nhiệm để thực hiện chấm dứt hoặc thay đổi việc làm cần được xác định và phân công rõ ràng.
- b) Thông tin liên lạc về việc chấm dứt trách nhiệm phải bao gồm các yêu cầu đảm bảo an toàn thông tin liên tục và trách nhiệm pháp lý và khi thích hợp, trách nhiệm đã nêu trong bất kỳ thỏa thuận/ cam kết về an toàn, và các điều khoản và điều kiện làm việc, có thể vẫn tiếp tục

trong một thời gian xác định sau khi kết thúc công việc của nhân viên, người sử dụng bên nhà thầu hoặc nhà cung cấp.

3.3. Trả lại tài sản (theo mục A.8.1.4, Phụ lục A, tiêu chuẩn ISO/IEC 27001:2013)

- a) Tất cả các nhân viên, nhà thầu và nhà cung cấp phải trả lại tất cả các tài sản thông tin của công ty mà họ là chủ thể sở hữu mỗi khi chấm dứt việc làm, hợp đồng hoặc thỏa thuận với họ.
- b) Phòng Hành chính - Nhân sự (khi cần thiết, có sự phối hợp của BP. IT) sẽ thiết lập, sắp xếp việc chấm dứt và/ hoặc chuyển giao liên quan việc trả lại tài sản thông tin (kể cả tài sản vật lý và tài sản tri thức) đã được cung cấp để truy cập vào hệ thống và các dữ liệu, tài sản thông tin nhạy cảm và các phương tiện/ nơi bố trí, lưu giữ. Những tài sản này bao gồm, nhưng không giới hạn:
- Phần mềm đã phát hành,
 - Các tài liệu của công ty,
 - Các thiết bị của công ty, các thiết bị ICT di động,
 - Thẻ tín dụng,
 - Thẻ từ ra/vào các khu vực làm việc
 - Các hướng dẫn sử dụng/ sổ tay chỉ dẫn công việc (Manual),
 - Thông tin được lưu trữ trên phương tiện truyền thông điện tử di động của công ty.

- c) Trong trường hợp một nhân viên, nhà thầu hoặc nhà cung cấp mua thiết bị của công ty hoặc sử dụng thiết bị cá nhân của mình, các thủ tục sẽ được lập và thực hiện để đảm bảo rằng tất cả các thông tin liên quan được chuyển giao lại cho công ty và được xóa an toàn khỏi thiết bị.
- d) Trong trường hợp nhân viên, nhà thầu hoặc người sử dụng của bên thứ ba có nắm các thông tin có ý nghĩa quan trọng đối với hoạt động sản xuất- kinh doanh liên tục của công ty, các thông tin đó sẽ được ghi lại và chuyển giao cho công ty trước khi chấm dứt hoặc thay đổi việc làm.

3.4. Hủy bỏ quyền truy cập (theo mục A.9.2.6, Phụ lục A, tiêu chuẩn ISO/IEC 27001:2013)

- a) Quyền truy cập của tất cả nhân viên, nhà thầu/ nhà cung cấp vào các phương tiện xử lý thông tin và thông tin phải được loại bỏ khi chấm dứt việc làm, hợp đồng hoặc thoả thuận, hoặc điều chỉnh khi thay đổi.
- b) Quyền truy cập vào hệ thống thông tin và dữ liệu của công ty phải được chấm dứt đồng thời mỗi khi không còn yêu cầu truy cập (ví dụ như kết quả của chuyển giao, chấm dứt, và sự thay đổi của nhiệm vụ).
- c) Quyền truy cập phải được loại bỏ ngay lập tức đối với nhân viên kết thúc làm việc theo bất buộc, đối với cho các cá nhân được phép đối với hệ thống có các thông tin nhạy cảm hay có yêu cầu bảo mật, hoặc các cá nhân ở các vị trí có quyền “siêu truy cập” (chẳng hạn như các quản trị viên bảo mật). Tất cả các truy cập khác cần được loại bỏ trong vòng 05 ngày làm việc. Toàn bộ quá trình được tính từ ngày đầu tiên nhân viên được thông báo về việc chấm

dứt.

- d) Bộ phận IT sẽ ghi lại việc tạm thời vô hiệu hóa quyền truy cập vật lý và các hệ thống mạng của công ty khi nhân viên ra ngoài trong khoảng thời gian kéo dài quá 30 ngày do vấn đề cá nhân (ví dụ ốm đau kéo dài) hoặc mục đích được phép khác. Vô hiệu hóa quyền truy cập vật lý và các hệ thống mạng cũng áp dụng trong trường hợp đình chỉ công tác vì mục đích kỷ luật. Các trường hợp ngoại lệ có thể được cho phép khi có yêu cầu và có chấp thuận của lãnh đạo.
- e) Việc loại bỏ quyền truy cập phải bao gồm cả truy cập vật lý và logic, chìa khóa, thẻ nhận dạng, phương tiện xử lý thông tin, đăng ký, và loại bỏ từ bất kỳ tài liệu nào có nhận dạng một nhân viên như một thành viên hiện tại của tổ chức.
- f) BP. IT chịu trách nhiệm thường xuyên xem xét các quyền truy cập của người sử dụng theo tần suất ít nhất mỗi năm một lần và báo cáo cho TP. Công nghệ để tham mưu cho ISMS-MR có các quyết định thích hợp về việc phân quyền truy cập.
- g) Mật khẩu, kết hợp khóa, hoặc các biện pháp kiểm soát tương tự phải được thay đổi khi chấm dứt của một nhân viên, nhà thầu, hoặc nhà cung cấp.
- h) Quyền truy cập đối với các tài sản thông tin và các phương tiện xử lý thông tin phải được giảm bớt hoặc loại bỏ trước khi chấm dứt hoặc thay đổi công việc, tùy thuộc vào việc đánh giá các yếu tố rủi ro sau:
 - Bất kể việc chấm dứt hoặc thay đổi được phát sinh từ nhân viên, nhà thầu hoặc nhà cung

cấp, hoặc bởi lãnh đạo của công ty và lý do để chấm dứt;

- Trách nhiệm hiện tại của nhân viên, nhà thầu hoặc người sử dụng khác;
- Giá trị của tài sản có thể truy cập hiện tại.

Tài liệu tham chiếu:

- Cơ cấu tổ chức, trách nhiệm, quyền hạn trong hệ thống quản lý ATTT của công ty, kèm theo bộ Mô tả công việc trong công ty;
- Bản cam kết bảo vệ thông tin.

Phụ lục 14: KẾ HOẠCH ĐO LƯỜNG HIỆU LỰC CỦA ISMS THEO ISO/IEC 27001:2013

(ví dụ minh họa)

KẾ HOẠCH ĐO LƯỜNG HIỆU LỰC HỆ THỐNG QUẢN LÝ AN TOÀN THÔNG TIN

Năm: _____

STT	Tên chủ đề đo lường hiệu lực ISMS	Trách nhiệm đo lường		Tần suất/ Thời gian thực hiện ¹					Cách thức đo và hồ sơ kết quả đo lường ² (theo Phụ lục của ISO/IEC 27004:2016)	Ghi chú
		Chủ trì ³	Phối hợp	Tần suất thu thập data	Tần suất phân tích data	Tần suất báo cáo kết quả đo lường	Soát xét sau đối phép đo	Chu kỳ đo lường		
1.	Đào tạo nhân viên về ISMS	...		Hàng tháng, ngày làm việc đầu tiên	Hàng quý	Hàng quý	Xem xét hàng năm	Hàng năm	Phụ lục B.11	
2.	Đào tạo ATTT			Hàng tháng, ngày làm việc đầu tiên	Hàng quý	Hàng quý	Xem xét hàng năm	Hàng năm	Phụ lục B.12	
3.	Tuân thủ nhận thức về ATTT			Hàng tháng, ngày làm việc đầu tiên	Hàng quý	Hàng quý	Xem xét hàng năm	Hàng năm	Phụ lục B.13	
4.	Chất lượng của mật khẩu (thủ công)			Hàng năm	Hàng năm	Hàng năm	Xem xét, cập nhật hàng năm	Hàng năm	Phụ lục B.16	
5.	Chất lượng của mật khẩu (tự động)			Hàng tuần	Hàng tuần	Hàng tuần	Xem xét, cập nhật hàng năm	3 năm áp dụng	Phụ lục B.17	
6.	Quá trình xem xét ISMS			Hàng quý	Hàng quý	Hàng quý	Xem xét, cập nhật mỗi 2 năm	2 năm áp dụng	Phụ lục B.35	

¹ Chủ đề đo lường, tần suất, thời gian có sẵn ở đây được trích dẫn từ Danh mục ở Phụ lục B1 của ISO/IEC 27004:2016. Tùy thực tế mà công ty để xác định tần suất / thời gian cho phù hợp để áp dụng theo đúng tần suất đó.

² Tham chiếu đến định dạng báo cáo kết quả đo lường quy định tại mục "Định dạng báo cáo trong "Mục 7. Kết quả đo lường" ở các Phụ lục thuộc Quy trình đo lường hiệu lực ISMS (ATT.05).

³ Căn cứ theo chủ đề đo lường, các trách nhiệm liên quan sẽ được xác định cho thích hợp ở công ty (tham khảo mục "Responsible Parties" ở Phụ lục B2 ~ B35 để xác định trách nhiệm đối với Chủ thể thông tin (Information Owner), Người thu thập thông tin (Information collectors) và Khách hàng đo lường (Measurement Information security client).

CÔNG TY ABC

7.	Hiệu lực quản lý sự cố ATTT			Hàng tháng	Hàng tháng	Hàng tháng	6 tháng	Hàng tháng	Phụ lục B.32	
8.	Thực hiện hành động khắc phục			Hàng quý	Hàng quý	Hàng quý	Xem xét hàng năm	1 năm áp dụng	Phụ lục B.10	
9.	Cam kết của lãnh đạo			Hàng tháng	Hàng quý	Hàng quý	Xem xét, cập nhật mỗi 2 năm	2 năm áp dụng	Phụ lục B.4	
10.	Bảo vệ chống lại các mã độc			Hàng ngày	Hàng tháng	Hàng tháng	Xem xét hàng năm	1 năm áp dụng	Phụ lục B.23	
11.	Kiểm soát thâm nhập vật lý			Hàng năm	Hàng năm	Hàng năm	Xem xét, cập nhật hàng năm	12 tháng áp dụng	Phụ lục B.20	
12.	Xem xét các file nhật ký (log file)			Hàng tháng	Hàng tháng	Hàng quý	Xem xét hàng năm	Xem xét hàng năm	Phụ lục B.27	
13.	Quản lý bảo trì định kỳ			Hàng năm	Hàng năm	Hàng năm	Hàng năm	Hàng năm	Phụ lục B.21	
14.	An toàn trong thỏa thuận với bên thứ ba			Hàng tháng	Hàng quý	Hàng quý	Xem xét, cập nhật mỗi 2 năm	2 năm áp dụng	Phụ lục B.31.1/ B.31.2	

Lập ngày:

Kiểm tra ngày:

Xem xét ngày:

Phê duyệt ngày:

Điều phối viên ATTT

Tổ trưởng
Thư ký ISO/IEC 27001

Đại diện lãnh đạo
An toàn thông tin / ISMS-MR

GIÁM ĐỐC

Phụ lục 15: HOẠCH ĐỊNH CỤ THỂ ĐO LƯỜNG HIỆU LỰC ISMS

Đo lường chất lượng mật khẩu truy cập vào hệ thống thông tin của công ty bằng phương pháp thủ công (ví dụ minh họa)

Ký hiệu/ ID của phép đo	ISMS.ĐL.P.W-01
Nhu cầu thông tin	Nhằm đánh giá chất lượng của mật khẩu được người dùng sử dụng để truy cập vào hệ thống IT của công ty.
Chỉ số đo	Tổng số mật khẩu đáp ứng chính sách chất lượng mật khẩu của công ty: a) Tỷ số mật khẩu thỏa mãn chính sách chất lượng mật khẩu của công ty. b) Xu hướng của sự tuân thủ theo chính sách chất lượng mật khẩu.
Công thức/ điểm số	Đếm số lượng mật khẩu trong cơ sở dữ liệu mật khẩu của người dùng. Xác định số lượng mật khẩu đáp ứng chính sách mật khẩu của công ty. Σ của [Tổng số mật khẩu đáp ứng chính sách chất lượng mật khẩu của công ty cho mỗi người dùng]. a) Tỷ số mật khẩu đáp ứng chính sách chất lượng mật khẩu của công ty. b) Xu hướng của sự tuân thủ chính sách chất lượng mật khẩu của công ty.

	c) Chia [Tổng số mật khẩu đáp ứng chính sách chất lượng mật khẩu của công ty] cho [Số mật khẩu đã được đăng ký] d) So sánh tỉ số hiện tại với tỉ số trước đó.
Mục tiêu	- Nếu tỉ số là trên 0.9: mục tiêu kiểm soát được xem là đạt và không cần có hành động tiếp theo. - Nếu tỉ số là giữa 0.8 và 0.9: chưa đạt mục tiêu kiểm soát, tuy nhiên nếu xu hướng là dương so với tỉ số kỳ trước đó thì sẽ ghi nhận có sự cải thiện. - Nếu tỉ số là < 0.8: cần có hành động tức thì.
Bằng chứng thực hiện	1. Đếm số mật khẩu có trên database mật khẩu người dùng. 2. Xác định số mật khẩu thỏa mãn chính sách mật khẩu của công ty.
Tần suất	- Thu thập dữ liệu: tùy thuộc vào tính trọng yếu, nhưng ít nhất là hàng năm. - Phân tích: sau mỗi lần thu thập. - Báo cáo: sau mỗi lần phân tích. - Xem xét phép đo: hàng năm. - Chu kỳ đo: hàng năm.
Các bên có trách nhiệm	Chủ thể thông tin (Information owner): Cán bộ quản trị hệ thống IT/ System administrator.

	Người thu thập thông tin (Information collector): Nhân viên ATTT/ Security staff Khách hàng phép đo (Measurement client): Lãnh đạo ISMS-MR & Giám đốc
Nguồn dữ liệu	Database mật khẩu của người dùng; các mật khẩu của cá nhân.
Định dạng báo cáo	Biểu đồ dạng đường chỉ xu hướng mật khẩu thỏa mãn chính sách chất lượng mật khẩu của công ty (kèm theo đường chỉ xu hướng của kỳ đo lường trước đó).
Theo yêu cầu ISO/IEC 27001:2013	Phụ lục A, mục A.9.3.1: Việc sử dụng thông tin xác thực bí mật

Phụ lục 16: LẬP KẾ HOẠCH ĐÁNH GIÁ NỘI BỘ ISMS THEO ISO/IEC 27001:2013

(ví dụ minh họa)

Công ty ABC

CHƯƠNG TRÌNH ĐÁNH GIÁ NỘI BỘ

Lần 1/ năm 20yy

☐ ISO 9001:2015; ☒ ISO/IEC 27001:2013; ☐ Tích hợp ISO 9001 & ISO/IEC 27001

1. Ngày đánh giá: từ .../.../20yy ~ .../.../20yy

2. Phạm vi đánh giá: ☒ toàn bộ các đơn vị trong HTQL; ☐ Có ngoại lệ (nếu lý do):

3. Mục đích đánh giá:

☒ Đánh giá định kỳ (theo Kế hoạch tổng thể triển khai ISMS); ☐ Đánh giá đột xuất (nếu rõ lý do): ...

4. Chuẩn mực đánh giá:

☐ Tiêu chuẩn ISO 9001:2015; ☒ Tiêu chuẩn ISO/IEC 27001:2013;

☐ Hệ thống tài liệu QLCL; ☒ Hệ thống tài liệu QLATT; |

☒ Các văn bản pháp luật, chế định liên quan hệ thống QLATT của công ty. □

5. Nhóm đánh giá:

- Trưởng nhóm: Nguyễn Văn A	Chức vụ: ...
- Thành viên: Trần Văn B	Chức vụ: ...
- Thành viên: Nguyễn Thị C	Chức vụ: ...

6. Nội dung và lịch trình đánh giá:

Thời gian	Thành phần/ Đơn vị được đánh giá	Chuẩn mực đánh giá (theo yêu cầu ISO/IEC 27001:2013)	Nhóm đánh giá/ ĐGV
Ngày .../.../20yy			
8:00 – 8:30	Họp khai mạc đánh giá (phòng họp 3.1): Thành phần: - Ban Giám đốc/ Ban ISO/IEC 27001 - Thư ký ISO/IEC 27001 - Trưởng/ Phó các đơn vị thuộc phạm vi ISMS		Cả nhóm đánh giá

8:30 – 11:30	- Ban Giám đốc/ Ban ISO/IEC 27001 - Thư ký ISO/IEC 27001	- Xác định bối cảnh ATTT của công ty (4.1) - Hiểu nhu cầu, mong đợi các bên quan tâm ATTT (4.2) - Xác định phạm vi ISMS (4.3) - Thiết lập hệ thống ISMS (4.4) - Sự lãnh đạo và cam kết (5.1) - Chính sách ATTT (5.2) - Vai trò, trách nhiệm, quyền hạn về ATTT (5.3) - Các hành động giải quyết rủi ro, cơ hội (6.1.1; 6.1.2; 6.1.3) / Thông báo việc áp dụng - SoA - Mục tiêu ATTT và kế hoạch thực hiện (6.2) - Nhận thức (7.3) - Hệ thống thông tin dạng văn bản của ISMS (7.5) - Hồ sơ kiểm kê, phân loại, gán nhãn TSTT (6.1; A.8.2)/ ATTT.01. - Hồ sơ đánh giá rủi ro ATTT (6.1;8.2)/ ATTT.02 - Hồ sơ xử lý rủi ro ATTT (8.3)/ RTP - Hồ sơ đánh giá kết quả hoạt động về ATTT và đo lường hiệu lực của các biện pháp kiểm soát rủi ro ATTT (9.1)/ ATTT.03 - Hoạch định, thực hiện đánh giá nội bộ ISMS (9.2) - Hoạch định, thực hiện xem xét của lãnh đạo đối với ISMS (9.3)	Cả nhóm đánh giá (trừ những người thuộc bên được đánh giá)
--------------	---	--	--

13:30 – 14:15	P. TCNS	- Việc hoạch định, thực hiện, kiểm soát các quá trình của ISMS được công ty ban hành có liên quan đến các chức năng-nhiệm vụ của đơn vị (8.1); - Việc tham gia thực hiện các quy trình thuộc ISMS đã ban hành, ví dụ QT kiểm kê, phân loại và gán nhãn tài sản ATTT; QT đánh giá rủi ro ATTT,... (8.1); - Việc áp dụng/ tuân thủ các Chính sách đảm bảo ATTT đã được công ty ban hành và kết quả áp dụng. Bao gồm: các Chính sách CS.01 ~ CS.20; Các văn bản quy định về ATTT từ ATTT.04 ~ ATTT.19 (8.2; 8.3) theo chức năng, trách nhiệm liên quan của đơn vị.	Như trên
14:15 – 15:00	P. KH		
15:00 – 17:00	P. CN		
Ngày ../.../20yy			
8:00 – 11:30 13:30 – 15:00	Nhà máy XYZ	Như nội dung đánh giá vào ngày ../.../20yy	Như trên
15:00 – 16:00	Nhóm đánh giá nhóm họp để chuẩn bị nội dung họp kết thúc		Cả nhóm
16:00 – 17:30	Họp kết thúc đánh giá (phòng họp 3.1): Thành phần như họp khai mạc.		Cả nhóm

7. Ghi chú:

Các yêu cầu sau đây của các tiêu chuẩn áp dụng sẽ được đánh giá ở tất cả các đơn vị:

- **ISO/IEC 27001:2013:** 5.3 – Vai trò, trách nhiệm, quyền hạn; 6.1 - Hành động giải quyết rủi ro, cơ hội; 6.2 – Mục tiêu ATTT và hoạch định thực hiện mục tiêu; 7.2 – Năng lực; 7.3 – Nhận thức; 7.5.3 – Kiểm soát thông tin dạng văn bản; 8.2. Đánh giá rủi ro ATTT; 8.3. Xử lý rủi ro ATTT; 10.2 – Sự không phù hợp và HDKP.

8. Phân công trách nhiệm chuẩn bị:

- 1) Các nhóm đánh giá: Trưởng nhóm và thành viên nhóm có trách nhiệm chuẩn bị đầy đủ tài liệu, phiếu hỏi đánh giá, biểu mẫu phục vụ đánh giá, tiêu chuẩn ISO/IEC 27001:2013 để hoàn thành nhiệm vụ đánh giá theo chương trình.
- 2) Các đơn vị được đánh giá: đảm bảo nhân sự có trách nhiệm (trưởng, phó đơn vị) để làm việc với nhóm đánh giá theo lịch, đồng thời chuẩn bị sẵn sàng các tài liệu, hồ sơ, bằng chứng liên quan đến các nội dung sẽ được đánh giá.



Ngày lập:		Ngày kiểm tra:	Ngày phê duyệt:
Thư ký ISO	Điều phối viên ATTT	Đại diện lãnh đạo ATTT	Giám đốc



TÀI LIỆU THAM KHẢO

- <https://www.iso.org/the-iso-survey.html>
- [https://www.iso.org/search.html?q=27000&hPP=10&idx=all_en&p=0&hFR\[category\]\[0\]=standard](https://www.iso.org/search.html?q=27000&hPP=10&idx=all_en&p=0&hFR[category][0]=standard)
- Tiêu chuẩn ISO/IEC 27000:2018 - Công nghệ thông tin - Các kỹ thuật an toàn - Hệ thống quản lý an toàn thông tin - Khái quát và từ vựng
- Tiêu chuẩn ISO/IEC 27001:2013 - Công nghệ thông tin - Các kỹ thuật an toàn - Hệ thống quản lý an toàn thông tin - Các yêu cầu
- Tiêu chuẩn ISO/IEC 27003:2017 - Công nghệ thông tin - Các kỹ thuật an toàn - Hệ thống quản lý an toàn thông tin - Hướng dẫn
- Báo cáo tổng hợp kết quả thực hiện nhiệm vụ khoa học và công nghệ “Nghiên cứu, hướng dẫn áp dụng Hệ thống quản lý an toàn thông tin (ISO/IEC 27001) và Chỉ số đánh giá hoạt động chính (KPIs)” (mã số 03.2/2013-DA2), thuộc Dự án “Thúc đẩy hoạt động năng suất và chất lượng”, thuộc Chương trình quốc gia “Nâng cao năng suất và chất lượng sản phẩm, hàng hoá của doanh nghiệp Việt Nam đến năm 2020”.

NHÀ XUẤT BẢN...

Chịu trách nhiệm xuất bản và nội dung:

Biên tập và sửa bản in:

Thiết kế bìa:

In ... cuốn, khổ...cm, tại..... Đăng ký kế hoạch xuất bản số .../CXBIPH/.../... Quyết định xuất bản số.../QĐ-... ngày.... In xong và nộp lưu chiểu năm 2020.

ISBN: